PORTFOLIO CASE STUDY

MDM GRC Readiness & Control Assurance Case Study

Readiness assessment and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company.

Prepared by
Ali Fathi Aldhabiki
Cybersecurity Governance, Risk & Compliance (GRC)
linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Frameworks
SAMA Cyber Security Framework v1.0 | NCA Essential Cybersecurity Controls (ECC-2:2024)

Notice
The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

Contents

MDM-D01 Project Foundation and Scenario Definition....3
MDM-D02 Stakeholder and RACI Matrix....11
MDM-D03 MDM Data Flow and Asset Inventory....13
MDM-D04 Risk Assessment Methodology and Risk Register....17
MDM-D05 Control Requirements and Framework Crosswalk....29
MDM-D06 Mobile Device and BYOD Policy....50
MDM-D07 MDM Security Standard....57
MDM-D08 Conditional Access Control Design....83
MDM-D09 Evidence Request List and Evidence Index....96
MDM-D10 Control Testing Workbook....118
MDM-D11 Findings and Remediation Register....150
MDM-D12 Risk Treatment and Retesting Record....169
MDM-D13 GRC Workspace and Readiness Dashboard....178
MDM-D14 Executive Readiness Report....191

Project Foundation and Scenario Definition

MDM-D01

1. Purpose and Status

This document sets the foundation for the MDM GRC readiness assessment. It defines the business scenario, objectives, scope, assumptions and the method that links MDM-D02 to MDM-D15.

It describes how the assessment is performed, not what it found. Findings, gaps and readiness conclusions are reported in MDM-D10 to MDM-D14.

Simulation statement. The organization is fictional. No Microsoft Intune or Microsoft Entra ID tenant was configured. All evidence, test results, findings and readiness ratings in MDM-D09 to MDM-D14 are simulated and labeled as such. They show how the assessment would be performed and documented. They do not demonstrate that any control was implemented or operates effectively.

Source of the scenario. The starting scenario is adapted from a training exercise on mobile device risk: the company size, BYOD without MDM, and the four business problems. The risk method, control design, framework mapping, evidence model, test approach and all documents in this case study are my own work. MDM-D15 explains this split.

2. Business Scenario

The company is a fictional Saudi financing company with 850 employees. Staff use phones and tablets to read email, join meetings and work on documents away from their desks.

The company allows employees to use personal devices for work (BYOD) but has no mobile device management (MDM). It cannot see which devices hold corporate data, enforce protection on them, or remove that data when needed.

Management requested a readiness assessment after four recurring problems:

#	Business problem	Why it matters	Linked risk (MDM-D04)
1	Lost or stolen devices	Corporate email and documents stay on devices the company cannot lock or wipe.	MDM-RSK-001
2	Access not removed when people leave	Departed workers, including contractors, can keep reaching corporate data from their devices.	MDM-RSK-007
3	Devices not updated	Devices with outdated operating systems or security patches reach corporate services with known weaknesses.	MDM-RSK-003
4	Data copied to	Work documents move to personal apps and	MDM-RSK-

#	Business problem	Why it matters	Linked risk (MDM-D04)
	personal storage	cloud accounts outside company control.	002

Introducing MDM also creates risks of its own. MDM-D04 records four: disruptive access policy changes (MDM-RSK-004), unauthorized changes to device security settings (MDM-RSK-005), inappropriate access to employee device reports (MDM-RSK-006) and inaccurate compliance reporting (MDM-RSK-008).

The selected response is Microsoft Intune with Microsoft Entra ID: MDM enrollment for company-owned devices and app protection without enrollment for BYOD. Section 4 sets its boundaries.

3. Objectives

The assessment answers one question for management: is the company ready to run mobile access to corporate data under defined, testable controls? Six objectives support that answer.

ID	Objective	Achieved when	Shown in
OBJ-01	Define the mobile service, its assets and who is responsible.	Every in-scope asset has an ID and appears in the data flow. Every assessment activity has one accountable role.	MDM-D02, MDM-D03
OBJ-02	Assess the risks of the current state and of introducing MDM.	Every risk has a statement, linked assets, a risk owner and a score under one stated method.	MDM-D04
OBJ-03	Define control requirements and map them to recognized frameworks.	Every risk links to at least one control, and every control to a framework reference, a policy clause and a technical requirement.	MDM-D05, MDM-D06, MDM-D07, MDM-D08
OBJ-04	Define how each control is evidenced and tested.	Every tested control has an evidence request, a test procedure and a pass condition set before testing.	MDM-D09, MDM-D10
OBJ-05	Turn test results into gaps, remediation and risk treatment.	Every failed or partial test becomes a finding with a gap, an owner, a due date and a retest condition.	MDM-D11, MDM-

ID	Objective	Achieved when	Shown in
			D12
OBJ-06	Give management a readiness position and a decision to make.	The report states the overall risk level, the top three gaps, the immediate action, the owner and the decision required.	MDM-D13, MDM-D14

MDM-D15 summarizes the case study for a portfolio audience. It is not an assessment objective.

4. Scope and Exclusions

The assessment covers mobile access to Microsoft 365 from Android and iOS/iPadOS devices. This scope follows MDM-D06 Section 2, MDM-D07 Section 2 and MDM-D08 Section 1; where they differ, those documents govern.

In scope

Area	In scope	Source
Users	Employees on company-owned or approved personal devices; contractors on company-issued devices; Intune administrators.	MDM-D06, MDM-D08
Company-owned Android	Android Enterprise Fully Managed, associated with a single user.	MDM-D07
Company-owned iOS/iPadOS	Automated Device Enrollment, supervised, with user affinity.	MDM-D07
Personal devices (BYOD)	Android and iOS/iPadOS for eligible, approved employees, protected by Intune App Protection without MDM enrollment. Participation is voluntary.	MDM-D06, MDM-D07
Services	Microsoft 365 email, meetings, collaboration and work documents; Microsoft Intune; Microsoft Entra ID authentication and Conditional Access.	MDM-D03, MDM-D08
Information	Corporate documents accessed on mobile devices; employee device management reports.	MDM-D03
Activities	Administering the mobile service and handling employee device management reports.	MDM-D06

MDM-D03 lists the nine in-scope assets, MDM-AST-001 to MDM-AST-009.

Out of scope

Exclusion	Reason
Windows and macOS devices	Outside the permitted scope of the mobile service (MDM-D06, MDM-D08).
Core financing and payment operations from mobile devices	Not permitted on the mobile service (MDM-D06).
Privileged administrative sessions from mobile devices	Not permitted on the mobile service (MDM-D06).
Contractors on personal devices	Contractors must use company-issued devices (MDM-D07).
Guest and other external users	Governed by enterprise access policies (MDM-D08).
Design of user MFA	An enterprise policy the design depends on, not part of it (MDM-D08).
Live tenant configuration and testing	No tenant was configured; evidence and results are simulated (Section 5).

5. Assumptions and Constraints

The assessment rests on the assumptions below. Each one must be confirmed before the design is applied to a real organization. Technical assumptions specific to Conditional Access are listed in MDM-D08 Section 5.

Assumptions

ID	Assumption	Effect on the assessment
AS-01	The organization, its staff numbers and its roles are fictional.	Results illustrate the method, not a real environment.
AS-02	As a financing company, the company is regulated by SAMA. SAMA CSF v1.0 is the primary regulatory reference.	Control requirements in MDM-D05 map to SAMA CSF first.
AS-03	NCA ECC 2:2024 is adopted as an additional baseline for this case study.	Mappings show which controls support a provision, not full compliance. MDM-D05 records each mapping limitation.
AS-04	Microsoft 365 licensing covers Intune MDM,	Licensing and platform prerequisites

ID	Assumption	Effect on the assessment
	App Protection and Entra ID Conditional Access.	must be validated before implementation (MDM-D07 Section 2).
AS-05	An enterprise user MFA policy exists and covers this scope.	MFA design is excluded; its existence is confirmed with the IAM owner (MDM-D08).
AS-06	The roles in MDM-D02 exist and are staffed: CISO, GRC Analyst, IT Operations Manager and IT Operations Team. The Business Owner acts as Risk Owner, and Internal Audit retests work the GRC Analyst prepared.	Accountability in every deliverable depends on these roles.
AS-07	Platform behavior follows vendor documentation as checked at the time of writing.	Vendor changes may alter requirements; MDM-D10 tests confirm key platform assumptions.

Constraints

ID	Constraint	How it is handled
CN-01	No Intune or Entra ID tenant was configured.	All evidence and results in MDM-D09 to MDM-D14 are simulated and labeled as such.
CN-02	Not every requirement can be tested in one cycle.	MDM-D10 uses a risk-based sample of 10 tests and lists untested requirements with the reason.
CN-03	The GRC Analyst must stay independent of the operations being tested.	Operations staff perform operational activities such as access reviews; GRC tests them. Under MDM-CTL-005, the IT Operations Manager reviews team permissions and the CISO reviews the manager's.
CN-04	The project is prepared by one person without real stakeholder interviews.	Stakeholder input, approvals and evidence submissions are simulated.
CN-05	Framework references and vendor documentation change over time.	Each source is cited with its version, as in MDM-D05 and MDM-D08.

6. Approach and Traceability Chain

The assessment runs in six phases. Each phase uses the output of the one before it.

1. **Define**: set the scenario, scope, roles, assets and data flows (MDM-D01 to MDM-D03).
2. **Assess risk**: rate each risk under one method and assign a risk owner (MDM-D04).
3. **Design controls**: define control requirements, map them to frameworks, and turn them into policy, standard and access design (MDM-D05 to MDM-D08).
4. **Evidence and test**: request evidence and test a risk-based sample of controls (MDM-D09, MDM-D10).
5. **Remediate**: record findings, gaps and recommendations, then treat and retest the risks (MDM-D11, MDM-D12).
6. **Report**: track readiness and give management a decision (MDM-D13, MDM-D14).

Traceability chain

Every item links to the item before it by ID. A reader can start from any asset and follow it to a management decision, or start from a decision and trace it back.

Link	What it records	ID format	Recorded in
Asset	A device group, service or information set in scope	MDM-AST-001	MDM-D03
Risk	What could go wrong, to which assets, and who owns it	MDM-RSK-001	MDM-D04
Control	The requirement that treats the risk, with its framework mapping	MDM-CTL-001	MDM-D05 (policy in MDM-D06, technical requirements in MDM-D07, access policies MDM-CAP-001 in MDM-D08)
Evidence	What must be produced to show the control works	MDM-EVD-001	MDM-D09
Test	How the control is tested and what counts as a pass	MDM-TST-001	MDM-D10
Finding and gap	Current state, required state, the gap and the resulting risk	MDM-FND-001	MDM-D11
Recommendation	Action, owner, due date and success measure	MDM-REC-001	MDM-D11, MDM-D12
Decision	What the Risk Owner or	D-01	MDM-D11 Section

Link	What it records	ID format	Recorded in
	management must decide or accept		6, MDM-D12 Section 3, MDM-D14 Section 6

Chain rules

- Each record cites the ID of the link above it. A record with no upstream link is flagged as a gap in traceability, not dropped.
- A control without a test is listed in MDM-D10 as untested, with the reason.
- Every simulated evidence item and test result is labeled as simulated.
- Deliverable IDs (MDM-D01 to MDM-D15) are fixed and never reused.

7. Deliverables Map

The case study has 15 deliverables. The last column shows which of the eight outputs of the original exercise each one covers; each of those eight can be read on its own.

ID	Deliverable	Phase	Purpose	Exercise output
MDM-D01	Project Foundation and Scenario Definition	Define	Scenario, objectives, scope, assumptions and method.	Scope (Section 4)
MDM-D02	Stakeholder and RACI Matrix	Define	Who is responsible and accountable for each assessment activity.	—
MDM-D03	MDM Data Flow and Asset Inventory	Define	In-scope assets and how corporate data moves between them.	Asset inventory
MDM-D04	Risk Assessment Methodology and Risk Register	Assess risk	Scoring method and the eight risks with owners.	Risk register
MDM-D05	Control Requirements and Framework Crosswalk	Design controls	Controls that treat each risk, mapped to SAMA CSF and NCA ECC.	Control matrix
MDM-D06	Mobile Device and BYOD Policy	Design controls	Rules and responsibilities for corporate and personal devices.	—
MDM-D07	MDM Security	Design	Verifiable technical	—

ID	Deliverable	Phase	Purpose	Exercise output
	Standard	controls	requirements per platform and model.	
MDM-D08	Conditional Access Control Design	Design controls	Access policies that enforce device and app requirements.	—
MDM-D09	Evidence Request List and Evidence Index	Evidence and test	What evidence each control needs and who provides it.	Evidence list
MDM-D10	Control Testing Workbook	Evidence and test	Test procedures, pass conditions and simulated results.	—
MDM-D11	Findings and Remediation Register	Remediate	Findings, gap analysis, recommendations and decisions required.	Gap analysis; Recommendations
MDM-D12	Risk Treatment and Retesting Record	Remediate	Residual risk, treatment decisions and retest plan.	Recommendations (follow-up)
MDM-D13	GRC Workspace and Readiness Dashboard	Report	Readiness measures, status and escalation.	—
MDM-D14	Executive Readiness Report	Report	The readiness position and the decision required from management.	Executive summary
MDM-D15	Portfolio Case Summary and LinkedIn Presentation	Portfolio	A short account of the case study and of what is my own work.	—

Stakeholder and RACI Matrix

MDM-D02

Stakeholders

The roles below appear across this case study. All are part of the fictional organization; their input and approvals are simulated (MDM-D01, constraint CN-04).

Role	Responsibility in this case study	Appears in
CISO	Accountable for the assessment and its conclusions. Gives cybersecurity approval for access policy changes, owns MDM-CTL-005 and reviews the IT Operations Manager's administrative access.	MDM-D05, MDM-D07, MDM-D08, MDM-D14
GRC Analyst	Prepares the risk assessment, control requirements, evidence requests, tests and findings, and maintains the policy. Does not operate the service or approve and review access.	MDM-D04 to MDM-D06, MDM-D09 to MDM-D14
IT Operations Manager	Owns most operational controls. Approves and reviews the team's administrative access and receives escalations.	MDM-D05, MDM-D07, MDM-D08
IT Operations Team	Operates Intune and the mobile service: policies, offboarding, wipes and reports. Supplies technical evidence.	MDM-D07 to MDM-D09
Business Owner	Risk Owner for the mobile service risks. Approves access policy changes, risk treatment and residual risk acceptance.	MDM-D04, MDM-D05, MDM-D12
Enterprise IAM Team	Administers Conditional Access and emergency access accounts, and owns user MFA.	MDM-D08
Change Advisory Board (CAB)	Authorizes access policy changes before deployment.	MDM-D05, MDM-D06
Contractor Sponsor and Responsible Business Manager	The sponsor tracks each contractor's authorization, reports early departures and coordinates device return. The Responsible Business Manager approves extensions.	MDM-D06, MDM-D07
Line Manager	Approves an employee's request to join BYOD.	MDM-D06, MDM-D07

Role	Responsibility in this case study	Appears in
Internal Audit	Retests items the GRC Analyst prepared, so GRC never verifies its own work.	MDM-D12, MDM-D14
Employees and Contractors	Follow the policy, acknowledge the BYOD notice and report lost devices and incidents.	MDM-D06, MDM-D07

Assessment RACI

Activity	CISO	GRC Analyst	IT Operations Manager	IT Operations Team	Business Owner
Define the assessment scope, risks and control requirements.	A	R	C	C	C
Request and review supporting evidence.	A	R	I	C	I
Extract and submit the requested technical evidence.	I	C	A	R	I
Test controls and document findings.	A	R	I	C	I
Plan and implement technical remediation.	I	C	A	R	C
Approve risk treatment and accept residual risk.	C	R	C	I	A
Retest controls and report readiness conclusions.	A	R	C	C	I

R = Responsible | A = Accountable | C = Consulted | I = Informed

MDM Data Flow and Asset Inventory

MDM-D03

Asset Inventory

Asset ID	Asset / Asset Group	Asset Type	Purpose	Asset Owner	Classification
MDM-AST-001	Company-owned Android devices	Device Group	Enable employees to access approved work applications and corporate information.	IT Operations Manager	Confidential
MDM-AST-002	Microsoft Intune	Cloud Service	Manage corporate mobile devices and protect work applications and data.	IT Operations Manager	Confidential
MDM-AST-003	Corporate documents accessed on mobile devices	Information	Provide employees with the business information needed to perform their work and collaborate while away from their desks.	Business Owner	Confidential
MDM-AST-004	Company-owned iOS/iPadOS devices	Device Group	Enable employees and authorized external personnel to access approved work applications and corporate information.	IT Operations Manager	Confidential
MDM-AST-005	Personal Android devices used for work	Device Group	Enable eligible employees to access approved work applications from their personal devices.	Employee (device); IT Operations Manager (corporate data in approved apps)	Confidential (corporate data in approved apps only)
MDM-AST-	Personal iOS/iPadOS	Device	Enable eligible employees to access	Employee (device); IT	Confidential (corporate

Asset ID	Asset / Asset Group	Asset Type	Purpose	Asset Owner	Classification
006	devices used for work	Group	approved work applications from their personal devices.	Operations Manager (corporate data in approved apps)	data in approved apps only)
MDM-AST-007	Microsoft Entra ID	Cloud Service	Authenticate users and enforce access policies for corporate applications and services.	Enterprise IAM Team	Confidential
MDM-AST-008	Microsoft 365 applications and services	Application / Cloud Service Group	Provide corporate email, meetings, collaboration and access to work documents.	IT Operations Manager (mobile access); Business Owner (information)	Confidential
MDM-AST-009	Employee device management reports	Information	Support device compliance monitoring and operational follow-up.	IT Operations Manager	Confidential (contains employee personal data)

Asset owners and classifications are project-defined. The case study uses two levels, Confidential and Internal. Every in-scope asset is Confidential because it holds, processes or protects confidential corporate information or employee personal data. For personal devices, the employee owns the device; the company's ownership and classification cover only corporate data inside approved apps.

MDM Data Flow Summary

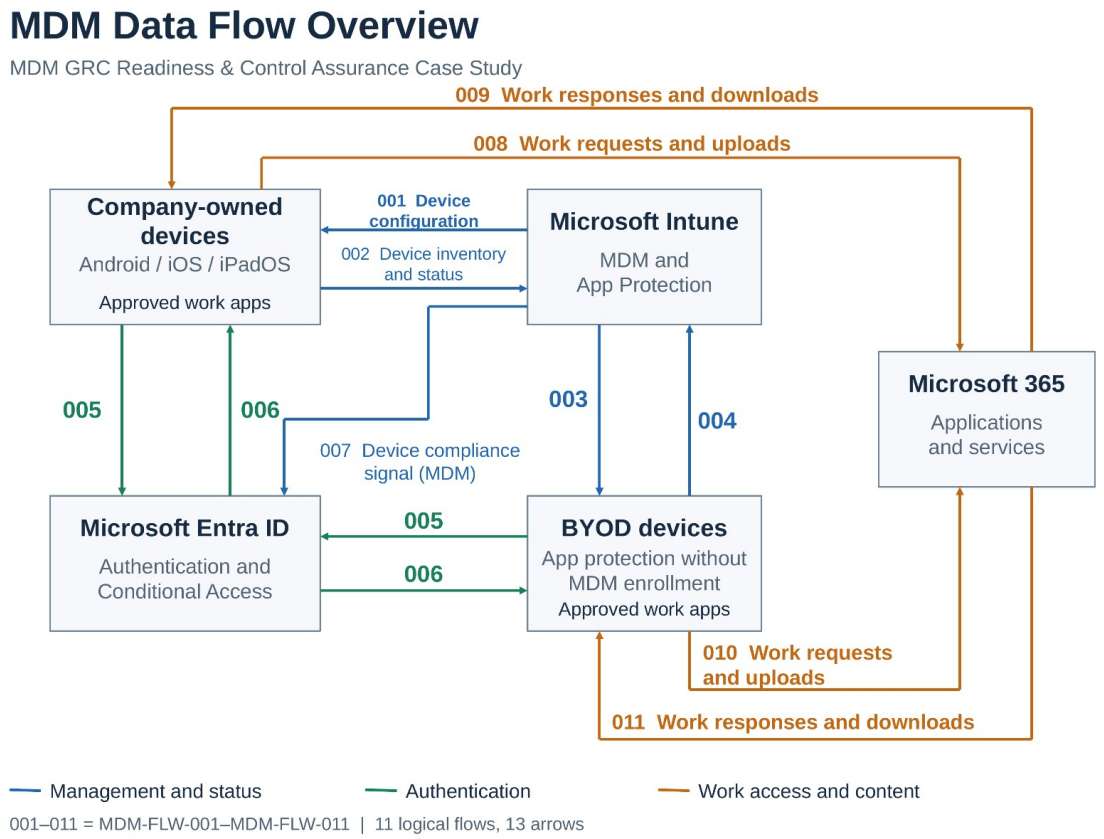
Flow ID	Source	Destination	Data exchanged
MDM-FLW-001	Microsoft Intune	Company-owned Android and iOS/iPadOS devices	Device configuration profiles and device restriction settings.
MDM-FLW-002	Company-owned Android	Microsoft	Device inventory, device compliance status, and configuration deployment

Flow ID	Source	Destination	Data exchanged
	and iOS/iPadOS devices	Intune	status.
MDM-FLW-003	Microsoft Intune	Approved work apps on BYOD devices	App protection policies governing access to and handling of corporate data.
MDM-FLW-004	Approved work apps on BYOD devices	Microsoft Intune	App protection status, app check-in information, and associated user, app, and device metadata.
MDM-FLW-005	Approved work apps on company-owned and BYOD devices	Microsoft Entra ID	Sign-in and token requests, with relevant user, app, and device context.
MDM-FLW-006	Microsoft Entra ID	Approved work apps on company-owned and BYOD devices	Authentication responses and access tokens when access requirements are satisfied.
MDM-FLW-007	Microsoft Intune	Microsoft Entra ID	Enrolled device compliance status used in Conditional Access evaluation.
MDM-FLW-008	Approved work apps on company-owned devices	Microsoft 365 applications and services	Access tokens, service requests, outgoing email, meeting communications, and document uploads or edits.
MDM-FLW-009	Microsoft 365 applications and services	Approved work apps on company-owned devices	Service responses, incoming email, meeting communications, and document downloads or updates.
MDM-FLW-010	Approved work apps on BYOD devices	Microsoft 365 applications and services	Access tokens, service requests, outgoing email, meeting communications, and document uploads or edits.
MDM-FLW-011	Microsoft 365 applications	Approved work apps on BYOD	Service responses, incoming email, meeting communications, and

Flow ID	Source	Destination	Data exchanged
	and services	devices	document downloads or updates.

Conceptual flows for the proposed architecture. Enrollment exchanges, authentication broker interactions, and protocol-level details are not shown. BYOD uses app protection without MDM enrollment.

MDM Data Flow Overview



Risk Assessment Methodology and Risk Register

MDM-D04

Impact Criteria

Score	Impact level	Description
1	Insignificant	Brief individual disruption with a workaround; no sensitive data exposure or material business harm.
2	Minor	Limited disruption or easily corrected changes to low-sensitivity information; minor business harm.
3	Moderate	Team-level disruption, confidential data exposure, or record changes causing meaningful but contained harm.
4	Major	Significant disruption to important activities or serious harm from sensitive data exposure or unauthorized record changes.
5	Severe	Critical activities prevented, extensive highly sensitive data exposure, or critical record corruption causing severe harm.

Use the highest applicable confidentiality, integrity, or availability impact score and document the rationale.

Likelihood Criteria

Score	Likelihood Level	Description
1	Rare	Requires exceptional circumstances; exposure and opportunities are very limited.
2	Unlikely	Plausible but not expected; exposure is limited and several conditions must coincide.
3	Possible	Could occur under realistic conditions; exposure and an opportunity exist.
4	Likely	Expected under common conditions; exposure is frequent and barriers are limited.
5	Almost Certain	Expected repeatedly or imminently; exposure is persistent and barriers are minimal.

Assess likelihood over the next 12 months and document the rationale. Credit existing controls only where their effectiveness is supported by evidence.

Risk Scoring and Classification

Risk Score = Likelihood × Impact

Risk Score	Risk Level
1–4	Low
5–9	Medium
10–16	High
17–25	Critical

Any risk with an Impact score of 5 requires management review regardless of its overall score. The calculated risk level remains unchanged. A Low rating does not imply automatic risk acceptance.

These scoring thresholds are defined for this case study and are not regulatory requirements.

Risk Assessment Basis

Assessment Type	Assessment Basis
Inherent Risk	Risk assessed without crediting controls that address the scenario.
Current Residual Risk	Risk remaining after considering existing controls whose effectiveness is supported by evidence. Mark as “Not assessed” until reviewed.
Target Residual Risk	Expected risk after planned treatment, assuming controls operate effectively. Subject to validation through testing.

Document the likelihood, impact, score, and rationale for each assessment. Planned controls do not justify reducing current residual risk. Update the current assessment after testing or retesting, retaining previous results for traceability.

Risk Ownership

Each risk is assigned a Risk Owner: the role accountable for the business consequences of the risk and authorized to decide its treatment. The Risk Owner approves the treatment approach and target residual risk, and receives testing results affecting the risk. Control owners in MDM-D05 are accountable for control design and operation and may differ from the Risk Owner. Risk acceptance follows the corporate risk acceptance process. Risk Owner assignments in this case study are project-defined.

Risk Register

The register holds eight risks. The table summarizes them; a detailed record for each risk follows. Residual ratings come from MDM-D12 Section 4.

Risk ID	Risk Title	Risk Owner	Inherent Risk	Current Residual	Target Residual
MDM-RSK-001	Unauthorized Access to Data on a Lost Corporate Device	Business Owner	Medium (9)	Medium (6)	Low (3)
MDM-RSK-002	Corporate Data Leakage to Personal Apps or Accounts	Business Owner	High (12)	Medium (9), provisional	Medium (8)
MDM-RSK-003	Corporate Data Exposure Through Non-Compliant Devices	Business Owner	Medium (9)	Medium (6)	Medium (6) until D-01 is decided
MDM-RSK-004	Business Disruption Due to Incorrect Access Policy Changes	Business Owner	Medium (6)	Not assessed	-
MDM-RSK-005	Unauthorized Changes to Centralized Device Security Settings	CISO	High (12)	Medium (6)	Low (3)
MDM-RSK-006	Inappropriate Internal Access to Employee Device Reports	CISO	Medium (6)	Not assessed	-
MDM-RSK-007	Continued Corporate Access After Contractor Departure	Business Owner	Medium (9)	Medium (6)	Low (3)
MDM-RSK-008	Inaccurate Device Compliance Reporting	CISO	Medium (6)	Not assessed	-

"Not assessed" means the related controls were outside the test sample in MDM-D10.

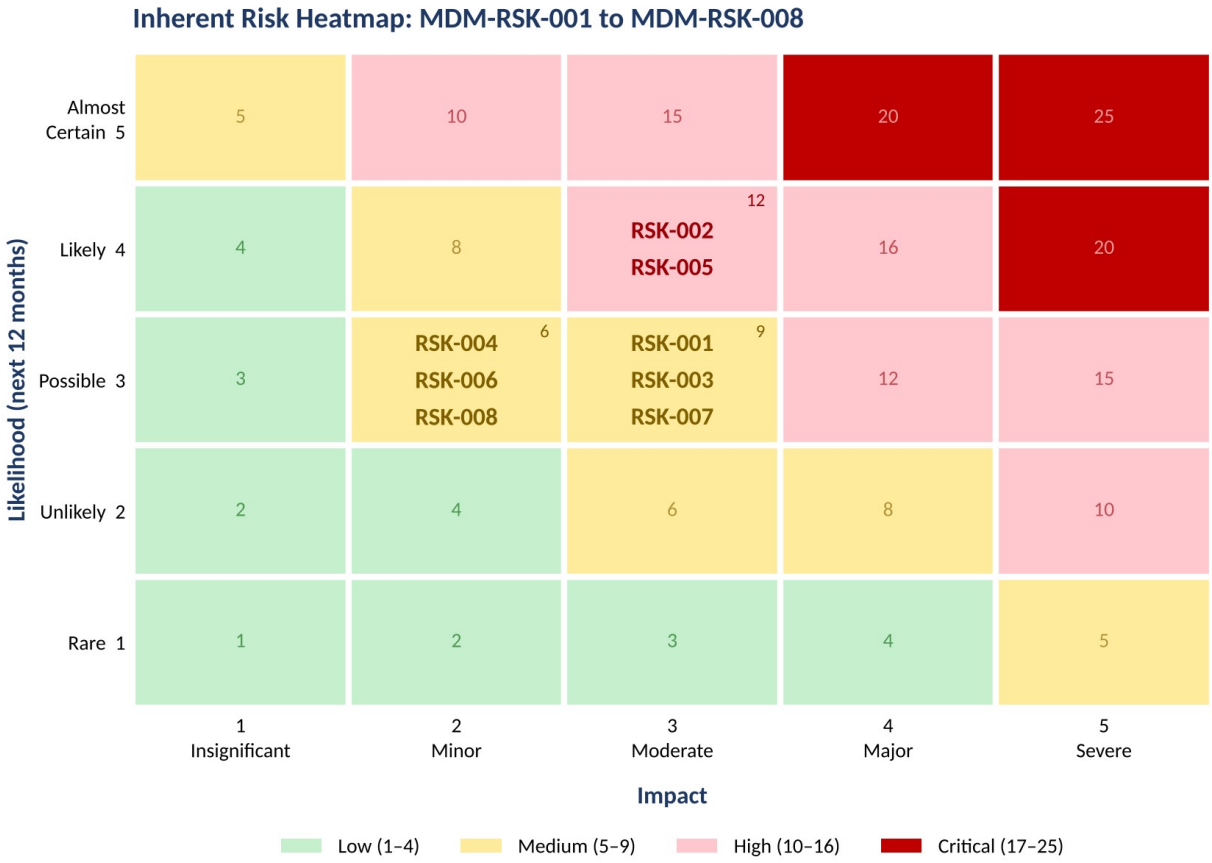


Figure 1. Inherent risk heatmap. Positions use the likelihood and impact scores in each risk record below.

Risk ID

MDM-RSK-001

Field	Details
Risk Title	Unauthorized Access to Data on a Lost Corporate Device
Risk Statement	If a company-owned mobile device is lost or stolen, an absent or weak device passcode may allow an unauthorized person to access corporate information, resulting in a confidentiality breach and potential financial or reputational harm.
Related Assets	MDM-AST-001; MDM-AST-004; MDM-AST-003
Risk Owner	Business Owner
Primary CIA Impact	Confidentiality
Scenario Assumption	A corporate device is routinely used off-site and contains or can access a limited set of confidential internal work

Field	Details
	documents.
Inherent Impact	3 - Moderate
Impact Rationale	Exposure of a limited set of confidential internal work documents could cause meaningful but contained business harm.
Inherent Likelihood	3 - Possible
Likelihood Rationale	Routine off-site use creates opportunities for device loss or theft, while weak or absent passcode protection makes subsequent unauthorized access plausible within 12 months.
Inherent Risk Score	9
Inherent Risk Level	**Medium**
Current Residual Risk	Medium (6). MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Low (3). MDM-D12 Section 4, 16 November 2026.**

Risk ID

MDM-RSK-002

Field	Details
Risk Title	Corporate Data Leakage to Personal Apps or Accounts
Risk Statement	Missing or misconfigured data transfer restrictions may allow employees to copy or save confidential work documents to personal apps or accounts on BYOD devices, resulting in loss of organizational control over the documents and potential unauthorized disclosure.
Related Assets	MDM-AST-005; MDM-AST-006; MDM-AST-003; MDM-AST-002
Risk Owner	Business Owner
Primary CIA Impact	Confidentiality
Scenario Assumption	Employees frequently handle confidential work documents on BYOD devices, where personal apps and storage accounts are readily available.

Field	Details
Inherent Impact	3 - Moderate
Impact Rationale	Exposure of a limited set of confidential internal work documents could cause meaningful but contained business harm.
Inherent Likelihood	4 - Likely
Likelihood Rationale	Frequent document handling and readily available personal storage make transfers outside approved apps likely within 12 months when transfer restrictions are ineffective.
Inherent Risk Score	12
Inherent Risk Level	**High**
Current Residual Risk	Medium (9), provisional. MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	Medium (8). MDM-D12 Section 4, 16 November 2026.

Risk ID

MDM-RSK-003

Field	Details
Risk Title	Corporate Data Exposure Through Non-Compliant Devices
Risk Statement	Missing or misconfigured access restrictions may allow non-compliant devices to access corporate services, potentially exposing confidential work documents to unauthorized parties if a device is compromised.
Related Assets	MDM-AST-001; MDM-AST-004; MDM-AST-003; MDM-AST-002; MDM-AST-007; MDM-AST-008
Risk Owner	Business Owner
Primary CIA Impact	Confidentiality
Scenario Assumption	A corporate device with an outdated OS and an exploitable vulnerability can access confidential work documents through Microsoft 365 despite failing security requirements.
Inherent Impact	3 - Moderate

Field	Details
Impact Rationale	Exposure of a limited set of confidential internal work documents could cause meaningful but contained business harm.
Inherent Likelihood	3 - Possible
Likelihood Rationale	An exploitable OS vulnerability combined with continued access to corporate services makes device compromise and subsequent document exposure plausible within 12 months.
Inherent Risk Score	9
Inherent Risk Level	**Medium**
Current Residual Risk	Medium (6). MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	Medium (6) until D-01 is decided. MDM-D12 Section 4, 16 November 2026.

Risk ID

MDM-RSK-004

Field	Details
Risk Title	Business Disruption Due to Incorrect Access Policy Changes
Risk Statement	Inadequate testing of access policy changes before deployment may block authorized employees from accessing corporate services, disrupting business tasks that depend on email and work documents.
Related Assets	MDM-AST-001; MDM-AST-004; MDM-AST-005; MDM-AST-006; MDM-AST-007; MDM-AST-008
Risk Owner	Business Owner
Primary CIA Impact	Availability
Scenario Assumption	An incorrect access policy blocks one team's mobile access to Microsoft 365 for several hours. Corporate computers remain available for most tasks.
Inherent Impact	2 - Minor
Impact Rationale	Corporate computers provide an alternative way to continue most tasks, limiting the disruption to minor delays in one

Field	Details
	team's work.
Inherent Likelihood	3 - Possible
Likelihood Rationale	Inadequate testing creates a plausible opportunity for an access policy error to reach deployment and block legitimate mobile access within 12 months.
Inherent Risk Score	6
Inherent Risk Level	**Medium**
Current Residual Risk	Not assessed; controls not tested. MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Not set until tested. MDM-D12 Section 4.**

Risk ID

MDM-RSK-005

Field	Details
Risk Title	Unauthorized Changes to Centralized Device Security Settings
Risk Statement	Excessive administrative privileges may allow users to make unauthorized changes to Intune security settings, weakening protection across affected corporate devices.
Related Assets	MDM-AST-002; MDM-AST-001; MDM-AST-004
Risk Owner	CISO
Primary CIA Impact	Integrity
Scenario Assumption	Several staff members with excessive administrative privileges modify configurations daily without independent review. A change disables passcode enforcement across most corporate devices; existing passcodes are not removed.
Inherent Impact	3 - Moderate
Impact Rationale	Unauthorized removal of passcode enforcement compromises the approved security configuration across corporate devices and requires coordinated restoration and verification. The scenario assumes meaningful but contained

Field	Details
	operational harm.
Inherent Likelihood	4 - Likely
Likelihood Rationale	Daily changes by multiple staff with excessive privileges and no independent review make unauthorized configuration changes likely within 12 months.
Inherent Risk Score	12
Inherent Risk Level	**High**
Current Residual Risk	Medium (6). MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Low (3). MDM-D12 Section 4, 16 November 2026.**

Risk ID

MDM-RSK-006

Field	Details
Risk Title	Inappropriate Internal Access to Employee Device Reports
Risk Statement	Overly broad access permissions on a shared folder may allow employees without a business need to view colleagues' personal data in device management reports, compromising data confidentiality and employee privacy.
Related Assets	MDM-AST-009; MDM-AST-002
Risk Owner	CISO
Primary CIA Impact	Confidentiality
Scenario Assumption	An internally shared report contains only employee names, work email addresses, device models and compliance statuses, and is accessible to staff without a business need.
Inherent Impact	2 - Minor
Impact Rationale	Internal exposure of limited employee identifiers and device details is expected to cause minor privacy harm.
Inherent Likelihood	3 - Possible
Likelihood Rationale	Broad folder permissions make unauthorized internal

Field	Details
	viewing plausible within 12 months, although frequent browsing or direct distribution is not assumed.
Inherent Risk Score	6
Inherent Risk Level	**Medium**
Current Residual Risk	Not assessed; controls not tested. MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Not set until tested. MDM-D12 Section 4.**

Risk ID

MDM-RSK-007

Field	Details
Risk Title	Continued Corporate Access After Contractor Departure
Risk Statement	Delayed notification of a contractor's departure to IT may leave access active after the contract ends, allowing unauthorized viewing or disclosure of corporate information and, where editing permissions remain, unauthorized modification of documents.
Related Assets	MDM-AST-001; MDM-AST-004; MDM-AST-003; MDM-AST-007; MDM-AST-008
Risk Owner	Business Owner
Primary CIA Impact	Confidentiality
Scenario Assumption	A former contractor retains access from a company-issued device for several days after departure, including access to confidential routine team documents and permission to edit some of them.
Inherent Impact	3 - Moderate
Impact Rationale	Unauthorized disclosure or modification of confidential team documents could cause meaningful but contained harm, including rework and limited delays.
Inherent Likelihood	3 - Possible
Likelihood Rationale	Access remaining active for several days after departure

Field	Details
	gives a former contractor an opportunity to view, disclose or modify corporate documents without authorization within the assessment period.
Inherent Risk Score	9
Inherent Risk Level	**Medium**
Current Residual Risk	Medium (6). MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Low (3). MDM-D12 Section 4, 16 November 2026.**

Risk ID

MDM-RSK-008

Field	Details
Risk Title	Inaccurate Device Compliance Reporting
Risk Statement	Errors in manually matching device records may assign compliance statuses to the wrong devices, resulting in inaccurate reporting, misdirected follow-up and delays in corrective action.
Related Assets	MDM-AST-009
Risk Owner	CISO
Primary CIA Impact	Integrity
Scenario Assumption	A manually compiled device compliance report is used by one team for routine operational follow-up.
Inherent Impact	2 - Minor
Impact Rationale	Incorrect device compliance information causes misdirected follow-up, limited operational delays and rework to correct the report.
Inherent Likelihood	3 - Possible
Likelihood Rationale	Manual matching of device records creates a plausible opportunity for errors that affect operational follow-up within the 12-month assessment period.
Inherent Risk Score	6

Field	Details
Inherent Risk Level	**Medium**
Current Residual Risk	Not assessed; controls not tested. MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Not set until tested. MDM-D12 Section 4.**

Control Requirements and Framework Crosswalk

MDM-D05

Control Register

Control ID

MDM-CTL-001

Field	Details
Control Title	Device Passcode and Automatic Lock
Related Risk	MDM-RSK-001
Control Objective	Prevent unauthorized access to corporate mobile devices when lost, stolen or left unattended.
Control Statement	All in-scope company-owned mobile devices must require a passcode meeting the approved strength requirements. Devices must automatically lock after a defined period of inactivity and require authentication to unlock.
Control Function	Preventive
Control Nature	Technical
Design Status	Defined — pending platform-specific configuration mapping and validation.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Minimum Passcode Length	At least 6 digits for a PIN, or 6 characters for a password.
Passcode Complexity	Simple passcodes must be blocked, including repeated or sequential PINs.
Automatic Lock Timeout	No more than 5 minutes of inactivity.
Authentication After Lock	Authentication must be required immediately to unlock, with no grace period.
Supporting Reference	SAMA CSF 3.3.8, control considerations 5 and 6(a). Specific configuration values are defined for this project.

Control ID

MDM-CTL-002

Field	Details
Control Title	Corporate Data Transfer Protection on BYOD
Related Risk	MDM-RSK-002
Control Objective	Prevent corporate data leakage to personal or unapproved destinations when using BYOD devices.
Control Statement	In-scope work applications on BYOD devices must enforce restrictions that prevent corporate data from being saved, shared, or copied and pasted to personal apps, accounts, storage locations, or other unapproved destinations. Transfers between approved corporate destinations may be permitted only where the required data protection remains enforced.
Control Function	Preventive
Control Nature	Technical
Design Status	Defined - pending platform-specific configuration mapping and validation.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Corporate Data Storage	Corporate data must be saved only to approved corporate storage locations where the required protection remains enforced. Saving copies to personal accounts or unprotected local storage must be blocked.
App-to-App Data Sharing	Sharing or opening corporate data in another app must be restricted to approved work apps using corporate accounts, with the required data protection maintained. Transfers to personal accounts or unapproved apps must be blocked.
Copy and Paste Restrictions	Copying and pasting corporate data must be restricted to approved work apps and corporate accounts where the required protection remains enforced. Pasting corporate data into personal or unapproved

Field	Details
	destinations must be blocked.
Supporting Reference	SAMA CSF 3.3.10, control considerations 4(c) and 4(d), supporting business/personal information separation and mobile application governance. Specific data transfer restrictions are defined for this project.

Control ID

MDM-CTL-003

Field	Details
Control Title	Compliance-Based Access for Corporate Mobile Devices
Related Risk	MDM-RSK-003
Control Objective	Prevent non-compliant corporate mobile devices from accessing in-scope corporate services and exposing corporate data.
Control Statement	Access to in-scope Microsoft 365 services from company-owned mobile devices must require a compliant device status based on defined security requirements. Non-compliant devices must be denied access. Access may be restored only after remediation and reassessment confirm compliance, subject to other applicable access requirements.
Control Function	Preventive
Control Nature	Technical
Design Status	Defined - pending platform-specific configuration mapping and validation.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Compliance Assessment Requirements	In-scope company-owned Android and iOS/iPadOS devices must be assigned applicable compliance policies that assess the approved security baseline, including minimum OS version

Field	Details
	and applicable security update requirements. Platform-specific criteria will be defined in MDM-D07.
Access Enforcement	Conditional Access must require devices to be marked as compliant before granting access to in-scope Microsoft 365 services. Device enrollment alone must not satisfy this requirement.
Unverified Compliance Status	Devices without an assigned compliance policy, or without a valid compliant status, must not satisfy the device compliance requirement for access.
Access Restoration	Access may be restored only after the cause of non-compliance is remediated and reassessment confirms a compliant status, subject to all other applicable access requirements.
Supporting Reference	SAMA CSF 3.3.8, control considerations 1, 2 and 5, supports defining and monitoring infrastructure security standards covering mobile devices. Microsoft Learn: “Device compliance policies in Microsoft Intune” and “How to Require Device Compliance with Conditional Access” support the technical design. The compliance-based access requirement is defined for this project.

Control ID

MDM-CTL-004

Field	Details
Control Title	Access Policy Change Management
Related Risk	MDM-RSK-004
Control Objective	Prevent unintended disruption to authorized mobile access caused by access policy changes and enable controlled recovery if disruption occurs.

Field	Details
Control Statement	Changes to in-scope mobile access policies must undergo documented impact assessment, testing and required approvals before deployment. A rollback plan must be prepared before implementation. Post-implementation verification must confirm that authorized access remains available and required access restrictions remain effective. If the change fails the defined acceptance criteria, recovery must follow the approved rollback procedure.
Control Function	Preventive and Corrective
Control Nature	Administrative
Design Status	Defined - pending validation of change workflow, approval routing and rollback arrangements.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Business Approval	Business Owner
Cybersecurity Approval	CISO
Change Authorization	Change Advisory Board (CAB)
Change Impact Assessment	Each change must document its purpose, affected policies, users, device groups and services, expected access outcomes, and potential security and availability impacts.
Pre-Implementation Testing	Changes must be tested before deployment using representative access scenarios. Testing must confirm that authorized access is allowed and prohibited access remains blocked. Results and acceptance criteria must be documented.
Change Approvals	Business Owner approval and CISO cybersecurity approval must be obtained before submission to CAB. CAB authorization must be recorded before deployment. These approvals are dependencies on the corporate change management process.

Field	Details
Deployment and Communication	Affected teams must be informed of the planned change, implementation window and support arrangements. Deployment must begin with a limited scope where feasible, with results checked before broader rollout.
Rollback Preparation	Before deployment, the previous approved configuration must be retained and rollback steps, activation criteria, the responsible operator and the rollback decision authority must be documented.
Post-Implementation Verification	After deployment, IT Operations must verify that authorized access remains available and required access restrictions remain effective. Results must be recorded. Changes that fail acceptance criteria must follow the approved rollback procedure, with recovery verified.
Supporting Reference	SAMA CSF 3.3.7, control considerations 4(a)–4(f) and 4(i), supports impact assessment, security testing, approvals, post-implementation review, and fallback and rollback procedures. CISO approval responsibility and deployment details are defined for this project.

Control ID

MDM-CTL-005

Field	Details
Control Title	Intune Administrative Access Management
Related Risk	MDM-RSK-005
Control Objective	Reduce the risk of unauthorized changes to centralized device security settings by restricting administrative access to approved responsibilities and reviewing continued access needs.
Control Statement	Administrative access to Microsoft Intune must be formally approved and restricted to the permissions and management scope required for assigned responsibilities. Access must be attributable to individual administrators and

Field	Details
	independently reviewed at least every three months and upon role changes. Unnecessary or inappropriate access must be removed or adjusted promptly, and access must be revoked as part of the departure process.
Control Function	Preventive and Detective
Control Nature	Administrative and Technical
Design Status	Defined - pending validation of administrative role mappings, scope restrictions and access review arrangements.
Control Owner	CISO
Control Operator	IT Operations Manager / IT Operations Team
Access Authorization	Requests for Intune administrative access must document the business need, required permissions and management scope. The IT Operations Manager must approve team members' requests; requests for the manager's own access must be approved by the CISO. No individual may approve their own access.
Least Privilege and Scope	Administrative permissions must be limited to approved responsibilities and the devices or groups each administrator is authorized to manage. Broad administrative access must require documented justification and CISO approval. Platform-specific role and scope mappings must be validated before implementation.
Individual Accountability	Administrative access must use individually assigned accounts so that actions can be attributed to a specific administrator. Shared administrative accounts must not be used for routine administration.
Periodic and Event-Driven Reviews	Administrative access must be reviewed at least every three months and upon role changes or changes in business need. The IT Operations Manager must review team members' access; the

Field	Details
	CISO must review the manager's access. No individual may review their own access.
Access Adjustment and Revocation	Unnecessary or inappropriate permissions identified during reviews must be removed or adjusted promptly. Administrative access must be revoked as part of the departure process without waiting for the next periodic review. Review findings must remain open until the required changes are verified.
Review and Approval Records	Records must identify the administrator, assigned permissions and scope, business justification, approver, reviewer, review date and decision. Required access changes and evidence of their completion must be retained.
Supporting Reference	SAMA CSF 3.3.5, control considerations 4(a), 4(b)(4)–4(b)(7), and 4(f)(1)–4(f)(3), support business-based access restrictions, formal approvals, timely access changes, periodic reviews, audit trails and individual accountability. The quarterly review frequency, approval and review assignments, and restriction on routine shared administrative accounts are project-defined requirements.

Control ID

MDM-CTL-006

Field	Details
Control Title	Employee Device Report Access Control
Related Risk	MDM-RSK-006
Control Objective	Prevent inappropriate internal access to employee device reports by restricting access to authorized individuals with a documented business need.
Control Statement	Employee device reports must be stored in an approved repository with access restricted according to assigned tasks and business need. Read, update and access-management

Field	Details
	permissions must be separately controlled. Broad internal sharing must be prohibited, and access must be reviewed periodically and adjusted when responsibilities or business needs change.
Control Function	Preventive and Detective
Control Nature	Administrative and Technical
Design Status	Defined - pending validation of repository permissions, sharing restrictions and access review arrangements.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Approved Storage and Sharing	Employee device reports must be stored in an approved repository. Folder permissions, file permissions and sharing links must restrict access to authorized recipients. Organization-wide links and broadly accessible internal folders must not be used to distribute these reports.
Access Approval and Permission Levels	Access requests must document the required task and permission level. The IT Operations Manager must approve access; requests for the manager's own access must be approved by the CISO. Read access must be used where sufficient. Update and access-management permissions must be separately justified and restricted to designated personnel.
Access Reviews	The IT Operations Manager must review authorized users, permission levels and sharing links at least every three months and when responsibilities or business needs change. The CISO must review the manager's own access, where applicable. No individual may approve or review their own access.
Access Removal and Adjustment	Unnecessary or excessive access must be

Field	Details
	removed or reduced promptly. Access must be revoked as part of the departure process without waiting for the next periodic review. Inappropriate sharing links must be disabled, and completion of required changes must be verified.
Access and Review Records	Records must identify approved users, business justification, permission levels, approvals and review decisions. Evidence must include relevant repository permissions and sharing settings, identified access issues and verification of completed corrections.
Supporting Reference	SAMA CSF 3.3.5, control considerations 4(a) and 4(b)(4)–4(b)(7), support business-based access, formal approvals, timely access changes, periodic reviews and access-request audit trails. Repository and sharing restrictions, permission levels, reviewer assignments and the quarterly review frequency are project-defined requirements.

Control ID

MDM-CTL-007

Field	Details
Control Title	Contractor Offboarding and Access Revocation
Related Risk	MDM-RSK-007
Control Objective	Prevent continued access to corporate resources after contractor departure through timely notification, access revocation and verification.
Control Statement	Each contractor must have a designated internal sponsor and a recorded authorization end date and time. Automated reminders must be sent to the sponsor one month before expiry and weekly thereafter until expiry. Corporate access must be revoked when authorization ends unless an extension is formally approved beforehand. Early departures must trigger urgent notification and

Field	Details
	access revocation at the revised end time. Completion must include verification that access is blocked and documented follow-up on company device recovery and corporate data handling.
Control Function	Preventive and Detective
Control Nature	Administrative and Technical
Design Status	Defined - pending validation of departure notifications, automated reminders, access revocation mechanisms and verification procedures.
Control Owner	IT Operations Manager
Control Operator	Designated Internal Sponsor / IT Operations Team
Contractor Records and Notifications	Each contractor's record must identify the designated internal sponsor, corporate accounts, assigned company devices and authorization end date and time. The sponsor must keep departure details current and immediately notify IT Operations of early departures or changes to the agreed end time.
Automated Reminders and Extensions	IT Operations must configure automated reminders to the sponsor one month before expiry and weekly thereafter until expiry. Extensions must be formally approved by the responsible business manager and recorded before the existing authorization expires. Missing responses or pending extension requests must not delay access revocation.
Access Revocation	IT Operations must disable relevant corporate accounts and remove access to in-scope applications, groups and shared resources when authorization ends. Existing sessions and tokens must be revoked using supported platform mechanisms. Platform-specific steps and timing limitations must be documented and validated

Field	Details
	before implementation.
Verification and Escalation	IT Operations must retain evidence of account disablement, session revocation actions and checks confirming that access to in-scope services is blocked. Account status alone must not be treated as sufficient evidence. Failed or incomplete actions must be immediately escalated to the IT Operations Manager and remain open until effective access removal is verified.
Device Recovery and Corporate Data	The sponsor must coordinate the return of assigned company devices, and IT Operations must record their receipt and handle corporate data according to approved retention and secure removal procedures. Unreturned devices must be escalated for protective action. Access revocation must not wait for device recovery, and a remote removal command must not be treated as completed without confirmation.
Offboarding Records	Records must include the contractor and sponsor identities, authorized end time, notifications, reminders, approved extensions where applicable, affected accounts and devices, revocation timestamps, verification results and outstanding issues. Access removal and device recovery must be tracked separately, with unresolved actions assigned an owner and target completion date.
Supporting Reference	SAMA CSF 3.3.5, control considerations 4(b)(1), 4(b)(3)–4(b)(5), 4(b)(7) and 4(c), support third-party access lifecycle management, initiation by an appointed accountable party, formal approvals, timely access changes, audit trails and automation. The reminder schedule, expiry-based revocation timing, verification steps and device-handling workflow are project-defined requirements.

Control ID

MDM-CTL-008

Field	Details
Control Title	Device Compliance Report Accuracy Verification
Related Risk	MDM-RSK-008
Control Objective	Ensure that device compliance statuses are attributed to the correct devices in reports used for operational follow-up.
Control Statement	Manually compiled device compliance reports must preserve the association between each device identifier and its compliance status. Before reports are released for operational use, device-to-status mappings must be verified against the source records, and any identified mismatches must be corrected.
Control Function	Preventive and Detective
Control Nature	Administrative
Design Status	Defined - pending validation of source report fields, device identification and report review procedures.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Source Records and Device Matching	Each report must use an identified source of device compliance records. During compilation, each device identifier must remain associated with its corresponding compliance status. Matching must use an identifier that uniquely distinguishes the device record in the source; employee names or email addresses alone must not be used. The source report and extraction date and time must be recorded.
Independent Report Review	Before each manually compiled device compliance report is released for operational use, an IT Operations team member other than the preparer must verify device-to-status mappings against the source records. Identified mismatches

Field	Details
	must be corrected and rechecked before release.
Review and Correction Records	Review records must identify the report version, preparer, reviewer, review date and outcome. Any mismatches must be documented together with their corrections and the reviewer's confirmation that the corrected mappings agree with the source records. The source records used for verification and evidence of the completed review must be retained.
Supporting Reference	SAMA CSF Section 1.2 provides the information integrity objective. Section 3.2.1.3, control considerations 6(a)–6(c), supports identifying, evaluating and selecting risk-appropriate controls. Device matching, independent pre-release review and correction records are project-defined requirements.

Outstanding Design and Validation Items

The items left open when these controls were designed were carried forward: technical requirements into MDM-D07, access design into MDM-D08, and evidence, testing and findings into MDM-D09 to MDM-D11. Their current status is tracked in MDM-D11. One dependency sits outside this project and remains open here:

Related Control	Outstanding Item	Tracked In	Status
N/A - Enterprise dependency	MFA for user sign-in to mobile services is provided by an enterprise IAM control, not by this project. That control and its owner must be identified, and its coverage of in-scope users, approved apps, corporate devices and BYOD confirmed.	MDM-D08 Section 4.5 and assumption A-06	Open

Framework Crosswalk

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
MDM-CTL-001	SAMA CSF v1.0	3.3.8 Infrastructure Security, considerations	Supports including mobile devices within infrastructure	General supporting mapping. The cited provisions do not explicitly prescribe

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
		5 and 6(a)	security standards and defining security configuration and access controls. Device passcode and automatic lock requirements address this aspect of mobile device protection.	passcode or automatic lock requirements. The six-digit PIN or six-character password minimum, repeated/sequential PIN restrictions, five-minute maximum inactivity timeout and immediate authentication after lock are project-defined.
MDM-CTL-001	NCA ECC 2:2024	2-6-3-2 — Mobile Devices Security	Device passcode and automatic lock contribute to controlled and restricted use of company-owned mobile devices by limiting unauthorized device access.	General supporting mapping; this control addresses only part of restricted device use. The cited provision does not explicitly prescribe passcodes, automatic locking or their configuration values. ECC is an adopted baseline for this case study.
MDM-CTL-002	SAMA CSF v1.0	3.3.10 Bring Your Own Device, considerations 4(c) and 4(d)	Restrictions on corporate data storage, sharing and copy-and-paste support business/personal information separation and controlled use of approved work applications on BYOD.	Specific transfer restrictions and approved destinations are project-defined; platform mappings remain pending. This mapping covers aspects of 4(c) and 4(d), not all BYOD requirements or compliance with 4(e).
MDM-CTL-002	NCA ECC 2:2024	2-6-3-1 — Mobile Devices	Restrictions on storage, sharing	Partial mapping to the data separation

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
		Security	and copy-and-paste to personal or unapproved destinations support separation of corporate information from personal information on BYOD.	requirement only. CTL-002 does not define encryption requirements. Specific transfer restrictions are project-defined, and platform mappings remain pending. ECC is an adopted baseline for this case study.
MDM-CTL-003	SAMA CSF v1.0	3.3.8 Infrastructure Security, considerations 1, 2 and 5	Defining security requirements for company-owned mobile devices and assessing their compliance supports infrastructure security standards and compliance monitoring within the mobile device scope.	The cited provisions do not explicitly require compliance-based access or Microsoft Conditional Access. Access blocking, handling of unverified compliance and restoration conditions are project-defined. Platform criteria and enforcement mappings remain pending in D07–D08.
MDM-CTL-003	NCA ECC 2:2024	2-6-3-2 — Mobile Devices Security	Requiring a valid compliant device status before company-owned mobile devices can access corporate services supports controlled and restricted device use.	General supporting mapping. The provision does not explicitly require device compliance checks or Conditional Access. Compliance criteria, access blocking and restoration conditions are project-defined and require technical validation. ECC is an adopted baseline for

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
				this case study.
MDM-CTL-004	SAMA CSF v1.0	3.3.7 Change Management, considerations 4(a)–4(f) and 4(i)	Supports change impact assessment, security testing, business and cybersecurity approvals, CAB authorization, post-implementation review and rollback procedures for mobile access policy changes.	Mapping is limited to the specified change management aspects within the mobile access scope. Assigning cybersecurity approval to the CISO, representative access tests, acceptance criteria and deployment details are project-defined. This control does not establish full coverage of 3.3.7.
MDM-CTL-004	NCA ECC 2:2024	1-6-1 and 1-6-2-2 — Cybersecurity in Information and Technology Project Management	Security impact assessment and pre-deployment verification of mobile access policy settings support integrating cybersecurity requirements into change management and reviewing secure configurations before changes are released.	Partial mapping to cybersecurity integration and pre-release configuration review. The cited provisions do not prescribe the control's approval routing or rollback workflow. Coverage does not extend to all project management, hardening or update requirements. ECC is an adopted baseline for this case study.
MDM-CTL-005	SAMA CSF v1.0	3.3.5, considerations 4(a), 4(b)(4)–4(b)(7) and 4(f)(1)–4(f)(3)	Formal approvals, restricted administrative permissions and scope, timely	Partial mapping: CTL-005 does not address the MFA provisions within 4(f)(1). Quarterly reviews, approval and review

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
			access adjustments, periodic reviews, access records and individually assigned accounts support controlled privileged access and individual accountability.	assignments, and the prohibition of routine shared administrative accounts are project-defined. Intune role and scope mappings remain pending.
MDM-CTL-005	NCA ECC 2:2024	2-2-3-3, 2-2-3-4 and 2-2-3-5 — Identity and Access Management	Restricting Intune permissions to assigned responsibilities, preventing self-approval and self-review, and periodically reviewing administrative access support least privilege, segregation of duties and privileged access management.	Mapping covers selected administrative access practices, not all privileged access safeguards. Quarterly frequency and specific role assignments are project-defined. Technical role and scope validation remains pending. ECC is an adopted baseline for this case study.

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
MDM-CTL-006	SAMA CSF v1.0	3.3.5, considerations 4(a) and 4(b)(4)–4(b)(7)	Business-need-based report access, formal approvals, timely permission changes, periodic reviews and retained access records support controlled access to employee device reports.	Repository and sharing restrictions, separate permission levels, reviewer assignments and quarterly reviews are project-defined. Mapping covers report access management, not all identity and access management requirements or report accuracy.
MDM-CTL-006	NCA ECC 2:2024	2-2-3-3 and 2-2-3-5 — Identity and Access Management	Restricting report permissions to assigned tasks, separating read, update and access-management permissions, preventing self-approval and self-review, and reviewing access periodically support least privilege, segregation of duties and access rights review.	Specific repository settings, sharing-link restrictions, review assignments and quarterly frequency are project-defined. Technical permission validation remains pending. ECC is an adopted baseline for this case study.
MDM-CTL-007	SAMA CSF v1.0	3.3.5, considerations 4(b)(1), 4(b)(3)–4(b)(5), 4(b)(7) and 4(c)	Designated sponsor notifications, approved extensions, timely access revocation, retained offboarding records and	The reminder schedule, exact authorization expiry timing, session revocation and verification steps, and device recovery workflow are project-defined. Automated reminders support

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
			automated reminders support third-party access lifecycle management.	only part of access management automation. Platform mechanisms and timing limitations remain pending validation.
MDM-CTL-007	NCA ECC 2:2024	1-9-5 — Cybersecurity in Human Resources	Revoking contractor access when authorization ends, including early departures, supports immediate review and revocation of personnel access rights upon termination or departure.	Offboarding roles and procedures are project-defined. Mapping covers access revocation only, not all offboarding or data removal requirements. ECC is an adopted baseline for this case study.
MDM-CTL-008	SAMA CSF v1.0	1.2 — Integrity objective; 3.2.1.3, 6(a)–6(c)	Device-to-status verification supports information integrity through a control selected to address the identified reporting risk.	General supporting mapping. Device identifiers, independent review, correction and review records are project-defined, not expressly prescribed by these references.
MDM-CTL-008	NCA ECC 2:2024	2-7 — Objective: 2-7-1 — Data and Information Protection	Defined report preparation and verification requirements support accurate handling and integrity of device	General supporting mapping, not full coverage of 2-7-1. Matching and review procedures are project-defined. ECC is an adopted baseline for this case study.

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
			compliance information.	

Mobile Device and BYOD Policy

MDM-D06

1. Purpose

This policy defines requirements and responsibilities for secure mobile access to corporate services, protection of corporate information, and authorized use of company-owned and personal mobile devices.

2. Scope

This policy applies to employees using company-owned or approved personal Android and iOS/iPadOS devices, and contractors using company-issued devices, to access Microsoft 365 email, meetings, collaboration and work documents.

Company-owned devices are managed through Microsoft Intune MDM. Personal devices use Intune App Protection without MDM enrollment. BYOD participation is voluntary, limited to eligible employees and subject to prior approval. Microsoft Entra ID provides authentication and Conditional Access decisions.

The policy also covers responsibilities for administering the in-scope mobile service and handling employee device management reports.

Windows and macOS devices, core financing and payment operations, and privileged administrative sessions from mobile devices are outside the permitted scope of this service.

3. Roles and Responsibilities

The responsibilities below complement the assessment RACI in MDM-D02 and the control-specific assignments in MDM-D05.

Role	Responsibilities
CISO	Oversee security requirements and control assurance. Provide cybersecurity approval for mobile access policy changes and perform access approvals and reviews assigned in MDM-D05.
GRC Analyst	Define and maintain policy requirements, review supporting evidence, test controls, document findings and retest remediation in accordance with MDM-D02.
IT Operations Manager	Oversee operational implementation, technical evidence submission and remediation. Perform assigned access approvals and reviews, and ensure unresolved operational issues are tracked and escalated.

Role	Responsibilities
IT Operations Team	Implement and operate technical controls, verify applicable requirements before enabling access, provide evidence and perform remediation. Execute access revocation, device handling and report preparation and review activities as assigned.
Employee's Line Manager	Approve the business need for employee BYOD access. Approval does not replace verification of applicable security and access requirements.
Designated Internal Sponsor	Maintain contractor authorization details, promptly notify IT Operations of departures or changes, coordinate timely extension approvals and arrange company device recovery.
Responsible Business Manager	Approve contractor authorization extensions before the existing authorization expires. Pending approval must not delay access revocation.
Business Owner	Approve the business impact of mobile access policy changes before submission to CAB.
Change Advisory Board (CAB)	Authorize mobile access policy changes before deployment, following Business Owner and CISO approvals under the corporate change management process.
Employees and Contractors	Follow this policy, protect assigned devices and corporate information, use only authorized access methods, promptly report loss or suspected compromise, and cooperate with access removal and applicable device return requirements.

No individual may approve or review their own access. Detailed approval, review and verification assignments remain as specified in MDM-D05.

4. Authorized Use and Access

Access to in-scope corporate services must meet the following requirements:

Area	Policy Requirement
Authorized Use	Users must use approved work applications and individually assigned corporate accounts for authorized business purposes. Access through mobile web browsers

Area	Policy Requirement
	is not permitted within this service.
Company-Owned Devices	Devices must be enrolled in Microsoft Intune MDM and have a valid compliant status against applicable security requirements before access is granted. Enrollment alone is insufficient.
Personal Devices (BYOD)	Access is voluntary, limited to eligible employees and subject to prior line manager approval. Approved work applications must meet applicable App Protection and access requirements without MDM enrollment.
Contractor Access	Contractors must use company-issued devices. Access must remain within the approved business need and authorization period.
User Obligations	Users must not share account credentials, bypass access restrictions or disable required security protections.

5. Device and Corporate Data Protection

Area	Policy Requirement
Company-Owned Devices	Devices must meet defined passcode, automatic lock, operating system and security update requirements. Users must not remove MDM enrollment or disable required protections without authorization from IT Operations.
BYOD Data Protection	Corporate data must remain within approved work applications, corporate accounts and storage locations where required protection is maintained. Saving, sharing or copying and pasting corporate data to personal or unapproved destinations is prohibited.
Encryption	Corporate data must be encrypted at rest and in transit. Applicable encryption requirements for company-owned devices and BYOD work applications must be defined and technically validated in MDM-D07.
Security Remediation	Users must cooperate with IT Operations to resolve security issues. Access must not be restored until applicable protection and access requirements are satisfied.

Area	Policy Requirement
Corporate Data Removal	Users must cooperate with authorized corporate data removal when access ends or protective action is required. For BYOD, removal must target corporate data within approved work applications and must not include personal data or a full-device wipe.

6. Privacy and Device Reporting

Area	Policy Requirement
Information Collection and Use	Collection and use of employee, device and application information must be limited to what is necessary for mobile service security and operation.
BYOD Notice and Acknowledgment	Before BYOD access is enabled, employees must receive and acknowledge a notice explaining the information available to the company, its purposes, and protective actions that may affect corporate data or access. Acknowledgment must not be treated as unrestricted permission to access personal data.
Report Access and Sharing	Employee device reports must be stored in an approved repository and restricted to authorized individuals with a documented business need. Read, update and access-management permissions must be separately controlled. Broad internal sharing is prohibited.
Access Review	Report permissions and sharing links must be reviewed at least every three months and when responsibilities or business needs change. Unnecessary access must be removed, and no individual may approve or review their own access.
Report Accuracy	Manually compiled device compliance reports must preserve each device identifier's association with its compliance status. Another IT Operations team member must verify these mappings against source records before release. Errors must be corrected and rechecked, with review and

Area	Policy Requirement
	correction evidence retained.

7. Incident Reporting and Offboarding

Area	Policy Requirement
Incident Reporting	Users must immediately report device loss, theft, suspected compromise or unintended corporate data disclosure to IT Operations through the designated reporting channel and cooperate with response instructions.
Incident Handling	IT Operations must escalate reported incidents through the corporate incident management process and coordinate authorized protective actions. Actions and outstanding issues must be documented.
Contractor Authorization	Each contractor must have a designated internal sponsor and a recorded authorization end date and time. The sponsor must immediately notify IT Operations of early departures or changes to the agreed end time.
Reminders and Extensions	Automated reminders must be sent to the sponsor one month before authorization expires and weekly thereafter until expiry. Extensions require responsible business manager approval and recording before expiry. Missing responses or pending requests must not delay revocation.
Access Revocation	Access must be revoked when authorization ends, including at a revised end time for early departures. IT Operations must address relevant accounts, application permissions and existing sessions, and verify that access to in-scope services is blocked.
Device Return and Data Handling	The sponsor must coordinate contractor device return. IT Operations must record receipt and handle corporate data under approved retention and secure removal procedures. Access revocation must not wait for device recovery. BYOD data removal remains subject to Section 5.

Area	Policy Requirement
Verification and Follow-up	Access removal and device recovery must be tracked separately. Failed or incomplete revocation must be immediately escalated to the IT Operations Manager. Unreturned devices must be escalated for protective action. Removal commands must not be treated as completed without confirmation.

8. Policy Governance

Area	Policy Requirement
Policy Maintenance and Review	The GRC Analyst must maintain this policy under CISO oversight. It must be reviewed periodically and following material changes to service scope, risks or applicable requirements. Policy approval must follow the corporate policy governance process.
Exceptions	Exceptions must document the business justification, affected requirements, scope, owner, risk assessment, compensating measures where applicable, and expiry date. CISO security review and risk acceptance by the authorized corporate risk acceptance authority are required before activation. A pending request does not authorize non-compliance.
Exception Expiry and Follow-up	Exceptions must be tracked and reviewed before expiry. They must not remain active beyond expiry without renewed assessment and approval. Required corrective actions must have assigned owners and target dates.
Scope Changes	Exceptions must not authorize activities excluded from the service scope. Such activities require formal scope review and assessment of the associated risks and control design before authorization.
Access Policy Changes	Changes must follow the corporate change management process and MDM-CTL-004, including impact assessment, testing, Business Owner and CISO approvals, CAB authorization before deployment, rollback planning and post-

Area	Policy Requirement
	implementation verification.
Supporting Design and Assurance	Technical requirements must be specified in MDM-D07 and Conditional Access design in MDM-D08. Policy documentation alone does not demonstrate implementation or effectiveness; these require supporting evidence and control testing.

MDM Security Standard

MDM-D07

1. Purpose and Applicability

This standard defines verifiable technical requirements supporting MDM-D05 controls and the MDM-D06 policy. Requirements and platform mappings do not demonstrate implementation or effectiveness. Conditional Access design is addressed in MDM-D08, evidence collection in MDM-D09, and control testing in MDM-D10.

2. Management Models and Prerequisites

Company-owned mobile devices must be assigned to individual users and used for business purposes only. The following management models are selected for the service design:

Device Group	Selected Management Model
Company-owned Android	Android Enterprise Fully Managed, associated with a single user.
Company-owned iOS/iPadOS	Automated Device Enrollment (ADE), supervised, with user affinity.
Employee BYOD - Android and iOS/iPadOS	Intune App Protection without MDM enrollment.

Enrollment prerequisites, licensing, supported platforms and configuration dependencies must be validated before implementation. Contractors must use company-issued devices.

2.1 Technical Prerequisites

Area	Required Prerequisites
Identity and Licensing	In-scope users must have individual corporate Microsoft Entra accounts, Intune Plan 1 user entitlements or equivalent included rights, and Microsoft Entra ID P1 or higher for Conditional Access. Required Microsoft 365 service entitlements must also be verified.
Corporate Android	Devices must support Android Enterprise Fully Managed and Google Mobile Services. Intune must be connected to Managed Google Play. Devices must be new or factory-reset for provisioning, with an assigned fully managed enrollment profile.
Corporate iOS/iPadOS	Devices must be available in the corporate Apple automated enrollment service and assigned to

Area	Required Prerequisites
	Intune. An active ADE token and Apple MDM push certificate are required. New or erased devices must receive an ADE profile with supervision and user affinity.
BYOD Applications and Identity	Approved applications must support Intune App Protection. Policies must target the relevant users and applications. Required authentication brokers and Microsoft Entra device registration must be validated without introducing MDM enrollment.
Dependency Maintenance	IT Operations must track certificate and token expiry, renewal responsibilities and service connectivity. Supported OS and application versions must be verified against the technical requirements defined in this standard.

These prerequisites are defined requirements, not confirmed implementation. License assignments, service connections, enrollment settings and application dependencies remain subject to evidence review and testing.

3. Corporate Device Security

3.1 Device Passcode and Automatic Lock - Android

Requirement ID: MDM-STD-001

Field	Details
Scope and traceability	MDM-AST-001, company-owned Android (Fully Managed). Supports MDM-CTL-001 and MDM-D06 Section 5.
Requirement	A PIN of at least six digits; repeated or sequential PINs blocked; automatic lock within five minutes of inactivity; immediate authentication after lock, with no grace period.
Verification	Short, repeated and sequential PINs are rejected. The device locks within five minutes. Authentication is required straight after automatic and manual lock.
Constraints and status	No supported setting is confirmed yet for immediate authentication after lock; IT Operations confirms one for the selected models before activation. Screen-off timing alone does not prove it. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.

Field	Details
Source	Microsoft Learn: Intune Android Enterprise device restrictions, fully managed (device password, power settings). Reviewed 29 October 2026.

3.2 Device Passcode and Automatic Lock — iOS/iPadOS

Requirement ID: MDM-STD-002

Field	Details
Scope and traceability	MDM-AST-004, company-owned iOS/iPadOS (ADE, supervised, user affinity). Supports MDM-CTL-001 and MDM-D06 Section 5.
Requirement	A PIN of at least six digits or a password of at least six characters; simple passcodes blocked; automatic lock within five minutes of inactivity; immediate authentication after lock.
Verification	Short and simple passcodes are rejected and permitted ones accepted. The device locks within five minutes. Authentication is required straight after automatic and manual lock.
Constraints and status	The grace period must stay at zero. The Numeric passcode type does not restrict passcodes to digits only. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Apple device restriction settings in Intune (Password). Reviewed 29 October 2026.

3.3 Operating System and Security Update Baseline

Requirement ID: MDM-STD-003

Field	Details
Scope and traceability	MDM-AST-001 and MDM-AST-004, company-owned Android and iOS/iPadOS. Supports MDM-CTL-003 and MDM-D06 Section 5. Threshold changes follow MDM-CTL-004.
Requirement	Devices meet the approved minimum OS and security update level, and selected models stay supported for updates, Intune management and approved apps. IT Operations reviews thresholds monthly and after relevant

Field	Details
	advisories, and records values, sources and effective dates. A new threshold takes effect on a recorded enforcement date, normally 14 days after approval; critical or actively exploited issues trigger an urgent review with a deadline and interim protections.
Verification	Threshold records show the review date, approved values and enforcement date. Devices below the threshold on that date are reported noncompliant under Section 3.6.
Constraints and status	Platform thresholds are set in Sections 3.4 and 3.5. Device and app compatibility, update availability and build-level thresholds still need validation. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: device compliance settings for Android Enterprise and for iOS/iPadOS. Reviewed 29 October 2026.

3.4 Android OS and Security Update Requirements

Requirement ID: MDM-STD-004

Field	Details
Scope and traceability	MDM-AST-001, company-owned Android (Fully Managed). Supports MDM-CTL-003, MDM-STD-003 and MDM-D06 Section 5.
Requirement	Minimum OS version Android 15.0 and minimum security patch level 2026-10-01 (Android Security Bulletin, 5 October 2026). Selected models must have active manufacturer support with monthly security updates.
Verification	Devices below either threshold are reported noncompliant and reassessed after updating. Access enforcement is tested in MDM-D10.
Constraints and status	Both values are project-defined and the patch date does not advance automatically. Manufacturer delivery may lag the bulletin, so availability is confirmed per model before the enforcement date. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android Enterprise compliance settings; Android Security Bulletin, October 2026. Reviewed 29

Field	Details
	October 2026.

3.5 iOS/iPadOS OS and Security Update Requirements

Requirement ID: MDM-STD-005

Field	Details
Scope and traceability	MDM-AST-004, company-owned iOS/iPadOS (ADE, supervised, user affinity). Supports MDM-CTL-003, MDM-STD-003 and MDM-D06 Section 5.
Requirement	Minimum OS version iOS 27.2 and iPadOS 27.2 (released 26 October 2026). Selected models must support iOS/iPadOS 27 and stay eligible for Apple security updates. Where a fix is identified by build rather than version, a minimum build is set.
Verification	Devices below the threshold are reported noncompliant and reassessed after updating. Access enforcement is tested in MDM-D10.
Constraints and status	Devices on iOS/iPadOS 26 do not meet the baseline, even on its latest security release, because one minimum version cannot accept the latest release of two major versions without also accepting unpatched releases of the newer one. Eligible devices must upgrade before the enforcement date. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: iOS/iPadOS compliance settings; Apple: Apple security releases and Security content of iOS 27.2 and iPadOS 27.2. Reviewed 2 November 2026.

3.6 Compliance Assignment and Noncompliance Handling

Requirement ID: MDM-STD-006

Field	Details
Scope and traceability	Company-owned Android and iOS/iPadOS devices. Supports MDM-CTL-003 and MDM-D06 Section 4. Changes follow MDM-CTL-004.
Requirement	Every in-scope device receives its platform compliance policy; enrollment alone never counts as compliance.

Field	Details
	Devices with no policy are marked noncompliant. A failed requirement makes the device noncompliant immediately, with no grace period. A device that has not reported for 7 days is treated as noncompliant. Missing or unverified compliance is never accepted as proof for access.
Verification	Test four cases: no assigned policy, a failed requirement, awaiting evaluation, and no report for more than 7 days. Confirm reassessment after reporting resumes and the resulting access decision.
Constraints and status	Removing the grace period does not mean instant detection or ending open sessions; reporting delays still apply (session limits are in MDM-D08). The 7-day period is project-defined and tenant-wide, so its wider impact is assessed first. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: device compliance policies in Intune; actions for noncompliance; policy refresh intervals. Reviewed 29 October 2026.

3.7 Corporate Device Integrity

Requirement ID: MDM-STD-007

Field	Details
Scope and traceability	MDM-AST-001 and MDM-AST-004, company-owned enrolled devices only. Supports MDM-CTL-003 and MDM-D06 Section 5.
Requirement	Corporate devices pass the platform integrity checks: Android basic and device integrity, and jailbreak detection on iOS/iPadOS. A detected failure makes the device noncompliant under Section 3.6.
Verification	Confirm policy assignment, successful evaluation on approved devices, handling of a detected failure, and reassessment after remediation.
Constraints and status	Integrity checks do not detect every compromise. Android evaluation depends on Google Mobile Services. A missing or failed evaluation is never treated as proof of integrity. Implementation and effectiveness are assessed in MDM-D09

Field	Details
	and MDM-D10.
Source	Microsoft Learn: Android Enterprise and iOS/iPadOS compliance settings; Google: Play Integrity verdicts. Reviewed 29 October 2026.

3.8 Corporate Device Encryption at Rest

Requirement ID: MDM-STD-008

Field	Details
Scope and traceability	MDM-AST-001 and MDM-AST-004, company-owned enrolled devices only. Supports MDM-D06 Section 5 (encryption), MDM-CTL-003 (compliance-based access) and MDM-CTL-001 (passcode).
Requirement	Corporate data on corporate devices is protected by platform-native encryption backed by the passcode in Sections 3.1 and 3.2. Encryption is part of the compliance evaluation.
Verification	MDM-D09 collects policy settings and device-level protection evidence. MDM-D10 tests evaluation and access handling where technically possible and records test limits.
Constraints and status	A configured policy does not prove encryption on a specific device. This requirement does not cover removable media, cloud copies or data in transit. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android Enterprise and iOS/iPadOS compliance settings. Reviewed 29 October 2026.

4. BYOD Application Protection

4.1 Approved Work Applications

Requirement ID: MDM-STD-009

Field	Details
Scope and traceability	MDM-AST-005 and MDM-AST-006, employee BYOD with Intune App Protection and no MDM enrollment. Supports MDM-CTL-002 and MDM-D06 Sections 4 and 5.
Requirement	Six approved work apps: Microsoft Outlook, Teams,

Field	Details
	OneDrive, Word, Excel and PowerPoint, on Android and iOS/iPadOS. All six are covered by the App Protection policies and used only with corporate accounts. Approval of an app does not permit moving corporate data to personal accounts. Mobile browser access stays prohibited under MDM-D06.
Verification	Confirm each approved app is targeted on both platforms and protected as expected. Confirm that unapproved apps cannot reach corporate services.
Constraints and status	Listing an app in a protection policy does not by itself limit access to the approved list; access enforcement is in MDM-D08. Licensing and supported app and OS versions need validation. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Supported Microsoft Intune apps. Reviewed 30 October 2026.

4.2 Approved Corporate Storage Destinations

Requirement ID: MDM-STD-010

Field	Details
Scope and traceability	Corporate data in approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-CTL-002 and MDM-D06 Section 5.
Requirement	Corporate data may be saved only to the company's OneDrive for Business and SharePoint Online, using corporate accounts. Saving or exporting to personal accounts, unapproved storage, local storage or the photo library is blocked.
Verification	Saves to corporate storage succeed. Saves to personal accounts, local storage, the photo library and unapproved services are blocked on both platforms.
Constraints and status	Choosing a storage service does not by itself restrict saves to the company's tenant; account restrictions need validation. Protected app storage and offline caches are not exports, but stay subject to encryption and data removal. Implementation and effectiveness are assessed in MDM-D09

Field	Details
	and MDM-D10.
Source	Microsoft Learn: Troubleshoot data transfer and Intune app protection policies. Reviewed 30 October 2026.

4.3 Corporate Data Copy and Paste Restrictions

Requirement ID: MDM-STD-011

Field	Details
Scope and traceability	Corporate data in approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-CTL-002 and MDM-D06 Section 5.
Requirement	Copy and paste is allowed between protected corporate apps, and pasting into them from personal apps is allowed. Copying corporate data out to personal or unprotected apps is blocked, with no character-count exception.
Verification	Test three paths on both platforms: corporate Outlook to corporate Word (allowed), corporate Word to a personal notes app (blocked), and a personal notes app to corporate Word (allowed). Also test pasting into personal accounts inside approved apps.
Constraints and status	Protected apps are not automatically limited to the six approved apps, so the effective boundary needs validation. Pasted-in content is not checked for safety. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Troubleshoot restricting cut, copy and paste between applications. Reviewed 30 October 2026.

4.4 Corporate File Transfer Between Applications

Requirement ID: MDM-STD-012

Field	Details
Scope and traceability	Corporate files in approved work apps on MDM-AST-005 and MDM-AST-006, which are not enrolled in MDM by design. Supports MDM-CTL-002 and MDM-D06 Section 5.
Requirement	Corporate files stay within approved apps, corporate accounts and approved storage. Sending them to personal or unapproved apps is restricted. No custom exemption

Field	Details
	allows transfer to unapproved apps, and built-in exemptions are reviewed and documented before use.
Verification	Test approved app-to-app transfers and attempts to share with personal apps and accounts. On iOS/iPadOS, record whether the transfer happens and whether the receiving app can read the file.
Constraints and status	Partial. On unenrolled iOS/iPadOS devices, the Share extension can move encrypted corporate files outside managed apps, and App Protection cannot block this path. Encryption does not prove the transfer was prevented. This limitation must be resolved against MDM-D06 before design closure. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: App protection policies overview; data protection framework; data transfer policy exceptions. Reviewed 30 October 2026.

4.5 BYOD Corporate Data Encryption at Rest

Requirement ID: MDM-STD-013

Field	Details
Scope and traceability	Corporate data stored by approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Section 5 (encryption) and the app protection boundary of MDM-CTL-002.
Requirement	Corporate data stored in approved BYOD apps is encrypted. On Android, App Protection encrypts app data. On iOS/iPadOS, protection relies on device encryption while locked, so a device passcode may be required before app access.
Verification	MDM-D09 collects effective settings and app diagnostics. MDM-D10 tests app access with and without a device passcode on iOS/iPadOS, and protection of stored corporate files, recording any limits on direct verification.
Constraints and status	The app PIN is separate from the device passcode. This requirement does not cover the whole device, personal data or data in transit. Encryption does not show that a transfer

Field	Details
	was prevented (Section 4.4). Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings. Reviewed 30 October 2026.

4.6 BYOD Application Access Protection

Requirement ID: MDM-STD-014

Field	Details
Scope and traceability	Corporate contexts in approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Section 4 and the app protection boundary of MDM-CTL-002.
Requirement	An app PIN of at least six digits, with simple PINs blocked. Supported biometrics may replace the PIN, but the PIN is required again after 30 minutes. Access requirements are rechecked after 5 minutes of inactivity.
Verification	Short and simple PINs are rejected. Biometric access works, the PIN is required after the timeout and after biometric changes, and the 5-minute recheck applies when switching between protected apps.
Constraints and status	PIN length and timeouts are project-defined. The app PIN is separate from the device lock and from MFA at sign-in, and does not make the device compliant. Behavior varies by platform and app. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings; app protection policy logs. Reviewed 30 October 2026.

4.7 BYOD Root and Jailbreak Detection

Requirement ID: MDM-STD-015

Field	Details
Scope and traceability	Approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Section 4 and the app protection boundary of MDM-CTL-002.
Requirement	Access to corporate data in protected apps is blocked when

Field	Details
	a rooted or jailbroken device is detected.
Verification	Confirm the setting on both platforms and test blocking on a controlled test device where feasible. Configuration evidence alone does not prove effectiveness.
Constraints and status	The block applies inside protected apps only; it does not lock or wipe the personal device. Passing the check does not prove the device is uncompromised. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android app protection policy settings; data protection framework. Reviewed 30 October 2026.

4.8 BYOD Minimum Operating System Requirements

Requirement ID: MDM-STD-016

Field	Details
Scope and traceability	Approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Section 4 and MDM-CTL-002. Threshold changes follow MDM-CTL-004.
Requirement	Corporate app access requires Android 15.0 or later, or iOS/iPadOS 27.2 or later; devices below are blocked. Before enforcement, IT Operations validates compatibility, informs users and records the effective date. Thresholds are reviewed monthly and after relevant advisories.
Verification	Access is blocked below the threshold and allowed at it on each platform, and is reassessed after updating. Meeting the threshold does not bypass other requirements.
Constraints and status	Initial thresholds are project-defined and match Sections 3.4 and 3.5. Meeting the minimum OS does not establish device compliance; Android patch level is covered in Section 4.9. Devices that cannot meet the baseline are not eligible for BYOD. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings; managing OS versions with Intune. Reviewed 30 October 2026.

4.9 BYOD Android Security Patch Requirements

Requirement ID: MDM-STD-017

Field	Details
Scope and traceability	Approved work apps on MDM-AST-005, personal Android devices. Supports MDM-D06 Section 4 and MDM-CTL-002. Threshold changes follow MDM-CTL-004.
Requirement	Corporate app access requires Android security patch level 2026-10-01 or later; devices below are blocked. Before enforcement, IT Operations confirms update availability by model and region, informs users and records the effective date. The threshold is reviewed monthly.
Verification	Access is blocked below the threshold and allowed at it, and is reassessed after updating. Meeting the patch level does not bypass other requirements.
Constraints and status	The threshold is project-defined and matches Section 3.4; the date does not advance automatically. App Protection checks the patch level but does not install updates, which depend on the manufacturer. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android app protection policy settings; data protection framework. Reviewed 30 October 2026.

4.10 BYOD Offline Access Limit

Requirement ID: MDM-STD-018

Field	Details
Scope and traceability	Corporate data in approved apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Section 4 and MDM-CTL-002.
Requirement	Corporate data access in protected apps is blocked after 24 hours (1,440 minutes) offline. Access returns only after the app reconnects and passes authentication and protection checks; network availability alone does not count.
Verification	Test access before and after expiry on both platforms, including app suspension and reopening, and confirm revalidation after reconnection.

Field	Details
Constraints and status	Timers differ by platform: Android starts when the app detects it is offline, iOS/iPadOS counts from each app's last Intune check-in. Blocking is not guaranteed at exactly 24 hours. This requirement blocks access only; data removal after a long offline period is in Section 4.14. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings. Reviewed 30 October 2026.

4.11 BYOD Failed PIN Attempts and Disabled Accounts

Requirement ID: MDM-STD-019

Field	Details
Scope and traceability	Corporate contexts in approved apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Sections 4 and 7; complements MDM-STD-014 and MDM-STD-018.
Requirement	After 5 failed PIN attempts, the app PIN is reset. The user must sign in with the corporate account, including MFA where required, and set a new PIN that meets Section 4.6. When the account is disabled, corporate access in protected apps is blocked.
Verification	Test 5 failed attempts, authenticated recovery, and rejection of a weak replacement PIN. Disable a test account and confirm blocking online and offline, recording any detection delay.
Constraints and status	Accounts are disabled through the authorized identity process; App Protection only reacts once it detects the change and does not end every session or offline access at once. These actions block access but do not remove data. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings; data protection framework. Reviewed 30 October 2026.

4.12 BYOD Backup, Synchronization and Printing Restrictions

Requirement ID: MDM-STD-020

Field	Details
Scope and traceability	Corporate data in approved apps on MDM-AST-005 and MDM-AST-006. Supports MDM-CTL-002 and MDM-D06 Section 5.
Requirement	Corporate app data is kept out of personal device backups (Android backup, iCloud and iTunes) and is not synchronized to native apps or add-ins. Printing corporate data from BYOD is blocked.
Verification	On both platforms, test backup and restore, native contact and calendar sync (including Outlook), add-ins and printing. Record blocked operations and unsupported cases.
Constraints and status	Enforcement depends on app support, and some apps may not honor the sync restriction. These controls do not remove data already exported or backed up. Unsupported paths must be resolved before design closure. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings; supported Intune apps. Reviewed 30 October 2026.

4.13 BYOD Notifications and Screen Capture Protection

Requirement ID: MDM-STD-021

Field	Details
Scope and traceability	Approved work apps on Android and iOS/iPadOS BYOD. Supports MDM-CTL-002 and MDM-D06 Section 5.
Requirement	Notifications from protected apps do not show corporate content; generic alerts are allowed. Screen capture of corporate content is blocked, including screenshots, recording, screen sharing and mirroring on iOS/iPadOS. Users accept these restrictions when joining BYOD.
Verification	Check notification content on the device and connected accessories. Test screenshots, recording, screen sharing and app-switcher previews, and record app versions and results.
Constraints and status	Support varies by app and version; on iOS/iPadOS, screen capture blocking needs a recent Intune SDK in each app.

Field	Details
	Unsupported behavior must be resolved before activation. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings.

4.14 BYOD Extended Offline Data Removal

Requirement ID: MDM-STD-022

Field	Details
Scope and traceability	Approved work apps on Android and iOS/iPadOS BYOD. Supports MDM-D06 Sections 5 and 7; complements MDM-STD-018.
Requirement	After 90 days offline, the app requires reconnection and sign-in. If sign-in fails, the work account and its app data are removed selectively; personal data and the device are not wiped. The 24-hour access block in Section 4.10 still applies.
Verification	Test successful and failed reauthentication after the period, interaction with the 24-hour block, removal of corporate data and preservation of personal data, on each platform and tested app.
Constraints and status	Removal is not guaranteed at an exact time or across all apps at once, and elapsed time is not proof of removal. This does not replace offboarding or incident removal (Section 4.15). The 90-day trigger is project-defined. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings (conditional launch); NCA ECC 2:2024, 2-6-3-3 (supporting).

4.15 BYOD Selective Wipe Requests and Verification

Requirement ID: MDM-STD-023

Field	Details
Scope and traceability	Corporate data in protected apps on Android and iOS/iPadOS BYOD. Supports MDM-D06 Sections 5 and 7.
Requirement	Corporate app data is removed by selective wipe when

Field	Details
	offboarding, BYOD withdrawal or an incident requires it: per device for a lost or withdrawn device, per user for a departure. Personal data and full-device wipe are out of scope. IT Operations raises and tracks each request against the authorizing record, confirms the target by more than the device name, and revokes access without waiting for removal.
Verification	Each request keeps its status, target, timestamps and evidence. Pending or failed requests stay open with follow-up. Test device and user targeting, online and offline behavior, and preservation of personal data.
Constraints and status	Completion is not immediate. Submitting a request, or its disappearance from the report, is not proof of completion; evidence must be captured within the report's four-day retention. Copies exported earlier are not assumed removed. A user-level wipe continues until the user is taken off its list. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: How to wipe only corporate data from Intune-managed apps; NCA ECC 2:2024, 2-6-3-3.

4.16 BYOD App Version and Protection Compatibility

Requirement ID: MDM-STD-024

Field	Details
Scope and traceability	The six approved work apps on Android and iOS/iPadOS BYOD. Supports MDM-CTL-002 and MDM-D06 Sections 4 and 5, and Sections 4.1 to 4.15 of this standard. Changes follow MDM-CTL-004.
Requirement	Each approved app has a minimum version per platform that supports the required protections, plus a minimum SDK version on iOS/iPadOS. Older versions are blocked after a communicated update period. A baseline record lists each app, platform, minimum version, source and enforcement date, and is reviewed monthly.
Verification	Test access below and at each minimum, restoration after updating, and that one app's threshold is not applied to

Field	Details
	another.
Constraints and status	Exact version thresholds and enforcement dates are still to be set. Meeting the version does not prove that every protection works. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings (conditional launch).

4.17 BYOD Privacy Notice and Activation Record

Requirement ID: MDM-STD-025

Field	Details
Scope and traceability	Employees requesting Android or iOS/iPadOS BYOD access. Supports MDM-D06 Sections 4 and 6.
Requirement	Before activation, the employee acknowledges a version-controlled privacy notice. It states what the company can see, why, who can access it, the protection restrictions, how corporate data is removed and its limits, and a support contact. IT Operations activates BYOD only after acknowledgment, prior manager approval and technical checks; no check replaces another. The activation record keeps the employee, notice version, acknowledgment time, approval, check result and activation date, with access limited to business need.
Verification	Confirm on both platforms that what the company can actually see matches the notice, and that activation is refused when acknowledgment, approval or a technical check is missing.
Constraints and status	App protection reporting is not MDM device compliance, and documented fields are not verified tenant observations. The records repository, permissions and retention period are confirmed before operational use. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	MDM-D06 Sections 4 and 6; Microsoft Learn: How to monitor app protection policies.

5. Shared Security Requirements

5.1 Corporate Data Protection in Transit

Requirement ID: MDM-STD-026

Field	Details
Scope and traceability	Corporate and BYOD Android and iOS/iPadOS devices using approved Microsoft 365 services. Supports MDM-D06 Section 5 (encryption in transit).
Requirement	Corporate data is encrypted in transit: TLS 1.2 or later for connections, and SRTP for Teams audio and video. Approved apps validate server certificates, with no unencrypted fallback or validation bypass. IT Operations confirms supported clients and the network path, including any proxy or TLS inspection.
Verification	Keep service documentation and configuration evidence. Check representative connections on both platforms and management models for TLS version, certificate validation and Teams media protection, and record test limits.
Constraints and status	The Intune app encryption setting covers data at rest, not in transit. Microsoft documentation does not prove this environment's behavior. Transport encryption is not end-to-end, and does not cover email delivery to external recipients. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Encryption for data in transit; encryption for SharePoint, OneDrive, Teams and Exchange.

5.2 Intune Administrative Roles and Scope

Requirement ID: MDM-STD-027

Field	Details
Scope and traceability	Administrative and reviewer access to Microsoft Intune for the mobile service. Supports MDM-CTL-005 and MDM-D06 Section 3.
Requirement	Each person gets only the permissions and scope their tasks need. Operational administration, evidence review and role management are separate. Routine operational roles cannot grant or expand access. Wipe permissions are limited to designated IT Operations staff and an approved backup.

Field	Details
	Cancelling a pending selective wipe needs documented approval, with the request, reason, approver and operator recorded. Reviewers get scoped read-only access only when needed. Broad roles such as Global Administrator are avoided where narrower roles work. Each assignment records the role, tasks, scope, justification and approval.
Verification	Test permitted actions and attempts to change out-of-scope objects, change role assignments, or write through reviewer access, checking the combined effect of all assigned roles.
Constraints and status	Some permissions are bundled, so separation is partly procedural; for example, the permission to update apps also allows cancelling pending wipes. Exact roles and scopes are still to be defined. Approval and review are set in Section 5.4. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Role-based access control with Intune; RBAC and scope tags; custom roles (managed apps permissions).

5.3 Intune Administrative Authentication

Requirement ID: MDM-STD-028

Field	Details
Scope and traceability	Human accounts with administrative access to Intune, through Entra roles or Intune role assignments. Supports MDM-CTL-005; complements MDM-STD-027.
Requirement	Intune administrative access requires phishing-resistant MFA, with approved methods registered before enforcement. All administrative accounts are covered, including those assigned through Intune roles and not only the Entra Intune Administrator role. Recovery and emergency access are defined and tested with the IAM owner, and any exception is documented, authorized and monitored.
Verification	Approved methods succeed and weaker methods are rejected. Coverage of both kinds of administrator, the recovery arrangements and sign-in records are checked.

Field	Details
Constraints and status	Depends on the enterprise privileged-access control and its owner, and on licensing and method support. This requirement protects administration of the service; it does not allow administrative sessions from mobile devices. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Require phishing-resistant MFA for administrators; Conditional Access authentication strengths.

5.4 Intune Administrative Access Approval and Review

Requirement ID: MDM-STD-029

Field	Details
Scope and traceability	Administrative access to the mobile service through Entra roles and Intune role assignments. Supports MDM-CTL-005; complements MDM-STD-027 and MDM-STD-028.
Requirement	Access is approved before assignment and reviewed every quarter and whenever a role or employment status changes. The IT Operations Manager approves and reviews team members' access; the CISO approves and reviews the Manager's access. A separately authorized role administrator makes each assignment. Reviews cover direct and group-based access, combined permissions, scope and privileged Entra roles, and record a keep, adjust or remove decision per assignment. Leavers and role changes are actioned at once, not at the next review.
Verification	Sample grants for prior approval by the right approver and correct implementation. Confirm each review was complete, done by the assigned reviewer, and that removals were completed. Evidence kept: the access list reviewed, reviewer, date, decisions and completion proof.
Constraints and status	No one approves, implements or reviews their own access. The CISO holds no Intune administrative access. The GRC Analyst does not approve, review or change access; GRC tests whether approvals and reviews happened, using read-only evidence. Integration with the enterprise workflow is pending. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.

Field	Details
Source	Project-defined, based on MDM-CTL-005 and its framework mapping in MDM-D05.

5.5 Device Report Repository and Access Protection

Requirement ID: MDM-STD-030

Field	Details
Scope and traceability	Employee device management reports stored outside Intune, including manually prepared reports. Supports MDM-CTL-006 and MDM-D06 Section 6.
Requirement	Reports are kept in a restricted library on a dedicated corporate SharePoint site. Access follows business need, with three separate levels: readers view, preparers upload and update, and designated administrators manage access on approved requests. External sharing, "Anyone" links and organization-wide links are disabled. Permissions and membership are reviewed quarterly and when responsibilities change.
Verification	Readers and preparers can do only their permitted actions. Unauthorized access, permission changes and broad sharing links are refused. Review and correction evidence is kept.
Constraints and status	Read access does not stop downloading or copying, and repository permissions do not control copies after export. The site, groups and permission mapping are confirmed with the SharePoint owner before use. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft: manage sharing settings for SharePoint and OneDrive; access requests; sharing and collaboration options.

5.6 Device Compliance Report Accuracy

Requirement ID: MDM-STD-031

Field	Details
Scope and traceability	Manually compiled compliance reports for corporate devices enrolled in Intune. Supports MDM-CTL-008, MDM-RSK-008 and MDM-AST-009. Control owner: IT Operations Manager.

Field	Details
Requirement	Each device stays matched to its own compliance state from extraction to release. The Intune managed device ID is the matching key, never the device name, user email or Entra device ID. Each report shows the device ID, name, serial number and user where available, compliance state, last sync and extraction time. The source snapshot is kept. Before release, a second IT Operations team member checks every device ID and state against the snapshot and records the result. Discrepancies are investigated, corrected and rechecked; a corrected version goes to recipients of any affected report.
Verification	Test swapped device and status pairs, duplicate names and one user with several devices. Confirm detection, correction and independent review evidence.
Constraints and status	A reporting discrepancy is never recorded as device noncompliance, and a match is never guessed. Last sync and extraction time are different. An accurate report does not prove current compliance, and BYOD app protection status is not MDM compliance. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: managedDevice resource type, Microsoft Graph v1.0.

5.7 Contractor Authorization Register and Reminders

Requirement ID: MDM-STD-032

Field	Details
Scope and traceability	Contractors using company-issued mobile devices. Supports MDM-CTL-007 and MDM-D06 Section 7.
Requirement	A restricted register records each contractor's accounts, device IDs, sponsor, authorization end date and time with time zone, approval reference, reminders sent and change history. An automated daily check reminds the sponsor one calendar month before expiry, then every seven days. An extension needs recorded approval from the Responsible Business Manager before expiry; a pending request does not extend access. Sponsors report early departures at once. IT Operations monitors failed runs and escalates to the IT

Field	Details
	Operations Manager.
Verification	Test scheduling, time zones and month-end dates, extensions, early departures, late entries, failed runs and unauthorized changes to the register.
Constraints and status	Reminders do not enforce expiry: access ends at the authorized time whatever happens to the reminder (Section 5.8). A sent reminder does not prove it was read. The automation's licensing and ownership need validation. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Power Automate triggers and licensing.

5.8 Contractor Access Revocation and Verification

Requirement ID: MDM-STD-033

Field	Details
Scope and traceability	Contractors on company-issued devices with individual cloud-only Entra ID accounts. Supports MDM-CTL-007 and MDM-D06 Section 7.
Requirement	Access is revoked at authorization expiry or at the early-departure time; only an extension approved before expiry changes the deadline. IT Operations prepares an offboarding task with the exact end time, an operator, a backup and out-of-hours cover; missing cover never extends access. At the deadline, authorized administrators disable the account, revoke sign-in sessions and remove app, group and shared-resource permissions.
Verification	Confirm that access is actually blocked, not only that the account shows as disabled. Keep the task reference, action results, timestamps and open issues. The IT Operations Manager monitors due tasks and escalates any missed or incomplete action at once, with an owner and target time. Test expiry, early departure, extension, operator absence, new sign-ins and existing sessions.
Constraints and status	Existing sessions may continue for a time depending on tokens and apps, so blocking delays are measured. Device recovery and data removal are tracked separately and never

Field	Details
	delay revocation. Closing the task is not proof of revocation. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Revoke user access in Microsoft Entra ID.

5.9 Corporate Device Recovery and Data Removal

Requirement ID: MDM-STD-034

Field	Details
Scope and traceability	Corporate Android (Fully Managed) and supervised iOS/iPadOS devices. Supports MDM-D06 Sections 5 and 7, and MDM-CTL-007 for contractor offboarding.
Requirement	Returned devices are recorded (device IDs, previous user, receipt date, receiver) and fully wiped before reassignment, after retention and incident-evidence checks. A reassigned device is re-enrolled and checked for protection and compliance before access is given. A lost or stolen device is wiped remotely once reported, without waiting for recovery; delaying the wipe to keep incident evidence needs CISO approval on record. Unreturned devices are escalated, and access revocation never waits for recovery.
Verification	Each wipe result is tracked. An unconfirmed wipe stays open with an owner and follow-up date. Returned devices are inspected for a clean reset before re-enrollment. Test wipe and re-enrollment on both platforms, including lost devices, offline devices and failed actions.
Constraints and status	Sending the command, deleting the record or a reported status is not proof of removal. Remote wipe depends on device connectivity. Full-device wipe is never used on BYOD. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Wipe devices with Microsoft Intune; NCA ECC 2:2024, 2-6-3-3.

5.10 Approved Applications and Storage for Corporate Devices

Requirement ID: MDM-STD-035

Field	Details
Scope and traceability	Company-owned Android and iOS/iPadOS devices enrolled in Intune. Supports MDM-D06 Sections 4 and 5.
Requirement	The approved business apps are the same six as for BYOD: Microsoft Outlook, Teams, OneDrive, Word, Excel and PowerPoint, used with corporate accounts. Corporate data is stored only in the company's OneDrive for Business and authorized SharePoint locations. Enrollment, management and authentication components are allowed but do not extend the app list. Mobile browser access to corporate services stays prohibited.
Verification	On both platforms, confirm approved apps, corporate-account use and permitted storage. Test unapproved clients, personal accounts, unauthorized destinations and the sign-in flows the apps need.
Constraints and status	Installing approved apps does not by itself block other clients or limit storage to the company's tenant; data transfer restrictions and access design (MDM-D08) do that. Platform-specific enforcement is still to be mapped. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Project-defined, based on MDM-D06 Sections 4 and 5.

Conditional Access Control Design

MDM-D08

1. Purpose and Scope

This appendix defines the Conditional Access design for the mobile service. It translates the access requirements in MDM-D05, MDM-D06 and MDM-D07 into four Microsoft Entra Conditional Access policies.

The design covers access to Microsoft 365 from Android and iOS/iPadOS devices. It applies to corporate devices, approved BYOD and Intune administrators.

Windows and macOS devices, guest and external users, and the design of user MFA are out of scope. They depend on enterprise policies, described in Sections 4.5 and 5.

This is a design document. No tenant was configured. Evidence and testing in MDM-D09 and MDM-D10 are simulated.

2. Design Approach and Prerequisites

2.1 Design Approach

Every user is covered by default. Corporate devices must be compliant. Approved BYOD users may also use App Protection. Mobile browsers are blocked. Administrators need phishing-resistant MFA.

User Population	Policy	Access Requirement
Employees and contractors on corporate devices	MDM-CAP-001	Compliant device
Approved BYOD users	MDM-CAP-002	Compliant device or App Protection
Employees not approved for BYOD, on personal devices	MDM-CAP-001	Blocked. A personal device cannot be compliant.
Contractors on personal devices	MDM-CAP-001	Blocked
All users in mobile browsers	MDM-CAP-003	Blocked
Intune administrators	MDM-CAP-004	Phishing-resistant MFA
Guest and external users	None	Outside D06 scope. Enterprise policies apply.

2.2 Groups

Group	Members	Managed By	Used By
MDM-BYOD-Approved	Employees who passed the D07 Section 4.17 activation gate	IT Operations Team	MDM-CAP-002 (include); MDM-CAP-001 (exclude)
MDM-Intune-Admins-*	Accounts holding Intune RBAC roles, one group per role	Separately authorized role administrators (D07 Sections 5.2 and 5.4)	Intune role assignments; MDM-CAP-004 (include)
MDM-Emergency-Access	Emergency access accounts	Enterprise IAM team	Excluded from all four policies

Group names are project-defined. Each addition to MDM-BYOD-Approved must reference its activation record.

2.3 Prerequisites

Field	Details
Licensing	Microsoft Entra ID P1 for all users in scope (D07 Section 2.1).
Corporate Enrollment	Corporate devices are enrolled in Intune (D07 Section 2).
Compliance Policies	Compliance policies are assigned to corporate devices (D07 Section 3.6).
App Protection Policies	Policies follow D07 Section 4 and target unmanaged devices only.
Broker Apps	Microsoft Authenticator on iOS. Company Portal on Android.
iOS App Configuration	OneDrive on corporate iOS receives a manual app configuration policy.
Administrator Methods	Administrators register phishing-resistant methods before MDM-CAP-004 is enforced.
Emergency Access	Emergency accounts are created and tested (Section 4.1).
Policy Administration	The enterprise IAM team holds the Conditional Access Administrator role.

Field	Details
User MFA	The enterprise user MFA policy is confirmed (Section 4.5).

3. Access Policies

3.1 Corporate Mobile Device Compliance

Field	Details
Policy	MDM-CAP-001 - Corporate Mobile - Require Compliant Device
Traceability	MDM-CTL-003; MDM-RSK-003; D06 Section 4; D07 Sections 3.3 to 3.8.
Applies to	All users on Android and iOS, all resources and all client app types. Excluded: the approved BYOD group (covered by MDM-CAP-002), guest and external users, and emergency access accounts (Section 4.1).
Requirement	Access only from devices that Intune reports as compliant.
Design decisions	Devices with no compliance policy count as not compliant and are blocked (D07 Section 3.6). Personal devices of employees not approved for BYOD, and of contractors, cannot be compliant, so they are blocked. Legacy clients are blocked. Enrollment is not blocked, so new devices can enroll before they become compliant. No manual override; restoration follows Section 4.3.
Rollout and ownership	Starts in report-only; switched on after MDM-CTL-004 approval and pilot results. Owner: IT Operations Manager (MDM-CTL-003). Operator: IT Operations Team.
Limitations	Platform spoofing (L-01). Access may continue until the token renews (L-02).
Validation (D10)	Compliant device allowed; noncompliant device, device with no policy and legacy client blocked; new device enrolls; employee and contractor personal devices blocked; access restored after remediation; iPadOS covered by the iOS platform.
Source	Microsoft Learn: Conditional Access grant, conditions and user targeting; require device compliance. Reviewed 3 November 2026.

3.2 BYOD App Protection Access

Field	Details
Policy	MDM-CAP-002 - BYOD Mobile - Require Compliant Device or App Protection
Traceability	MDM-CTL-002; MDM-RSK-002; D06 Section 4; D07 Sections 4.1 and 4.17.
Applies to	The approved BYOD group on Android and iOS, all resources and all client app types. Excluded: emergency access accounts. Users join the group only after the D07 Section 4.17 activation gate; on withdrawal they are removed (effective within a day, Section 4.2). Departures follow D07 Section 5.8 and data removal D07 Section 4.15.
Requirement	A compliant device or an app protected by Intune App Protection; one of the two is enough.
Design decisions	The compliant option exists because a BYOD user may also hold a corporate device, which must then be compliant. App Protection targets unmanaged devices only, so a corporate device cannot pass through the app option. Apps outside the D07 Section 4.1 policies fail the grant. Device-level checks (root, OS, patch, offline, disabled account) are enforced by App Protection in D07 Sections 4.7 to 4.11, not here. A broker app is required (Authenticator on iOS, Company Portal on Android); there is no MDM enrollment. On corporate iOS, OneDrive needs a manual app configuration (Section 2.3). Legacy clients are blocked.
Rollout and ownership	Starts in report-only; a "Report-only: Failure" entry for the app control is not by itself a pilot failure. Switched on after MDM-CTL-004 approval and pilot results. Restoration follows Section 4.3. Owner: IT Operations Manager (MDM-CTL-002). Operator: IT Operations Team.
Limitations	L-01, L-02, group changes not immediate (L-03), OneDrive managed state (L-05).
Validation (D10)	Approved app on BYOD allowed; app outside the policies blocked; noncompliant corporate device of a BYOD user blocked (mandatory, A-01); OneDrive on corporate iOS tested with and without app configuration; each approved app supports the grant (A-04); missing broker redirects to the store; legacy client blocked; group members match

Field	Details
	activation records.
Source	Microsoft Learn: Conditional Access grant; require app protection policy; create and assign app protection policies. Reviewed 3 November 2026.

3.3 Mobile Browser Access Block

Field	Details
Policy	MDM-CAP-003 - All Mobile - Block Browser Access to Microsoft 365
Traceability	D06 Section 4 (Authorized Use); D07 Section 4.1 (MDM-STD-009) and Section 5.10 (MDM-STD-035). D07 Section 5.10 has no D05 control and is covered under known gap 1 in the D10 test plan.
Applies to	All users, including the approved BYOD group, on Android and iOS, for Office 365 in browsers only. Excluded: guest and external users, and emergency access accounts.
Requirement	Block browser access. Approved apps are the only access route.
Design decisions	The block covers every mobile browser, including Edge with App Protection, and a compliant device or App Protection does not override it. Approved apps sign in as mobile apps, not browsers, so they are not affected (A-03). Targeting Office 365 keeps enrollment, Company Portal and security-info registration outside the block.
Rollout and ownership	Starts in report-only; switched on after MDM-CTL-004 approval and pilot results. Owner: IT Operations Manager. Operator: IT Operations Team.
Limitations	A browser in desktop-site mode may appear as macOS and fall outside the policy (L-01).
Validation (D10)	Outlook on the web, SharePoint and OneDrive blocked in mobile browsers on both platforms; approved app sign-in still works; links from Teams and Outlook behave as expected; desktop-site mode tested on iPhone and iPad; enrollment, Company Portal and security-info registration unaffected; in-app web views tested.

Field	Details
Source	Microsoft Learn: Conditional Access conditions, target resources and user targeting; MFA for Intune enrollment. Reviewed 3 November 2026.

3.4 Intune Administrator Phishing-Resistant MFA

Field	Details
Policy	MDM-CAP-004 - Intune Administrators - Require Phishing-Resistant MFA
Traceability	MDM-CTL-005; MDM-RSK-005; D07 Section 5.3 (MDM-STD-028).
Applies to	The MDM-Intune-Admins-* groups and the Intune Administrator and Global Administrator roles, for all resources on any platform. Excluded: emergency access accounts.
Requirement	Phishing-resistant MFA for every account that administers Intune.
Design decisions	Role targeting covers built-in Entra roles only, so the groups that grant Intune roles are also the groups this policy targets; no one can hold an Intune role and be out of scope. Only separately authorized role administrators change these groups (D07 Section 5.2). Enforcing before methods are registered risks lockout. The policy does not allow administration from mobile devices (D06 Section 2).
Rollout and ownership	Starts in report-only; switched on after registration is confirmed and MDM-CTL-004 approval. Recovery: emergency access (Section 4.1) and IAM recovery arrangements (D07 Section 5.3). Owner: CISO (MDM-CTL-005). Operator: enterprise IAM team. IT Operations administrators are in scope but do not configure the policy. Confirm with the IAM owner that no enterprise policy already covers these accounts.
Limitations	Custom or administrative-unit-scoped roles are not covered by role targeting (L-06). Existing sessions (Section 4.2).
Validation (D10)	Phishing-resistant method accepted and weaker methods rejected; Entra-role and Intune RBAC administrators covered (A-05); Graph and PowerShell access covered; group

Field	Details
	members match policy scope; emergency account excluded and monitored; sign-in logs record the authentication strength.
Source	Microsoft Learn: Require phishing-resistant MFA for administrators; Conditional Access grant; filter for devices. Reviewed 3 November 2026.

4. Shared Design Elements

4.1 Emergency Access and Exclusions

Field	Details
Applies To	MDM-CAP-001 to MDM-CAP-004.
Accounts	At least two emergency access accounts, in the MDM-Emergency-Access group.
Account Type	Cloud-only, using the onmicrosoft.com domain. Not synchronized or federated.
Exclusion	Excluded from all four policies.
Authentication	Passkey (FIDO2). The method differs from those used by other administrators.
Monitoring	An alert is raised for every sign-in. Sign-in and audit logs are kept for review.
Validation	Sign-in is tested at least every 90 days and after major policy changes.
Owner	Enterprise IAM team.
Other Exclusions	None beyond those stated in each policy. Any exception follows D06 Section 8.
Exclusion Changes	Follow MDM-CTL-004.

4.2 Session Behavior

Field	Details
Applies To	MDM-CAP-001 to MDM-CAP-004.
Default Token Lifetime	Access tokens last one hour by default.

Field	Details
CAE Sessions	CAE-capable clients may hold tokens for up to 28 hours.
CAE Critical Events	Account disabled or deleted, password reset, sessions revoked, MFA enabled, high user risk.
Supported Services	Exchange Online, SharePoint Online and Teams.
Device Compliance	Microsoft does not list a change in device compliance as a CAE critical event. Access may continue until the token renews (L-02).
Session Revocation	Revoke sessions invalidates refresh tokens. It does not directly end an application's own session.
Policy and Group Changes	Changes to policies or group membership can take up to one day to take effect (L-03).
Departures	Use account disablement and session revocation (D07 Section 5.8). Removal from a group alone is too slow.
Offline Data	Blocking access does not remove data already on the device (L-04). D07 Sections 4.14, 4.15 and 5.9 apply.
Validation (D10)	Measure the time between noncompliance and loss of access. Measure the time between account disablement and loss of access.

4.3 Access Restoration

Field	Details
Corporate Devices	Access returns when Intune reports the device as compliant (MDM-CAP-001).
BYOD	Access returns when the app holds App Protection and passes conditional launch (MDM-CAP-002).
Unverified Status	Missing or unverified compliance is investigated before access is restored (D07 Section 3.6).
Re-enabled Accounts	Expect delays: about 15 minutes for SharePoint and Teams, and 35-40 minutes for Exchange.
Manual Override	Not permitted.

Field	Details
Restoration Evidence	A successful sign-in confirms restoration. A status change alone does not.

4.4 Change and Rollout

Field	Details
Governing Control	MDM-CTL-004.
Initial State	All four policies start in Report-only.
Report-Only Review	Review sign-in logs against expected outcomes before enforcement.
App Protection Note	“Report-only: Failure” for app protection alone is not a pilot failure.
Pilot	Enforce for a pilot group first, then expand in stages.
Approvals	Business Owner, CISO and CAB, before enforcement.
Rollback	Return the policy to Report-only. The previous approved configuration is retained.
Verification Window	Allow up to one day for changes to take effect before final post-implementation checks (L-03).

4.5 Enterprise Dependency: User MFA

Field	Details
Basis	D05 Outstanding Items (Enterprise dependency); D07 Sections 4.6 and 4.11.
Dependency	MFA for user sign-in is provided by an enterprise IAM policy. This project does not design it.
Required Confirmation	The IAM owner identifies the policy and confirms coverage of in-scope users, approved apps, corporate devices and BYOD (A-06).
ADE Enrollment	Phishing-resistant MFA is not supported in iOS/iPadOS Setup Assistant (L-07). Users need another MFA method or a Temporary Access Pass.
Second Device	MFA during ADE needs a second device or a Temporary

Field	Details
	Access Pass.
PIN Recovery	BYOD PIN reset relies on this policy (D07 Section 4.11).
Validation (D10)	Sign-in logs show MFA applied to mobile app sign-ins.
If Not Confirmed	Recorded as a gap in D11.

5. Assumptions and Limitations

The design relies on the assumptions below. Each assumption must be validated in MDM-D10 before the design is treated as effective. Limitations are accepted design boundaries; their handling is stated.

Assumptions

ID	Assumption	Affects	Validation
A-01	On a managed device without App Protection, the app protection grant fails.	MDM-CAP-002	Mandatory D10 test: noncompliant corporate device of a BYOD user is blocked.
A-02	The iOS device platform covers iPadOS.	MDM-CAP-001 to MDM-CAP-003	D10 test on an iPad.
A-03	Approved apps sign in as Mobile apps and desktop clients, not as Browser.	MDM-CAP-003	D10 test of app sign-in and in-app web views.
A-04	The six approved apps support the app protection grant.	MDM-CAP-002	D10 test for each app on both platforms.
A-05	Intune RBAC roles are assigned through Entra groups.	MDM-CAP-004	D09 evidence of role assignments.
A-06	An enterprise user MFA policy exists and covers this scope.	Section 4.5	Confirmation from the IAM owner; D10 sign-in log review.

Limitations

ID	Limitation	Affects	Handling
L-01	Device platform relies on the user agent, which can be changed. A browser in	MDM-CAP-001	Enterprise desktop policies provide protection. D10

ID	Limitation	Affects	Handling
	desktop-site mode may appear as macOS.	to MDM-CAP-003	tests desktop-site mode.
L-02	A change in device compliance is not a CAE critical event. Access may continue until the token renews.	MDM-CAP-001, MDM-CAP-002	Carried to D11 and D12 under MDM-RSK-003.
L-03	Policy and group changes can take up to one day to take effect.	All policies	Section 4.4 verification window. Departures use D07 Section 5.8.
L-04	Blocking access does not remove data already on the device.	All policies	D07 Sections 4.14, 4.15 and 5.9.
L-05	OneDrive on corporate iOS needs manual app configuration. Without it, the device is treated as unmanaged.	MDM-CAP-002	Section 2.3 prerequisite. D10 tests OneDrive with and without configuration.
L-06	Role targeting does not cover custom or administrative-unit-scoped roles.	MDM-CAP-004	Policy targets the Intune RBAC groups.
L-07	Phishing-resistant MFA is not supported in iOS/iPadOS Setup Assistant.	Section 4.5	Another MFA method or a Temporary Access Pass for ADE enrollment.
L-08	No tenant was configured. Report-only results cannot be observed.	All policies	D09 and D10 are marked as simulated.

6. Sources

All Microsoft Learn pages were reviewed on 3 November 2026.

Source	Used In
Microsoft Learn: Conditional Access: Grant - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-grant	3.1, 3.2, 3.4
Microsoft Learn: Migrate approved client app to application protection policy in Conditional Access - https://learn.microsoft.com/en-us/entra/identity/conditional-access/migrate-approved-client-app	3.2
Microsoft Learn: Require approved app or app protection policy -	3.2, 4.4

Source	Used In
https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-all-users-approved-app-or-app-protection	
Microsoft Learn: Conditional Access: Conditions - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-conditions	3.1, 3.3, 5
Microsoft Learn: Conditional Access: Target resources - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-cloud-apps	3.3
Microsoft Learn: Conditional Access: Users, groups, and workload identities - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-users-groups	2.1, 3.1, 3.3
Microsoft Learn: Conditional Access: Filter for devices - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-condition-filters-for-devices	3.4
Microsoft Learn: Require device compliance with Conditional Access - https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-all-users-device-compliance	3.1
Microsoft Learn: Require phishing-resistant multifactor authentication for administrators - https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-admin-phish-resistant-mfa	3.4
Microsoft Learn: Continuous access evaluation - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-continuous-access-evaluation	4.2, 4.3
Microsoft Learn: Revoke user access in Microsoft Entra ID - https://learn.microsoft.com/en-us/entra/identity/users/users-revoke-access	4.2
Microsoft Learn: Manage emergency access accounts in Microsoft Entra ID - https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/security-emergency-access	4.1
Microsoft Learn: How to create and assign app protection policies - https://learn.microsoft.com/en-us/mem/intune/apps/app-protection-policies	2.3, 3.2

Source	Used In
Microsoft Learn: Set up multifactor authentication for Intune device enrollment - https://learn.microsoft.com/en-us/mem/intune/enrollment/multi-factor-authentication	3.3, 4.5
Microsoft Learn: Authentication methods for automated device enrollment - https://learn.microsoft.com/en-us/intune/device-enrollment/apple/ref-automated-authentication-methods	4.5

Evidence Request List and Evidence Index

MDM-D09

1. Purpose and Scope

This document defines the evidence needed to assess the MDM controls. It lists each evidence request and records the review of the evidence received.

It covers the controls in MDM-D05, the requirements in MDM-D07 and the access policies in MDM-D08. It also covers D07 requirements without a D05 control (known gap 1) and enterprise dependencies.

This document assesses evidence only. Control effectiveness is tested in MDM-D10. Findings are recorded in MDM-D11.

No tenant was configured. All evidence and results are simulated.

2. Evidence Approach

2.1 Evidence Types

Type	Meaning	Collected In
C - Configuration	How a system is set up, such as a policy export.	MDM-D09
R - Record	Evidence of a state or an action, including system-generated reports.	MDM-D09
T - Test	Behavior that only a test can show.	MDM-D10

2.2 Roles

Field	Details
Requests Evidence	GRC Analyst.
Provides Evidence	IT Operations Team.
Exception	The enterprise IAM team provides MDM-EVD-027, MDM-EVD-032 to 034 and MDM-EVD-069 to 075.
Reviews Evidence	GRC Analyst.
Selects Samples	GRC Analyst, in MDM-D10. Providers do not select samples.
Basis	MDM-D02.

2.3 Request Rules

Field	Details
One Request per File	Each request covers one evidence file. Source Requirement lists every section the file supports.
Shared Files	A shared configuration file is requested once, under the control it mainly supports.
Populations	For recurring events, the full population is requested first. Details are requested for selected items.
Default Period	Three months. This covers one quarterly review cycle.
Log Period	30 days for Microsoft Entra sign-in logs, the native retention period (Section 5).
Events Not Occurred	A provider confirmation is accepted. It is recorded as Accepted with a note.
Traceability	Evidence must show its source, date and scope. Untraceable evidence is re-requested once.

3. Evidence Request List

Requests are grouped by control, then known gap 1, then enterprise dependencies. Each request has a unique evidence ID, used again in Section 4 and in MDM-D10.

3.1 MDM-CTL-001 Device Passcode and Automatic Lock

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-001	Android Enterprise fully managed device restrictions profile. Password and power settings, with group assignment.	D07 Section 3.1 (MDM-STD-001)	C	Intune policy export	Current, at collection date
MDM-EVD-002	Approved configuration for immediate authentication after lock. One entry per selected model and OS version.	D07 Section 3.1 (MDM-STD-001)	C	Configuration record with source	Current, at collection date
MDM-EVD-003	iOS/iPadOS device restrictions profile. Passcode	D07 Sections 3.2 and 3.8	C	Intune policy export	Current, at

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
	settings, with group assignment.	(MDM-STD-002, 008)			collection date

3.2 MDM-CTL-002 Corporate Data Transfer Protection on BYOD

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-004	Android App Protection policy. Data protection, access requirements and conditional launch settings, with assignment to unmanaged devices.	D07 Sections 4.1-4.13 and 4.16 (MDM-STD-009 to 021, 024)	C	Intune policy export	Current, at collection date
MDM-EVD-005	iOS/iPadOS App Protection policy. Same scope as MDM-EVD-004.	D07 Sections 4.1-4.13 and 4.16 (MDM-STD-009 to 021, 024)	C	Intune policy export	Current, at collection date
MDM-EVD-006	Approved app version baseline. App, platform, minimum version, SDK requirement, source and enforcement date.	D07 Section 4.16 (MDM-STD-024)	R	Baseline record	Current version and change history
MDM-EVD-007	OneDrive app configuration policy for corporate iOS devices.	D08 Section 2.3; L-05	C	Intune policy export	Current, at collection date
MDM-EVD-008	MDM-CAP-002 policy configuration.	D08 Section 3.2 (MDM-CAP-002)	C	Entra policy export	Current, at collection date
MDM-EVD-009	MDM-BYOD-Approved group membership, with the date each member was added.	D08 Sections 2.2 and 3.2	R	Entra group export	Current, at collection date

3.3 MDM-CTL-003 Compliance-Based Access for Corporate Mobile Devices

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-010	Android Enterprise fully managed compliance policy. OS, patch, integrity and encryption settings, with assignment.	D07 Sections 3.4, 3.7 and 3.8 (MDM-STD-004, 007, 008)	C	Intune policy export	Current, at collection date
MDM-EVD-011	iOS/iPadOS compliance policy. OS, build, jailbreak and password settings, with assignment.	D07 Sections 3.5, 3.7 and 3.8 (MDM-STD-005, 007, 008)	C	Intune policy export	Current, at collection date
MDM-EVD-012	Tenant compliance policy settings. Handling of devices with no assigned policy, and the validity period.	D07 Section 3.6 (MDM-STD-006)	C	Intune settings export	Current, at collection date
MDM-EVD-013	Device compliance report for corporate devices. Status, OS version, patch level and last check-in per device.	D07 Sections 3.6–3.8 (MDM-STD-006 to 008)	R	Intune report export	At collection date
MDM-EVD-014	Baseline maintenance record. Approved values, affected devices, sources and effective dates.	D07 Section 3.3 (MDM-STD-003)	R	Baseline record	Last three months
MDM-EVD-015	Threshold enforcement record. Approval date, enforcement date, user notifications and devices unable to comply.	D07 Sections 3.3–3.5 (MDM-STD-003 to 005)	R	Change record	Most recent threshold change
MDM-EVD-016	Urgent update record. Required update, deadline and interim protections.	D07 Section 3.3 (MDM-STD-003)	R	Change record	Last three months, if any
MDM-EVD-017	MDM-CAP-001 policy configuration.	D08 Section 3.1 (MDM-CAP-001)	C	Entra policy export	Current, at collection date

3.4 MDM-CTL-004 Access Policy Change Management

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-018	List of changes to in-scope mobile access policies.	D05 MDM-CTL-004; D07 Sections 3.3 and 3.6; D08 Section 4.4	R	Change register export	Last three months
MDM-EVD-019	Impact assessment and pre-implementation test results, with acceptance criteria.	D05 MDM-CTL-004	R	Change record	Changes selected from MDM-EVD-018
MDM-EVD-020	Business Owner approval, CISO approval and CAB authorization.	D05 MDM-CTL-004; D08 Section 4.4	R	Change record	Changes selected from MDM-EVD-018
MDM-EVD-021	Rollback plan, with the retained previous configuration.	D05 MDM-CTL-004; D08 Section 4.4	R	Change record	Changes selected from MDM-EVD-018
MDM-EVD-022	Deployment communication and pilot results.	D05 MDM-CTL-004; D08 Section 4.4	R	Change record	Changes selected from MDM-EVD-018
MDM-EVD-023	Report-only sign-in log review against expected outcomes.	D08 Section 4.4	R	Review record with log extract	Conditional Access changes selected from MDM-EVD-018
MDM-EVD-024	Post-implementation verification results.	D05 MDM-CTL-004; D08 Section 4.4	R	Change record	Changes selected from MDM-EVD-018

3.5 MDM-CTL-005 Intune Administrative Access Management

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-025	Intune RBAC role assignments. Role, assigned group, scope groups and scope tags.	D07 Section 5.2 (MDM-STD-027); D08 Section 5 (A-05)	C	Intune RBAC export	Current, at collection date

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-026	MDM-Intune-Admins-* group membership.	D08 Sections 2.2 and 3.4	R	Entra group export	Current, at collection date
MDM-EVD-027	Holders of the Intune Administrator and Global Administrator roles.	D07 Section 5.3 (MDM-STD-028); D08 Section 3.4	R	Entra role assignment export	Current, at collection date
MDM-EVD-028	Administrative access record. Account or group, role, tasks, scope, justification and approval reference.	D07 Section 5.2 (MDM-STD-027)	R	Access record	Current, at collection date
MDM-EVD-029	Access requests and approvals for administrative access grants.	D05 MDM-CTL-005; D07 Section 5.4 (MDM-STD-029)	R	Request records	All grants in the last three months
MDM-EVD-030	Most recent periodic access review. Reviewed listing, reviewer, date, decision per assignment and corrective actions.	D05 MDM-CTL-005; D07 Section 5.4 (MDM-STD-029)	R	Review record	Most recent quarterly review
MDM-EVD-031	Access removals and adjustments from reviews, role changes and departures, with completion evidence.	D05 MDM-CTL-005; D07 Section 5.4 (MDM-STD-029)	R	Change records with audit log extract	Last three months
MDM-EVD-032	Phishing-resistant method registration for administrator accounts.	D07 Section 5.3 (MDM-STD-028); D08 Section 2.3	C	Entra authentication methods report	Current, at collection date
MDM-EVD-033	MDM-CAP-004 policy configuration.	D08 Section 3.4 (MDM-CAP-004)	C	Entra policy export	Current, at collection

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
					date
MDM-EVD-034	Administrator sign-in logs, showing the authentication strength applied.	D07 Section 5.3 (MDM-STD-028); D08 Section 3.4	R	Entra sign-in log export	Last 30 days

3.6 MDM-CTL-006 Employee Device Report Access Control

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-035	Repository permissions. Users and groups, with permission levels.	D05 MDM-CTL-006; D07 Section 5.5 (MDM-STD-030)	R	SharePoint permissions report	Current, at collection date
MDM-EVD-036	Repository sharing settings. External sharing and default link type.	D05 MDM-CTL-006; D07 Section 5.5 (MDM-STD-030)	C	SharePoint settings export	Current, at collection date
MDM-EVD-037	Sharing links on device report files.	D05 MDM-CTL-006; D07 Section 5.5 (MDM-STD-030)	R	SharePoint sharing report	Current, at collection date
MDM-EVD-038	Access requests and approvals for the repository.	D05 MDM-CTL-006	R	Request records	All requests in the last three months
MDM-EVD-039	Most recent access review, with decisions and completed corrections.	D05 MDM-CTL-006	R	Review record	Most recent quarterly review

3.7 MDM-CTL-007 Contractor Offboarding and Access Revocation

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-040	Contractor authorization register. Contractor,	D05 MDM-CTL-007; D07	R	SharePoint list export	Current, with

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
	accounts, device IDs, sponsor, end date and time with time zone, approval reference and change history.	Section 5.7 (MDM-STD-032)			change history
MDM-EVD-041	Reminder flow configuration. Schedule, owner and connections.	D05 MDM-CTL-007; D07 Section 5.7 (MDM-STD-032)	C	Power Automate flow export	Current, at collection date
MDM-EVD-042	Reminder flow run history, with failures and follow-up actions.	D07 Section 5.7 (MDM-STD-032)	R	Run history export	Last three months
MDM-EVD-043	Extension approvals, recorded before expiry.	D05 MDM-CTL-007; D07 Section 5.7 (MDM-STD-032)	R	Approval records	Last three months, if any
MDM-EVD-044	Offboarding tasks for departed contractors. Task reference, end time, operator and backup.	D05 MDM-CTL-007; D07 Section 5.8 (MDM-STD-033)	R	Task records	All departures in the last three months
MDM-EVD-045	Revocation actions. Account disablement, session revocation and permission removal, with timestamps.	D05 MDM-CTL-007; D07 Section 5.8 (MDM-STD-033)	R	Task record with Entra audit log extract	Departures selected from MDM-EVD-044
MDM-EVD-046	Verification that access is blocked, with timestamps.	D05 MDM-CTL-007; D07 Section 5.8 (MDM-STD-033)	R	Verification record	Departures selected from MDM-EVD-044
MDM-EVD-047	Escalations of failed or incomplete revocation actions.	D05 MDM-CTL-007; D07 Section 5.8 (MDM-STD-033)	R	Escalation records	Last three months, if any

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-048	Recovery records for contractor devices. Device identifiers, receipt date, receiving staff member and data handling.	D05 MDM-CTL-007; D07 Section 5.9 (MDM-STD-034)	R	Recovery record	Departures selected from MDM-EVD-044

3.8 MDM-CTL-008 Device Compliance Report Accuracy Verification

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-049	List of manually compiled compliance reports released for use.	D05 MDM-CTL-008	R	Report register	Last three months
MDM-EVD-050	Source extract for each report, with extraction date and time.	D05 MDM-CTL-008; D07 Section 5.6 (MDM-STD-031)	R	Source report file	Reports selected from MDM-EVD-049
MDM-EVD-051	Pre-release review record. Report version, preparer, reviewer, date and outcome.	D05 MDM-CTL-008; D07 Section 5.6 (MDM-STD-031)	R	Review record	Reports selected from MDM-EVD-049
MDM-EVD-052	Correction records. Discrepancy, correction, source reference, re-verification and recipient notice.	D05 MDM-CTL-008; D07 Section 5.6 (MDM-STD-031)	R	Correction record	Last three months, if any
MDM-EVD-053	Export field mapping, showing the unique device identifier used for matching.	D07 Section 5.6 (MDM-STD-031)	C	Export template or mapping record	Current, at collection date

3.9 Requirements Without a D05 Control (Known Gap 1)

Shared settings are requested under Sections 3.1–3.3. This section lists additional evidence only.

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-054	Encryption status per corporate device, where the platform reports it.	D07 Section 3.8 (MDM-STD-008)	R	Intune device report export	Devices selected from MDM-EVD-013
MDM-EVD-055	App protection status report. User, app, app version, platform, policy and last sync.	D07 Sections 4.5, 4.16 and 4.17 (MDM-STD-013, 024, 025)	R	Intune app protection report	Users selected from MDM-EVD-009
MDM-EVD-056	Microsoft service documentation for encryption in transit, with review date.	D07 Section 5.1 (MDM-STD-026)	R	Retained document copies	Current, at collection date
MDM-EVD-057	Network path review. Proxy or TLS inspection affecting mobile connections to Microsoft 365.	D07 Section 5.1 (MDM-STD-026)	C	Network configuration record	Current, at collection date
MDM-EVD-058	Selective wipe request log. Target, request date, per-app completion and unresolved requests.	D07 Section 4.15 (MDM-STD-023); D08 Section 3.2	R	Intune wipe request export	Last three months
MDM-EVD-059	Corporate device wipe records. Target, command date, result and confirmation.	D07 Section 5.9 (MDM-STD-034)	R	Intune device action export	Last three months
MDM-EVD-060	Lost or stolen device reports, with wipe action and any CISO-approved delay.	D07 Section 5.9 (MDM-STD-034)	R	Incident and action records	Last three months, if any
MDM-EVD-061	Pre-reassignment records. Reset state inspection, re-enrollment and compliance before access.	D07 Section 5.9 (MDM-STD-034)	R	Recovery record	Reassigned devices selected from MDM-

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
					EVD-059
MDM-EVD-062	Approved BYOD privacy notice, with version history.	D07 Section 4.17 (MDM-STD-025)	R	Controlled document	Current version and history
MDM-EVD-063	BYOD activation records. Identity, notice version, acknowledgment time, manager approval, IT Operations verification and activation date.	D07 Section 4.17 (MDM-STD-025)	R	Activation request records	All current MDM-BYOD-Approved members
MDM-EVD-064	Activation record repository. Access permissions and retention setting.	D07 Section 4.17 (MDM-STD-025)	C	Repository settings export	Current, at collection date
MDM-EVD-065	MDM-CAP-003 policy configuration.	D08 Section 3.3 (MDM-CAP-003)	C	Entra policy export	Current, at collection date
MDM-EVD-066	Corporate device app deployment. Approved app assignments and corporate account configuration.	D07 Section 5.10 (MDM-STD-035)	C	Intune app assignment export	Current, at collection date
MDM-EVD-067	Incident reporting channel and escalation route, confirmed by the incident process owner.	D05 Outstanding Items (D06 Section 7)	R	Confirmation record	Current, at collection date

3.10 Enterprise Dependencies and Prerequisites

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
MDM-EVD-068	License assignment. Entra ID P1 and Intune for in-scope users.	D07 Section 2.1; D08 Section 2.3	C	Microsoft 365 license report	Current, at collection date
MDM-EVD-069	Enterprise user MFA policy identified, with IAM owner confirmation of coverage.	D05 Outstanding Items	R	Confirmation record with	Current, at collection

Evidence ID	Evidence Requested	Source Requirement	Type	Format	Period or Sample
		(Enterprise dependency); D08 Section 4.5 (A-06)		policy export	date
MDM-EVD-070	User sign-in logs for mobile app sign-ins, showing MFA.	D08 Section 4.5 (A-06)	R	Entra sign-in log export	Last 30 days
MDM-EVD-071	Emergency access accounts. Account type, authentication method and policy exclusions.	D08 Section 4.1	C	Entra account and policy export	Current, at collection date
MDM-EVD-072	Emergency account sign-in alert configuration.	D08 Section 4.1	C	Alert rule export	Current, at collection date
MDM-EVD-073	Emergency account sign-in and alert history.	D08 Section 4.1	R	Sign-in log and alert export	Last 30 days
MDM-EVD-074	Emergency access sign-in test record.	D08 Section 4.1	R	Test record	Most recent test
MDM-EVD-075	Holders of the Conditional Access Administrator role.	D08 Sections 2.3 and 3.4	R	Entra role assignment export	Current, at collection date

4. Evidence Index

This index records the review of each evidence request in Section 3. All entries are simulated. The simulation assumes that the D07 and D08 design was implemented and operated for three months before collection. File references and results are illustrative.

The GRC Analyst reviewed all evidence at the end of the three-month period. Evidence for items selected in MDM-D10 was reviewed after sample selection. Each result assesses the evidence only. Control effectiveness is assessed in MDM-D10.

Result	Meaning
Accepted	Evidence is complete, covers the requested period and traces to its source.
Partial	Evidence is provided but incomplete. The missing part is stated in the

Result	Meaning
	review note.
Not Provided	No usable evidence was provided.

4.1 MDM-CTL-001 Device Passcode and Automatic Lock

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-001	SIM-EVD-001 Android restrictions profile	Accepted	Export shows password and power settings, with group assignment.	MDM-TST-006
MDM-EVD-002	SIM-EVD-002 Android immediate lock confirmation	Not Provided	No supported configuration was confirmed for the selected Android models.	MDM-TST-006
MDM-EVD-003	SIM-EVD-003 iOS restrictions profile	Accepted	Export shows passcode settings, with group assignment.	MDM-TST-006

4.2 MDM-CTL-002 Corporate Data Transfer Protection on BYOD

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-004	SIM-EVD-004 Android app protection policy	Accepted	Export shows all policy settings, with assignment.	MDM-TST-001, MDM-TST-008
MDM-EVD-005	SIM-EVD-005 iOS app protection policy	Accepted	Export shows all policy settings, with assignment.	MDM-TST-001, MDM-TST-008
MDM-EVD-006	SIM-EVD-006 App version baseline	Accepted	Baseline lists the six approved apps, with all required fields.	Not selected
MDM-EVD-007	SIM-EVD-007 OneDrive iOS app configuration	Not Provided	No OneDrive app configuration policy exists for corporate iOS devices.	MDM-TST-002

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-008	SIM-EVD-008 MDM-CAP-002 policy	Accepted	Export shows the full policy configuration.	MDM-TST-002
MDM-EVD-009	SIM-EVD-009 BYOD group membership	Accepted	Export shows members and the date each was added.	MDM-TST-002, MDM-TST-009

4.3 MDM-CTL-003 Compliance-Based Access for Corporate Mobile Devices

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-010	SIM-EVD-010 Android compliance policy	Accepted	Export shows OS, patch, integrity and encryption settings, with assignment.	MDM-TST-005
MDM-EVD-011	SIM-EVD-011 iOS compliance policy	Accepted	Export shows OS, build, jailbreak and password settings, with assignment.	MDM-TST-005
MDM-EVD-012	SIM-EVD-012 Tenant compliance settings	Accepted	Export shows no-policy handling and the validity period.	MDM-TST-005
MDM-EVD-013	SIM-EVD-013 Corporate device compliance report	Accepted	Report shows all requested fields for each device.	MDM-TST-005
MDM-EVD-014	SIM-EVD-014 Baseline maintenance record	Partial	Records cover two of three monthly reviews. The first month is missing.	MDM-TST-005
MDM-EVD-015	SIM-EVD-015 Threshold enforcement record	Accepted	Record includes approval date, enforcement date, notifications and affected devices.	MDM-TST-005
MDM-EVD-016	SIM-EVD-016 Urgent update	Accepted	No urgent update occurred in the period.	Not selected

Evidence ID	Reference	Result	Review Note	D10 Test
	confirmation		Confirmed by IT Operations.	
MDM-EVD-017	SIM-EVD-017 MDM-CAP-001 policy	Accepted	Export shows the full policy configuration.	MDM-TST-005

4.4 MDM-CTL-004 Access Policy Change Management

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-018	SIM-EVD-018 Change register extract	Accepted	Register covers the full period.	Not selected
MDM-EVD-019	SIM-EVD-019 Change assessment and testing	Accepted	Records include impact assessment, test results and acceptance criteria.	Not selected
MDM-EVD-020	SIM-EVD-020 Change approvals	Accepted	Records include all three approvals, with dates.	Not selected
MDM-EVD-021	SIM-EVD-021 Rollback plans	Accepted	Records include the rollback plan and previous configuration.	Not selected
MDM-EVD-022	SIM-EVD-022 Communication and pilot results	Accepted	Records include communication and pilot results.	Not selected
MDM-EVD-023	SIM-EVD-023 Report-only log review	Not Provided	The submitted screenshot had no date, policy name or filter. No traceable replacement was provided.	Not selected
MDM-EVD-024	SIM-EVD-024 Post-implementation verification	Accepted	Records include verification results.	Not selected

4.5 MDM-CTL-005 Intune Administrative Access Management

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-025	SIM-EVD-025 Intune RBAC assignments	**Accepted**	Export shows roles, assigned groups, scope groups and scope tags.	MDM-TST-003, MDM-TST-004
MDM-EVD-026	SIM-EVD-026 Admin group membership	**Accepted**	Export lists members of each role group.	MDM-TST-003, MDM-TST-004
MDM-EVD-027	SIM-EVD-027 Entra admin role holders	**Accepted**	Export lists holders of both roles.	MDM-TST-003, MDM-TST-004
MDM-EVD-028	SIM-EVD-028 Administrative access record	**Accepted**	Record includes all required fields for each entry.	MDM-TST-003
MDM-EVD-029	SIM-EVD-029 Access requests and approvals	**Accepted**	Records cover all grants in the period.	MDM-TST-003
MDM-EVD-030	SIM-EVD-030 Quarterly access review	**Partial**	Review covers team members. The CISO review of the manager's access is not evidenced.	MDM-TST-003
MDM-EVD-031	SIM-EVD-031 Access removals	**Accepted**	Records include completion evidence from audit logs.	MDM-TST-003
MDM-EVD-032	SIM-EVD-032 Admin method registration	**Accepted**	Report covers all administrator accounts.	MDM-TST-004
MDM-EVD-033	SIM-EVD-033 MDM-CAP-004 policy	**Accepted**	Export shows the full policy configuration.	MDM-TST-004
MDM-EVD-034	SIM-EVD-034 Admin sign-in logs	**Accepted**	Logs cover the period and show the authentication strength field.	MDM-TST-004

4.6 MDM-CTL-006 Employee Device Report Access Control

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-035	SIM-EVD-035 Repository permissions	Accepted	Report lists users, groups and permission levels.	Not selected
MDM-EVD-036	SIM-EVD-036 Repository sharing settings	Accepted	Export shows external sharing and default link settings.	Not selected
MDM-EVD-037	SIM-EVD-037 Sharing links report	Accepted	Report lists all sharing links on report files.	Not selected
MDM-EVD-038	SIM-EVD-038 Repository access requests	Accepted	Records cover all requests in the period.	Not selected
MDM-EVD-039	SIM-EVD-039 Repository access review	Accepted	Record includes decisions and completed corrections.	Not selected

4.7 MDM-CTL-007 Contractor Offboarding and Access Revocation

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-040	SIM-EVD-040 Contractor authorization register	Accepted	Export includes all required fields and change history.	MDM-TST-007
MDM-EVD-041	SIM-EVD-041 Reminder flow configuration	Accepted	Export shows schedule, owner and connections.	Not selected
MDM-EVD-042	SIM-EVD-042 Reminder flow run history	Partial	Run history covers only the last four weeks of the period.	MDM-TST-007
MDM-EVD-043	SIM-EVD-043 Extension approvals	Accepted	Records cover all extensions in the period.	Not selected
MDM-EVD-044	SIM-EVD-044 Offboarding tasks	Accepted	Records cover all departures in the period.	MDM-TST-007

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-045	SIM-EVD-045 Revocation actions	Accepted	Records include actions and timestamps from audit logs.	MDM-TST-007
MDM-EVD-046	SIM-EVD-046 Access block verification	Partial	One departure shows account status only. D05 does not accept status alone as evidence.	MDM-TST-007
MDM-EVD-047	SIM-EVD-047 Revocation escalations	Accepted	No failed revocation was escalated in the period. Confirmed by IT Operations.	MDM-TST-007
MDM-EVD-048	SIM-EVD-048 Contractor device recovery	Accepted	Records include all required fields.	Not selected

4.8 MDM-CTL-008 Device Compliance Report Accuracy Verification

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-049	SIM-EVD-049 Compliance report register	Accepted	Register covers the full period.	Not selected
MDM-EVD-050	SIM-EVD-050 Source extracts	Accepted	Source files include extraction date and time.	Not selected
MDM-EVD-051	SIM-EVD-051 Pre-release review records	Accepted	Records include all required fields.	Not selected
MDM-EVD-052	SIM-EVD-052 Correction records	Accepted	Records include all required fields.	Not selected
MDM-EVD-053	SIM-EVD-053 Export field mapping	Accepted	Mapping shows the device identifier used for matching.	Not selected

4.9 Requirements Without a D05 Control (Known Gap 1)

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-054	SIM-EVD-054	Partial	Android status is	MDM-TST-005

Evidence ID	Reference	Result	Review Note	D10 Test
	Device encryption status		reported. iOS/iPadOS status is not available at device level.	
MDM-EVD-055	SIM-EVD-055 App protection status report	Accepted	Report shows all requested fields for the selected users.	MDM-TST-001
MDM-EVD-056	SIM-EVD-056 Transit encryption documentation	Partial	Vendor documentation only. It does not show the project configuration.	Not selected
MDM-EVD-057	SIM-EVD-057 Network path review	Not Provided	No network path review was performed.	Not selected
MDM-EVD-058	SIM-EVD-058 Selective wipe log	Accepted	Log includes target, date, per-app completion and open requests.	MDM-TST-008
MDM-EVD-059	SIM-EVD-059 Corporate wipe records	Accepted	Records include command date, result and confirmation.	MDM-TST-008
MDM-EVD-060	SIM-EVD-060 Lost or stolen device reports	Partial	One reported loss. Wipe was issued. No confirmation, owner or follow-up date is recorded.	MDM-TST-008
MDM-EVD-061	SIM-EVD-061 Pre-reassignment records	Accepted	Records include inspection, re-enrollment and compliance check.	MDM-TST-008
MDM-EVD-062	SIM-EVD-062 BYOD privacy notice	Accepted	Notice includes version history.	MDM-TST-009
MDM-EVD-063	SIM-EVD-063 BYOD activation	Accepted	Records include all required fields.	MDM-TST-009

Evidence ID	Reference	Result	Review Note	D10 Test
	records			
MDM-EVD-064	SIM-EVD-064 Activation record repository	Partial	Access permissions are provided. No retention period is set.	MDM-TST-009
MDM-EVD-065	SIM-EVD-065 MDM-CAP-003 policy	Accepted	Export shows the full policy configuration.	MDM-TST-010
MDM-EVD-066	SIM-EVD-066 Corporate app deployment	Accepted	Export shows app assignments and account configuration.	MDM-TST-010
MDM-EVD-067	SIM-EVD-067 Incident reporting confirmation	Accepted	Confirmation from the incident process owner is provided.	Not selected

4.10 Enterprise Dependencies and Prerequisites

Evidence ID	Reference	Result	Review Note	D10 Test
MDM-EVD-068	SIM-EVD-068 License assignment report	Accepted	Report shows license assignment for in-scope users.	Not selected
MDM-EVD-069	SIM-EVD-069 Enterprise MFA confirmation	Partial	Policy export is provided. Written coverage confirmation from the IAM owner is not provided.	Not selected
MDM-EVD-070	SIM-EVD-070 User sign-in logs	Accepted	Logs include authentication details for mobile app sign-ins.	Not selected
MDM-EVD-071	SIM-EVD-071 Emergency access accounts	Accepted	Export shows account type, method and exclusions.	MDM-TST-004
MDM-EVD-072	SIM-EVD-072 Emergency alert	Accepted	Export shows the alert rule.	MDM-TST-004

Evidence ID	Reference	Result	Review Note	D10 Test
	rule			
MDM-EVD-073	SIM-EVD-073 Emergency sign-in history	Accepted	Export covers the period.	MDM-TST-004
MDM-EVD-074	SIM-EVD-074 Emergency access test	Accepted	Record includes date, account and result.	Not selected
MDM-EVD-075	SIM-EVD-075 CA Administrator role holders	Accepted	Export lists role holders.	Not selected

5. Assumptions and Limitations

The assumptions below define the simulation. The limitations state what the evidence cannot show.

Assumptions

ID	Assumption	Affects
EA-01	The D07 and D08 design was implemented and operated for three months before collection.	All evidence
EA-02	The requested reports and exports are available under the licenses in MDM-D08 Section 2.3.	All C and R evidence
EA-03	MDM-EVD-025 provides the D09 evidence for MDM-D08 assumption A-05. Other D08 assumptions are tested in MDM-D10, except A-06. A-06 is carried to MDM-D11 with MDM-EVD-069.	MDM-EVD-025, MDM-EVD-069

Limitations

ID	Limitation	Affects	Handling
EL-01	Configuration evidence does not show that a control works.	All C evidence	Effectiveness is tested in MDM-D10.

ID	Limitation	Affects	Handling
EL-02	Microsoft Entra keeps sign-in and audit logs for 30 days under P1.	MDM-EVD-031, 034, 045, 070, 073	Log requests use 30 days. Older actions rely on extracts kept in the task record at the time (D07 Section 5.8).
EL-03	Vendor documentation does not show the project configuration.	MDM-EVD-056	Reference only. Not tested in MDM-D10. Carried to MDM-D11 with MDM-EVD-057.
EL-04	Device-level reporting differs by platform.	MDM-EVD-054	Recorded per platform (D07 Section 3.8).
EL-05	No tenant was configured. File references and results are illustrative.	All evidence	Marked as simulated (MDM-D08 L-08).

6. Sources

All Microsoft Learn pages were reviewed on 5 November 2026.

Source	Used In
MDM-D02 Stakeholder and RACI Matrix	2.2
MDM-D05 Control Requirements and Framework Crosswalk	3, 4
MDM-D07 MDM Security Standard	3, 4, 5
MDM-D08 Conditional Access Control Design	3, 4, 5
Microsoft Learn: Microsoft Entra data retention - https://learn.microsoft.com/en-us/entra/identity/monitoring-health/reference-reports-data-retention	2.3, 5

Control Testing Workbook

MDM-D10

1. Purpose and Scope

This document tests whether the MDM controls and requirements work as designed. It records the test plan, the test procedures and the results.

It covers a risk-based sample of ten tests. The sample includes controls in MDM-D05, requirements in MDM-D07 and access policies in MDM-D08. It also includes D07 requirements without a D05 control (known gap 1). Requirements not tested are listed in Section 5.

Evidence sufficiency is assessed in MDM-D09. Findings are recorded in MDM-D11. Control readiness is rated in MDM-D13.

No tenant was configured. All results are simulated.

2. Testing Approach

2.1 Sample Selection Basis

Field	Details
Basis	Risk-based. Risk levels are taken from MDM-D04.
High Risks	Two tests each: MDM-RSK-002 and MDM-RSK-005.
Risks Scored 9	One test each: MDM-RSK-001, MDM-RSK-003 and MDM-RSK-007.
Risks Scored 6	**Not tested. Listed in Section 5.**
Known Gap 1	Tested where the requirement covers data removal, the BYOD notice or browser access (MDM-TST-008 to 010).
MDM-D08 Commitments	Assumptions and limitations that MDM-D08 assigns to testing are included, except A-06 (Section 5).
Sample Size	Ten items or fewer: all items are tested. More than ten: ten items are selected. Project-defined.
Automated Checks	When a check can be run on a full report, the full population is tested.
Selected By	GRC Analyst. Providers do not select samples.
Events Not Occurred	No step is designed for an event that did not occur in the period. A documented alternative is tested.

2.2 Roles and Independence

Field	Details
Performs Tests	GRC Analyst, using read-only access (D07 Section 5.4).
Device and Account Steps	IT Operations Team or the enterprise IAM team, under GRC observation.
Reviews Results	CISO.
Independence Exception	Internal Audit reviews MDM-TST-003 and MDM-TST-004. The CISO owns MDM-CTL-005 and performs part of it (D07 Section 5.4). The CISO is informed of the results.
Internal Audit Role	Project-defined for MDM-D10. Not part of the MDM-D02 RACI.
Test Accounts	Administrative test accounts are approved under D07 Section 5.4 and removed after testing.
Basis	MDM-D02; D07 Section 5.4.

2.3 Result Values

Value	Applies To	Meaning
Pass	Step	The actual result matches the expected result.
Fail	Step	The actual result does not match the expected result.
Not Performed	Step	The step could not be performed. The reason is stated. It does not count as a pass.
Effective	Test	All steps passed.
Partially Effective	Test	All key steps passed. At least one other step failed or was not performed.
Not Effective	Test	At least one key step failed or was not performed.

Field	Details
Key Step	A step that tests the objective of the control or requirement itself.
Findings	Each failed step is linked to a finding (MDM-FND-###). Failed steps with one root cause share one finding.

Field	Details
Severity	Finding severity is assessed in MDM-D11, not in the test result.
Control Rating	Controls are rated Implemented, Partial or Not Implemented in MDM-D13.

2.4 Simulation Basis

Field	Details
Basis	The D07 and D08 design was implemented and operated for three months. This is the same basis as MDM-D09 Section 4.
Test Timing	Tests were performed at the end of the period, after the evidence review in MDM-D09.
Exception Sources	Each simulated exception traces to an open item or limitation in MDM-D07 or MDM-D08, a Partial or Not Provided result in MDM-D09, or documented platform behavior. Without a source, the step passes.
Labeling	All results are simulated (TL-01).

3. Test Plan

3.1 Test Coverage

Test ID	Title	Related Risk	Control or Requirement
MDM-TST-001	BYOD data transfer restrictions	MDM-RSK-002	MDM-CTL-002; D07 Sections 4.2–4.5 (MDM-STD-010 to 013)
MDM-TST-002	BYOD access through MDM-CAP-002	MDM-RSK-002	MDM-CTL-002; MDM-CAP-002; D08 A-01, A-04 and L-05
MDM-TST-003	Administrative access approval and review	MDM-RSK-005	MDM-CTL-005; D07 Section 5.4 (MDM-STD-029)
MDM-TST-004	Administrator phishing-resistant MFA	MDM-RSK-005	MDM-CTL-005; MDM-CAP-004; D07 Section 5.3 (MDM-STD-028); D08 A-05
MDM-TST-005	Compliance-based access for corporate	MDM-RSK-	MDM-CTL-003; MDM-CAP-001; D07 Sections 3.3–3.8 (MDM-STD-003 to

Test ID	Title	Related Risk	Control or Requirement
	devices	003	008); D08 A-02 and L-02
MDM-TST-006	Device passcode and immediate lock	MDM-RSK-001	MDM-CTL-001; D07 Sections 3.1–3.2 (MDM-STD-001, 002)
MDM-TST-007	Contractor access revocation	MDM-RSK-007	MDM-CTL-007; D07 Sections 5.7–5.8 (MDM-STD-032, 033)
MDM-TST-008	Corporate wipe and BYOD data removal	None in D04 (known gap 1)	D07 Sections 4.14, 4.15 and 5.9 (MDM-STD-022, 023, 034); NCA ECC 2-6-3-3
MDM-TST-009	BYOD activation gate and privacy notice	None in D04 (known gap 1)	D07 Section 4.17 (MDM-STD-025); D08 Section 3.2 (group membership)
MDM-TST-010	Mobile browser block	None in D04 (known gap 1)	D07 Section 5.10 (MDM-STD-035); MDM-CAP-003; D08 A-03 and L-01

3.2 Evidence and Review Assignments

The GRC Analyst performs all tests. The CISO reviews results, except where independence requires another reviewer (Section 2.2).

Test ID	Evidence Used	Reviewed By
MDM-TST-001	MDM-EVD-004, 005, 055	CISO
MDM-TST-002	MDM-EVD-007, 008, 009	CISO
MDM-TST-003	MDM-EVD-025 to 031	Internal Audit
MDM-TST-004	MDM-EVD-025, 026, 027, 032, 033, 034, 071, 072, 073	Internal Audit
MDM-TST-005	MDM-EVD-010 to 015, 017, 054	CISO
MDM-TST-006	MDM-EVD-001, 002, 003	CISO
MDM-TST-007	MDM-EVD-040, 042, 044 to 047	CISO

Test ID	Evidence Used	Reviewed By
MDM-TST-008	MDM-EVD-004, 005, 058 to 061	CISO
MDM-TST-009	MDM-EVD-009, 062, 063, 064	CISO
MDM-TST-010	MDM-EVD-065, 066	CISO

3.3 Results Summary

Test ID	Test Result	Finding Reference
MDM-TST-001	Not Effective	MDM-FND-001
MDM-TST-002	Not Effective	MDM-FND-002
MDM-TST-003	Not Effective	MDM-FND-003
MDM-TST-004	Effective	None
MDM-TST-005	Partially Effective	MDM-FND-004
MDM-TST-006	Not Effective	MDM-FND-005
MDM-TST-007	Not Effective	MDM-FND-006
MDM-TST-008	Not Effective	MDM-FND-007
MDM-TST-009	Partially Effective	MDM-FND-008
MDM-TST-010	Effective	None

4. Test Procedures and Results

Each test has a details table and a steps table. Key steps follow Section 2.3. All results are simulated.

4.1 MDM-TST-001 BYOD Data Transfer Restrictions

Field	Details
Test ID	MDM-TST-001
Title	BYOD data transfer restrictions
Related Risk	MDM-RSK-002
Control or Requirement	MDM-CTL-002; D07 Sections 4.2–4.5 (MDM-STD-010 to 013)

Field	Details
Objective	Confirm that corporate data in approved apps on BYOD cannot be saved, copied or shared to personal or unapproved destinations.
Evidence Used	MDM-EVD-004, 005, 055
Sample	Two personal test devices: one Android and one iPhone. Each uses a test account in MDM-BYOD-Approved.
Report Sample	Ten users from MDM-EVD-009, selected by the GRC Analyst. Status checked in MDM-EVD-055.
Performed By	GRC Analyst. The IT Operations Team performed device steps under GRC observation.
Reviewed By	CISO
Test Result	**Not Effective**
Finding Reference	MDM-FND-001

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-004 and 005 with the mappings in D07 Sections 4.2-4.5.	All mapped values are set on both platforms.	All values match.	Yes	**Pass**
2	Review data transfer exemptions in MDM-EVD-004 and 005.	No custom exemption allows transfer to unapproved apps.	No custom exemptions.	Yes	**Pass**
3	Check policy status for the ten sampled users in MDM-EVD-055.	Policy is applied for each user and app.	Policy applied for all ten users.	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
4	Save a corporate file from OneDrive to a company SharePoint site. Both platforms.	Save is allowed.	Allowed on both platforms.	No	**Pass**
5	Save a corporate Outlook attachment to local storage and to the photo library. Both platforms.	Save is blocked.	Blocked on both platforms.	Yes	**Pass**
6	Save a corporate file to a personal OneDrive account and to a personal cloud storage app. Both platforms.	Save is blocked.	Blocked on both platforms.	Yes	**Pass**
7	Copy text from corporate Outlook to corporate Word. Both platforms.	Paste is allowed.	Allowed on both platforms.	No	**Pass**
8	Copy text from corporate Word to an unmanaged notes app. Both platforms.	Paste is blocked.	Blocked on both platforms.	Yes	**Pass**
9	Copy text from an unmanaged notes app to corporate Word. Both platforms.	Paste is allowed.	Allowed on both platforms.	No	**Pass**
10	Copy corporate text to a personal account in Outlook. Both platforms.	Paste is blocked.	Blocked on both platforms.	Yes	**Pass**
11	Paste corporate text into a new unsaved Word document, then save it to local storage. Both platforms.	Save is blocked.	Blocked on both platforms.	Yes	**Pass**
12	Share a corporate file from OneDrive to an unmanaged app. Android.	Transfer is blocked.	Unmanaged apps not offered.	Yes	**Pass**
13	Open a corporate file in an unmanaged app using Open-in. iPhone.	Transfer is blocked.	Unmanaged apps not offered.	Yes	**Pass**
14	Share a corporate file to an unmanaged app using the Share	Transfer is	File transferred.	Yes	**Fail**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	extension. iPhone.	blocked.	The receiving app could not open it.		
15	Remove the device passcode, then open corporate Outlook. iPhone.	The app requires a device passcode before access.	Access blocked until a passcode was set.	Yes	**Pass**
16	Review the app protection log for the encryption setting. Android.	Encryption is shown as applied.	Shown as applied.	No	**Pass**

4.2 MDM-TST-002 BYOD Access Through MDM-CAP-002

Field	Details
Test ID	MDM-TST-002
Title	BYOD access through MDM-CAP-002
Related Risk	MDM-RSK-002
Control or Requirement	MDM-CTL-002; MDM-CAP-002; D08 A-01, A-04 and L-05
Objective	Confirm that approved BYOD users reach corporate services only through protected apps or compliant corporate devices.
Evidence Used	MDM-EVD-007, 008, 009
Sample	One personal Android device and one personal iPhone. One corporate iPhone enrolled in Intune.
Test Account	One test account in MDM-BYOD-Approved, confirmed in MDM-EVD-009.
Performed By	GRC Analyst. The IT Operations Team performed device steps under GRC observation.
Reviewed By	CISO
Test Result	**Not Effective**

Field	Details
Finding Reference	MDM-FND-002

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-008 with D08 Section 3.2.	Users, exclusions, resources, platforms, grant and state match the design. Policy state is On.	All settings match. State is On.	Yes	**Pass**
2	Confirm the test account is in MDM-BYOD-Approved, using MDM-EVD-009.	The account is a member.	Member.	No	**Pass**
3	Sign in to each of the six approved apps. Personal Android.	Access is allowed in all six apps.	Allowed in all six apps.	Yes	**Pass**
4	Sign in to each of the six approved apps. Personal iPhone.	Access is allowed in all six apps.	Allowed in all six apps.	Yes	**Pass**
5	Sign in with an app outside the App Protection policies. Both personal devices.	Access is blocked.	Blocked on both devices.	Yes	**Pass**
6	Sign in with a legacy authentication client. Personal Android.	Access is blocked.	Blocked.	Yes	**Pass**
7	Remove Microsoft Authenticator, then sign in to Outlook. Personal iPhone.	User is redirected to the App Store.	Redirected.	No	**Pass**
8	Remove Company Portal,	User is	Redirected.	No	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	then sign in to Outlook. Personal Android.	redirected to Google Play.			
9	Sign in to Outlook on the corporate iPhone while compliant.	Access is allowed.	Allowed.	No	**Pass**
10	Remove the corporate iPhone passcode to make it noncompliant. Sign in to Outlook.	Access is blocked (A-01).	Blocked.	Yes	**Pass**
11	On the same noncompliant corporate iPhone, sign in to OneDrive without app configuration.	Access is blocked (A-01).	Access allowed through the app protection option.	Yes	**Fail**
12	Repeat Step 11 with the OneDrive app configuration applied.	Access is blocked.	Not performed. No OneDrive app configuration exists (MDM-EVD-007 Not Provided).	Yes	Not Performed

4.3 MDM-TST-003 Administrative Access Approval and Review

Field	Details
Test ID	MDM-TST-003
Title	Administrative access approval and review
Related Risk	MDM-RSK-005
Control or Requirement	MDM-CTL-005; D07 Section 5.4 (MDM-STD-029)
Objective	Confirm that Intune administrative access is approved before assignment, reviewed by the assigned reviewer, and corrected when required.

Field	Details
Evidence Used	MDM-EVD-025 to 031
Grant Sample	All four administrative access grants in the period (MDM-EVD-029). The population is below the sampling threshold.
Review Sample	The most recent quarterly review (MDM-EVD-030).
Performed By	GRC Analyst, using read-only evidence.
Reviewed By	Internal Audit
Test Result	**Not Effective**
Finding Reference	MDM-FND-003

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Reconcile current assignments in MDM-EVD-025 and 026 with the access record in MDM-EVD-028.	Every assignment has a record entry and an approval reference.	All assignments reconciled.	Yes	**Pass**
2	Check the approver of the IT Operations Manager's current access in MDM-EVD-028.	Approved by the CISO.	Approved by the CISO.	Yes	**Pass**
3	Compare approval dates with assignment dates for the four grants.	Each approval precedes its assignment.	All four approvals precede assignment.	Yes	**Pass**
4	Check the approver for the four grants.	Each grant is approved by the IT Operations Manager.	All four approved by the IT Operations Manager.	Yes	**Pass**
5	Check who implemented the four grants.	No grant is implemented by its requester.	No self-implementation.	Yes	**Pass**
6	Compare implemented	Implemented	All four	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	role and scope with the approved role and scope for the four grants.	access matches the approval.	match.		
7	Check review coverage in MDM-EVD-030 against MDM-EVD-025 and 026.	All team assignments are reviewed, including group-derived access.	All team assignments reviewed.	Yes	**Pass**
8	Check the reviewer and decision for team assignments.	IT Operations Manager recorded keep, adjust or remove for each.	Recorded for each assignment.	Yes	**Pass**
9	Check the review of the IT Operations Manager's access.	CISO review recorded, with a decision.	No record of the CISO review.	Yes	**Fail**
10	Trace removals and adjustments from the review to MDM-EVD-031.	Each required change is completed and verified.	Both required changes completed with audit log evidence.	Yes	**Pass**
11	Check access changes from role changes in the period, using MDM-EVD-031.	Access is adjusted without waiting for the quarterly review.	One role change. Access adjusted within two days.	Yes	**Pass**
12	Check GRC Analyst and CISO access in MDM-EVD-025 and 027.	No write access for the GRC Analyst. No Intune administrative access for the CISO.	Read-only access for the GRC Analyst. No access for the CISO.	No	**Pass**

4.4 MDM-TST-004 Administrator Phishing-Resistant MFA

Field	Details
Test ID	MDM-TST-004
Title	Administrator phishing-resistant MFA

Field	Details
Related Risk	MDM-RSK-005
Control or Requirement	MDM-CTL-005; MDM-CAP-004; D07 Section 5.3 (MDM-STD-028); D08 A-05
Objective	Confirm that every account administering Intune must use phishing-resistant MFA, on every access path.
Evidence Used	MDM-EVD-025, 026, 027, 032, 033, 034, 071, 072, 073
Test Accounts	One test account in an MDM-Intune-Admins-* group. One test account holding the Intune Administrator role. Both approved under D07 Section 5.4 and removed after testing.
Log Sample	Ten administrator sign-ins from MDM-EVD-034, selected by the GRC Analyst.
Performed By	GRC Analyst. The enterprise IAM team prepared the test accounts.
Reviewed By	Internal Audit
Test Result	**Effective**
Finding Reference	None

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-033 with D08 Section 3.4.	Groups, roles, exclusions, resources and grant match the design. Policy state is On.	All settings match. State is On.	Yes	**Pass**
2	Compare Intune RBAC assignments in MDM-EVD-025 with group members in MDM-EVD-026.	Every account with an Intune role is in an included group (A-05).	All accounts are in scope.	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
3	Compare holders in MDM-EVD-027 with the roles included in the policy.	Intune Administrator and Global Administrator holders are in scope.	All holders are in scope.	Yes	**Pass**
4	Check method registration for all administrator accounts in MDM-EVD-032.	Each account has a phishing-resistant method registered.	All accounts registered.	No	**Pass**
5	Sign in to the Intune admin center with a phishing-resistant method. RBAC test account.	Access is allowed.	Allowed.	No	**Pass**
6	Sign in to the Intune admin center with a weaker MFA method. RBAC test account.	Access is blocked.	Blocked.	Yes	**Pass**
7	Sign in to the Intune admin center with a weaker MFA method. Entra-role test account.	Access is blocked.	Blocked.	Yes	**Pass**
8	Connect to Microsoft Graph PowerShell with a weaker MFA method. RBAC test account.	Access is blocked.	Blocked.	Yes	**Pass**
9	Review the ten sampled sign-ins in MDM-EVD-034.	Each records phishing-resistant authentication strength as satisfied.	All ten satisfied.	Yes	**Pass**
10	Check emergency account exclusions in MDM-EVD-071.	Emergency accounts are excluded, as designed.	Excluded.	No	**Pass**
11	Compare emergency sign-ins	Each emergency	One sign-in	No	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	with alerts in MDM-EVD-072 and 073.	sign-in raised an alert.	in the period. Alert raised.		

4.5 MDM-TST-005 Compliance-Based Access for Corporate Devices

Field	Details
Test ID	MDM-TST-005
Title	Compliance-based access for corporate devices
Related Risk	MDM-RSK-003
Control or Requirement	MDM-CTL-003; MDM-CAP-001; D07 Sections 3.3–3.8 (MDM-STD-003 to 008); D08 A-02 and L-02
Objective	Confirm that only compliant corporate devices reach corporate services, and that compliance thresholds are maintained.
Evidence Used	MDM-EVD-010 to 015, 017, 054
Report Population	All corporate devices in MDM-EVD-013. The check is automated, so no sample is needed.
Test Devices	One corporate Android device. One corporate iPad. One newly enrolled device. One enrolled device without a compliance policy. One personal Android device of an employee not approved for BYOD. One personal iPhone of a contractor.
Performed By	GRC Analyst. The IT Operations Team performed device steps under GRC observation.
Reviewed By	CISO
Test Result	**Partially Effective**
Finding Reference	MDM-FND-004

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-010, 011 and 012 with D07 Sections 3.4–3.8.	All mapped values are set.	All values match.	Yes	**Pass**
2	Compare MDM-EVD-017 with D08 Section 3.1.	Users, exclusions, resources, platforms and grant match the design. Policy state is On.	All settings match. State is On.	Yes	**Pass**
3	Check all devices in MDM-EVD-013 against the OS and patch thresholds.	Every device below a threshold is noncompliant.	All devices below a threshold are noncompliant.	Yes	**Pass**
4	Check devices in MDM-EVD-013 with no report in the last seven days.	Each is noncompliant.	All such devices are noncompliant.	Yes	**Pass**
5	Check monthly baseline reviews in MDM-EVD-014.	One review for each of the three months.	Two reviews. The first month is missing.	No	**Fail**
6	Check the threshold change in MDM-EVD-015.	14 days between approval and enforcement. Users notified. Devices unable to comply identified.	All conditions met.	No	**Pass**
7	Check Android encryption status in MDM-EVD-054.	All Android devices report encryption.	All report encryption.	No	**Pass**
8	Sign in to Outlook. Compliant corporate Android device.	Access is allowed.	Allowed.	No	**Pass**
9	Set the corporate Android	Access is	Blocked.	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	device below the patch threshold. Attempt a new sign-in.	blocked.			
10	Update the device, then sign in again.	Access is restored after reassessment.	Restored.	No	**Pass**
11	Remove the passcode on the corporate iPad. Sign in to Teams.	Access is blocked (A-02).	Blocked.	Yes	**Pass**
12	Enroll a new device. Sign in before compliance evaluation completes.	Enrollment succeeds. Access is blocked until evaluation.	Enrolled. Blocked until evaluation.	Yes	**Pass**
13	Sign in from an enrolled device with no compliance policy assigned.	Access is blocked.	Blocked.	Yes	**Pass**
14	Sign in from the personal Android device of an employee not approved for BYOD.	Access is blocked.	Blocked.	Yes	**Pass**
15	Sign in from the personal iPhone of a contractor.	Access is blocked.	Blocked.	Yes	**Pass**
16	Sign in with a legacy authentication client.	Access is blocked.	Blocked.	Yes	**Pass**
17	Keep an Outlook session open during Step 9. Measure the time until it loses access.	Time is recorded (L-02).	Access continued for 6 hours 10 minutes, until token renewal. Within the 28-hour bound in D08 Section 4.2.	No	**Pass**

4.6 MDM-TST-006 Device Passcode and Immediate Lock

Field	Details
Test ID	MDM-TST-006
Title	Device passcode and immediate lock
Related Risk	MDM-RSK-001
Control or Requirement	MDM-CTL-001; D07 Sections 3.1–3.2 (MDM-STD-001, 002)
Objective	Confirm that corporate devices require a strong passcode, lock within five minutes and require authentication immediately after locking.
Evidence Used	MDM-EVD-001, 002, 003
Test Devices	One corporate Android device and one corporate iPhone, both approved models.
Performed By	GRC Analyst. The IT Operations Team performed device steps under GRC observation.
Reviewed By	CISO
Test Result	**Not Effective**
Finding Reference	MDM-FND-005

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-001 with D07 Section 3.1.	PIN and lock values are set and assigned.	All values match. Assigned.	Yes	**Pass**
2	Compare MDM-EVD-003 with D07 Section 3.2.	Passcode, lock and grace period values are set and assigned.	All values match. Grace period is Immediately. Assigned.	Yes	**Pass**
3	Check MDM-EVD-002 for the approved Android immediate-lock configuration.	A supported configuration is recorded for each selected	No configuration recorded (Not	No	**Fail**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
		model.	Provided).		
4	Set a five-digit PIN. Android.	PIN is rejected.	Rejected.	Yes	Pass
5	Set repeated and sequential PINs (111111, 123456). Android.	Both PINs are rejected.	Both rejected.	Yes	Pass
6	Set a permitted six-digit PIN. Android.	PIN is accepted.	Accepted.	No	Pass
7	Leave the device idle. Android.	Device locks within five minutes.	Locked at five minutes.	Yes	Pass
8	Wake the device 15 seconds after automatic screen-off. Android.	PIN is required.	Device unlocked without a PIN.	Yes	Fail
9	Lock the device with the power button, then wake it. Android.	PIN is required.	PIN required.	Yes	Pass
10	Set a five-digit passcode. iPhone.	Passcode is rejected.	Rejected.	Yes	Pass
11	Set simple passcodes (111111, 123456). iPhone.	Both passcodes are rejected.	Both rejected.	Yes	Pass
12	Set a permitted six-digit passcode. iPhone.	Passcode is accepted.	Accepted.	No	Pass
13	Leave the device idle. iPhone.	Device locks within five minutes.	Locked at five minutes.	Yes	Pass
14	Wake the device 15 seconds after automatic lock. iPhone.	Passcode is required.	Passcode required.	Yes	Pass
15	Lock the device with the side button, then wake it. iPhone.	Passcode is required.	Passcode required.	Yes	Pass

4.7 MDM-TST-007 Contractor Access Revocation

Field	Details
Test ID	MDM-TST-007
Title	Contractor access revocation
Related Risk	MDM-RSK-007
Control or Requirement	MDM-CTL-007; D07 Sections 5.7-5.8 (MDM-STD-032, 033)
Objective	Confirm that contractor access is revoked at the authorized end time, verified as blocked, and escalated when incomplete.
Evidence Used	MDM-EVD-040, 042, 044 to 047
Departure Sample	All three contractor departures in the period (MDM-EVD-044). The population is below the sampling threshold.
Test Account	One test contractor account with a corporate device, registered in MDM-EVD-040 with a sponsor and end time.
Performed By	GRC Analyst. The IT Operations Team performed account and device steps under GRC observation.
Reviewed By	CISO
Test Result	**Not Effective**
Finding Reference	MDM-FND-006

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Check contractor records in MDM-EVD-040.	Each record has a sponsor, accounts, devices, end time with time zone and an approval reference.	All records complete.	Yes	**Pass**
2	Check reminders in MDM-EVD-042 against the reminder rules in D07	Reminders sent one month before expiry, then weekly, without	Correct for the four weeks	No	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	Section 5.7.	duplicates.	available. Earlier runs are past platform retention.		
3	Check offboarding tasks in MDM-EVD-044 for the three departures.	Each task has the end time, an operator and a backup.	All three complete.	No	**Pass**
4	Compare revocation timestamps in MDM-EVD-045 with end times for the three departures.	Account disabled, sessions revoked and permissions removed at or before the end time.	All three on time.	Yes	**Pass**
5	Check access block verification in MDM-EVD-046 for the three departures.	Effective blocking is verified for each. Account status alone is not accepted.	Two verified. One shows account status only.	Yes	**Fail**
6	Check escalation of the incomplete verification in Step 5, using MDM-EVD-047.	The incomplete action is escalated to the IT Operations Manager.	Not escalated.	No	**Fail**
7	At the test end time, disable the test account and revoke sessions. Attempt a new sign-in.	Access is blocked.	Blocked.	Yes	**Pass**
8	Keep an Outlook session open during Step 7. Measure the time until it loses access.	Time is recorded (D08 Section 4.2).	Access lost after 3 minutes.	No	**Pass**
9	Record an early departure for the test account. Revoke at the revised time.	Access is revoked at the revised time.	Revoked at the revised time.	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
10	Set an end time outside working hours, with the primary operator marked absent.	The backup operator revokes access at the end time.	Revoked by the backup on time.	Yes	**Pass**

4.8 MDM-TST-008 Corporate Wipe and BYOD Data Removal

Field	Details
Test ID	MDM-TST-008
Title	Corporate wipe and BYOD data removal
Related Risk	None in D04 (known gap 1)
Control or Requirement	D07 Sections 4.14, 4.15 and 5.9 (MDM-STD-022, 023, 034); NCA ECC 2-6-3-3
Objective	Confirm that corporate data is removed from BYOD apps and corporate devices when required, that removal is verified, and that personal data is preserved.
Evidence Used	MDM-EVD-004, 005, 058 to 061
Record Population	All records in the period: five selective wipe requests (MDM-EVD-058), six corporate wipes (MDM-EVD-059), one reported loss (MDM-EVD-060) and four reassigned devices (MDM-EVD-061). Each population is below the sampling threshold.
Test Devices	One personal Android device and one personal iPhone, with test accounts in MDM-BYOD-Approved. One corporate Android device and one corporate iPhone.
Offline Test Policy	A copy of the production App Protection policy, with Offline grace period = 1 day. Assigned to the test accounts only.
Performed By	GRC Analyst. The IT Operations Team performed device and wipe steps under GRC observation.
Reviewed By	CISO
Test Result	**Not Effective**
Finding Reference	MDM-FND-007

Field	Details

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare offline settings in MDM-EVD-004 and 005 with D07 Section 4.14.	Offline grace period = 90 days, Action = Wipe data. The 1440-minute block is retained.	All values match.	Yes	**Pass**
2	Check the five selective wipe requests in MDM-EVD-058.	Each has a verified target, a request date and per-app completion. Unresolved requests are tracked.	All five complete. No unresolved requests.	Yes	**Pass**
3	Check the six corporate wipes in MDM-EVD-059.	Each has a command date, result and confirmation.	All six confirmed.	Yes	**Pass**
4	Check the four reassigned devices in MDM-EVD-061.	Reset inspected, re-enrolled and compliant before access.	All four complete.	Yes	**Pass**
5	Check the reported loss in MDM-EVD-060.	Wipe issued without waiting for recovery.	Wipe issued on the day of the report.	Yes	**Pass**
6	Check wipe completion for the reported loss.	Wipe completion is confirmed.	No confirmation recorded.	Yes	**Fail**
7	Check follow-up for the unconfirmed wipe.	Kept open with an owner and a follow-up date.	No owner or follow-up date recorded.	No	**Fail**
8	Submit a device-based selective wipe. Personal Android.	Corporate data removed from each app. Personal data preserved.	Removed from all apps. Personal data	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
			preserved.		
9	Submit a user-level selective wipe. Personal iPhone.	Corporate data removed from each app. Personal data preserved.	Removed from all apps. Personal data preserved.	Yes	**Pass**
10	Submit a selective wipe while the device is offline. Reconnect it. Personal Android.	Request stays pending, then completes on reconnection.	Pending, then completed.	No	**Pass**
11	Keep a test app offline past the test period. Fail reauthentication. Both personal devices.	Work account and app data removed. Personal data preserved.	Removed on both platforms. Personal data preserved.	Yes	**Pass**
12	Keep a test app offline past the test period. Reauthenticate successfully. Both personal devices.	Access restored. The offline interval resets.	Restored on both platforms.	No	**Pass**
13	Wipe the corporate Android device. Inspect, re-enroll and check compliance.	Device reset. No previous-user data. Compliant before access.	All conditions met.	Yes	**Pass**
14	Wipe the corporate iPhone. Inspect, re-enroll and check compliance.	Device reset. Activation Lock does not block re-enrollment. Compliant before access.	All conditions met.	Yes	**Pass**

4.9 MDM-TST-009 BYOD Activation Gate and Privacy Notice

Field	Details
Test ID	MDM-TST-009
Title	BYOD activation gate and privacy notice

Field	Details
Related Risk	None in D04 (known gap 1)
Control or Requirement	D07 Section 4.17 (MDM-STD-025); D08 Section 3.2 (group membership)
Objective	Confirm that BYOD is activated only after notice acknowledgment, manager approval and technical checks, and that the notice matches the information the company can see.
Evidence Used	MDM-EVD-009, 062, 063, 064
Membership Population	All members of MDM-BYOD-Approved (MDM-EVD-009), reconciled with activation records (MDM-EVD-063). The check is automated, so no sample is needed.
Record Sample	Ten activation records from MDM-EVD-063, selected by the GRC Analyst.
Test Requests	Four BYOD activation requests from test accounts, on one personal Android device and one personal iPhone.
Performed By	GRC Analyst. The IT Operations Team processed test requests under GRC observation.
Reviewed By	CISO
Test Result	**Partially Effective**
Finding Reference	MDM-FND-008

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Check the notice in MDM-EVD-062 against the content required by D07 Section 4.17.	The notice covers visible information, purposes, access, restrictions, data removal and support contact. Version history exists.	All content present. Version history exists.	Yes	**Pass**
2	Compare information visible in Intune for the	Visible information	Matches on both	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	test accounts with the notice. Both platforms.	matches the notice.	platforms.		
3	Reconcile all MDM-BYOD-Approved members with activation records.	Every member has an activation record.	All members reconciled.	Yes	**Pass**
4	Check the ten sampled records for required fields.	Identity, notice version, acknowledgment time, manager approval, IT Operations verification and activation date are present.	All ten complete.	Yes	**Pass**
5	Compare acknowledgment and approval dates with group addition dates for the ten records.	Both precede the date the user was added to the group.	All ten precede.	Yes	**Pass**
6	Check the notice version in the ten records against MDM-EVD-062.	The version acknowledged was current at the time.	All ten current.	No	**Pass**
7	Check repository permissions in MDM-EVD-064.	Access is limited to authorized roles.	Limited to authorized roles.	No	**Pass**
8	Check the retention setting in MDM-EVD-064.	A retention period is set.	No retention period set.	No	**Fail**
9	Submit a test request without acknowledgment.	Activation is refused.	Refused.	Yes	**Pass**
10	Submit a test request without manager approval.	Activation is refused.	Refused.	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
11	Submit a test request from a device below the BYOD OS minimum.	Activation is refused.	Refused.	Yes	Pass
12	Submit a complete test request.	Activation completed. User added to the group. Access works.	Activated. Added. Access works.	No	Pass

4.10 MDM-TST-010 Mobile Browser Block

Field	Details
Test ID	MDM-TST-010
Title	Mobile browser block
Related Risk	None in D04 (known gap 1)
Control or Requirement	D07 Section 5.10 (MDM-STD-035); MDM-CAP-003; D08 A-03 and L-01
Objective	Confirm that mobile browsers cannot reach corporate services, while approved app sign-in and enrollment flows still work.
Evidence Used	MDM-EVD-065, 066
Test Devices	One personal Android device and one personal iPhone, with test accounts in MDM-BYOD-Approved. One corporate Android device. One corporate iPhone, before ADE enrollment. One corporate iPad.
Performed By	GRC Analyst. The IT Operations Team performed device steps under GRC observation.
Reviewed By	CISO
Test Result	Effective
Finding Reference	None

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-065 with D08 Section 3.3.	Users, exclusions, resources, platforms, client apps and grant match the design. Policy state is On.	All settings match. State is On.	Yes	**Pass**
2	Compare MDM-EVD-066 with D07 Section 5.10.	The six approved apps are assigned with corporate account configuration.	All six assigned and configured.	No	**Pass**
3	Open Outlook on the web in Chrome. Personal Android.	Access is blocked.	Blocked.	Yes	**Pass**
4	Open SharePoint and OneDrive in Safari. Personal iPhone.	Access is blocked.	Blocked.	Yes	**Pass**
5	Open Outlook on the web in Microsoft Edge with App Protection. Corporate Android.	Access is blocked.	Blocked.	Yes	**Pass**
6	Sign in to the Outlook app after Steps 3–5. All three devices.	Access is allowed.	Allowed on all three.	Yes	**Pass**
7	Sign in through an in-app web view in Teams. Check the sign-in log.	Access is allowed. Logged as Mobile apps and desktop clients (A-03).	Allowed. Logged as Mobile apps and desktop clients.	Yes	**Pass**
8	Open a SharePoint document link and an Outlook on the web link from Teams. Personal iPhone.	The document opens in an approved app. The web link is blocked in the browser.	Document opened in OneDrive. Web link blocked.	No	**Pass**
9	Request the desktop site	Access is blocked by	Logged as	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	in Safari and open Outlook on the web. Personal iPhone.	MDM-CAP-003 or by enterprise desktop policies (L-01).	macOS. Blocked by an enterprise desktop policy.		
10	Open Outlook on the web in Safari with default settings. Corporate iPad.	Access is blocked by MDM-CAP-003 or by enterprise desktop policies (L-01).	Logged as macOS. Blocked by an enterprise desktop policy.	Yes	**Pass**
11	Enroll the corporate iPhone through ADE. Sign in to Company Portal and register security information.	All three flows succeed.	All three succeeded.	No	**Pass**

5. Requirements Not Tested

The sample covers all High risks and all risks scored 9 (Section 2.1). The requirements below were not tested. Requirements with a known evidence deficiency in MDM-D09 are carried to MDM-D11. Others are retained for the next test cycle.

Requirement	Related Risk	Reason Not Tested	D09 Evidence	Handling
MDM-CTL-004 Access policy change management	MDM-RSK-004 (6, Medium)	Below the sample threshold.	MDM-EVD-023 Not Provided	Carried to MDM-D11.
MDM-CTL-006 Device report access control	MDM-RSK-006 (6, Medium)	Below the sample threshold. No expansion, per project scope.	MDM-EVD-035 to 039 Accepted	Next test cycle.
MDM-CTL-008 Device compliance report accuracy	MDM-RSK-008 (6, Medium)	Below the sample threshold. No expansion, per project scope.	MDM-EVD-049 to 053 Accepted	Next test cycle.
D07 Sections 4.6–4.13	MDM-RSK-	The sample tested transfer	MDM-EVD-	Next test

Requirement	Related Risk	Reason Not Tested	D09 Evidence	Handling
and 4.16 (MDM-STD-014 to 021, 024) BYOD app-level protections	002	routes (MDM-TST-001) and access (MDM-TST-002). App-level behavior was not tested.	004, 005 Accepted	cycle.
D07 Section 5.1 (MDM-STD-026) Corporate data protection in transit	None in D04 (known gap 1)	Network path not reviewed. A device-side test cannot show proxy or TLS inspection.	MDM-EVD-057 Not Provided	Carried to MDM-D11.
D07 Section 5.2 (MDM-STD-027) Permission and scope behavior	MDM-RSK-005	Assignments were reconciled in MDM-TST-003. Permission behavior was not tested. Priority for the next cycle (High risk).	MDM-EVD-025, 027, 028 Accepted	Next test cycle.
D08 Section 4.5, assumption A-06 (enterprise user MFA)	Enterprise dependency	IAM owner coverage confirmation not provided.	MDM-EVD-069 Partial	Recorded as a gap in MDM-D11, per MDM-D08.

6. Assumptions and Limitations

6.1 Assumptions

ID	Assumption	Affects
TA-01	Test devices and test accounts receive the same policies and assignments as production users.	All device steps
TA-02	Configurations did not change between evidence collection (MDM-D09) and testing.	All configuration comparison steps

6.2 Limitations

ID	Limitation	Affects	Handling
TL-01	No tenant was configured. All results are simulated.	All tests	Marked as simulated (MDM-D08 L-08).
TL-02	Device tests show behavior on the test date only.	All device steps	Period records are tested where available.

ID	Limitation	Affects	Handling
TL-03	Android BYOD encryption cannot be verified directly.	MDM-TST-001, Step 16	The app protection log shows the setting as applied. Not a key step.
TL-04	iOS/iPadOS does not report encryption status at device level.	MDM-TST-005, Step 7	Android status tested. iOS/iPadOS relies on the passcode requirement (Step 11).
TL-05	Integrity failure handling was not tested on a compromised device.	MDM-TST-005	Policy setting checked in Step 1.
TL-06	Power Automate keeps run history for 28 days by default.	MDM-TST-007, Step 2	Reminders tested for the last four weeks only.
TL-07	The 90-day offline period could not be observed during testing.	MDM-TST-008, Steps 11–12	Tested with a one-day test policy. The mechanism was tested, not the 90-day value.
TL-08	IT Operations processed test requests knowing they were tests.	MDM-TST-009, Steps 9–12	Step 5 tests real activation records from the period.
TL-09	Desktop-site protection relies on enterprise policies outside project scope.	MDM-TST-010, Steps 9–10	Observed in sign-in logs only. Not evidenced in MDM-D09.

7. Sources

All Microsoft Learn pages were reviewed on 7 November 2026.

Source	Used In
MDM-D02 Stakeholder and RACI Matrix	2.2
MDM-D04 Risk Assessment Methodology and Risk Register	2.1, 3
MDM-D05 Control Requirements and Framework Crosswalk	3, 4
MDM-D07 MDM Security Standard	3, 4, 5, 6
MDM-D08 Conditional Access Control Design	3, 4, 5, 6
MDM-D09 Evidence Request List and Evidence Index	3, 4, 5
NCA Essential Cybersecurity Controls (ECC-2:2024) - https://cdn.nca.gov.sa/api/files/public/upload/86e09090-44e4-481f-bc28-	3, 4.8

Source	Used In
355673607654_ECC--2024-EN.pdf	
Microsoft Learn: iOS app protection policy settings - https://learn.microsoft.com/en-us/intune/apps/app-protection-policy-settings-ios	4.1
Microsoft Learn: Missing runs or triggers history for a flow - https://learn.microsoft.com/en-us/troubleshoot/power-platform/power-automate/flow-run-issues/missing-runs-or-triggers-history-for-a-flow	4.7, 6

Findings and Remediation Register

MDM-D11

1. Purpose and Scope

This document rates the findings raised in MDM-D10, analyses the gaps behind them and sets the remediation actions. It also records the gaps found outside the test sample.

It covers findings MDM-FND-001 to MDM-FND-008 from the ten tests in MDM-D10. It also covers MDM-FND-009, the requirements in MDM-D07 that have no control in MDM-D05, and items whose evidence was Partial or Not Provided in MDM-D09.

CTL-006, CTL-008, MDM-D07 sections 4.6 to 4.13 and 4.16, and section 5.2 are out of scope. They move to the next testing cycle.

Accepting residual risk is a decision for the Risk Owner named in MDM-D04, not the Control Owner. Items that need that decision are listed in Section 6 and decided in MDM-D12.

No tenant was configured. All findings, ratings and dates are simulated.

2. Method

2.1 Finding Types

Each finding is classified by one question: would the control fail even if it ran exactly as written?

Type	Test Question	Remediation Focus
Design	Would the control miss the requirement even if performed exactly as written?	Change the control design or add a control.
Operating	Is the design sufficient, but the control was not performed as written or there is no evidence that it was?	Perform the control as designed and keep evidence.

2.2 Gap Categories

Category	Basis	Severity
Tested Finding	A test in MDM-D10 failed or was partially effective.	Rated
Confirmed Design Gap	MDM-D05 or MDM-D07 shows that no control or owner exists for a requirement.	Rated
Assurance Gap	The item was not tested and its evidence was Partial or Not Provided in MDM-D09. Its effectiveness is unknown.	Not rated

An Assurance Gap shows the inherent risk level of its linked risk from MDM-D04 for context only. That level is not the gap's severity.

2.3 Severity Rating

Severity uses the Impact and Likelihood scales and the score bands in MDM-D04. It rates the exposure the finding leaves open, not the inherent risk of the linked risk.

Rule	Description
R1 – Scales	Use the MDM-D04 Impact and Likelihood scales and score bands. No other scale is used.
R2 – Impact	Rate what happens if the gap is exploited, limited to the scope it affects, such as iOS only or Android only.
R3 – Likelihood	Rate from the simulated evidence: how often the exception occurred and whether a documented compensating control exists. Limited harm is reflected here, not in the MDM-D10 test result.
R4 – Ceiling	A finding's severity cannot exceed the inherent risk level of its linked risk in MDM-D04.
R5 – Escalation	An Impact score of 5 requires management review, as in MDM-D04.
R6 – Override	Any change to the calculated severity is justified in writing in the register.

2.4 Remediation Timelines

Severity	Remediation Due
Critical	30 days
High	60 days
Medium	90 days
Low	180 days

These timelines are a project convention, not a framework requirement. They run from the date the Control Owner agrees the finding.

3. Findings Register

The register lists every rated item: Tested Findings and Confirmed Design Gaps. Assurance Gaps are listed in Section 4.3 only.

Finding	Title	Category	Test	Control	Risk	Type	Score (I × L)	Severity	Control Owner	Due
MDM-FND-001	iOS Share extension moves corporate files outside managed apps	Tested Finding	MDM-TST-001	MDM-CTL-002	MDM-RSK-002	Design	2 × 4 = 8	Medium	IT Operations Manager	90 days
MDM-FND-002	Noncompliant corporate iPhone reaches OneDrive through the app protection grant	Tested Finding	MDM-TST-002	MDM-CTL-002	MDM-RSK-002	Operating	3 × 3 = 9	Medium	IT Operations Manager	90 days
MDM-FND-003	No record of the CISO review of the IT Operations Manager's administrative access	Tested Finding	MDM-TST-003	MDM-CTL-005	MDM-RSK-005	Operating	3 × 2 = 6	Medium	CISO	90 days

Finding	Title	Category	Test	Control	Risk	Type	Score (I × L)	Severity	Control Owner	Due
MDM-FND-004	Monthly compliance baseline review missing for the first month	Tested Finding	MDM-TST-005	MDM-CTL-003	MDM-RSK-003	Operating	3 × 2 = 6	Medium	IT Operations Manager	90 days
MDM-FND-005	Corporate Android devices unlock without a PIN shortly after automatic screen-off	Tested Finding	MDM-TST-006	MDM-CTL-001	MDM-RSK-001	Design	3 × 2 = 6	Medium	IT Operations Manager	90 days
MDM-FND-006	Contractor access block verified by account status only, and not escalated	Tested Finding	MDM-TST-007	MDM-CTL-007	MDM-RSK-007	Operating	3 × 2 = 6	Medium	IT Operations Manager	90 days
MDM-	Wipe of	Teste	MDM-	None	None	Opera	3 × 2	Medi	IT	90

Finding	Title	Category	Test	Control	Risk	Type	Score (I × L)	Severity	Control Owner	Due
FND-007	a lost device not confirmed, with no owner or follow-up date	d Finding	TST-008	in MDM-D05 (MDM-D07 Section 5.9)	in MDM-D04; rated against MDM-RSK-001	ting	= 6	um	Operations Manager (interim)	days
MDM-FND-008	No retention period set for BYOD activation records	Tested Finding	MDM-TST-009	None in MDM-D05 (MDM-D07 Section 4.17)	None in MDM-D04; rated against MDM-RSK-006	Operating	2 × 2 = 4	Low	IT Operations Manager (interim)	180 days
MDM-FND-009	MDM-D07 requirements on encryption, data removal, the BYOD notice and browser access have no control, owner	Confirmed Design Gap	None (see Section 4.2)	None in MDM-D05	None in MDM-D04; rated against MDM-RSK-001	Design	3 × 2 = 6	Medium	CISO	90 days

Finding	Title	Category	Test	Control	Risk	Type	Score (I × L)	Severity	Control Owner	Due
	or risk									

3.1 Rating Rationale

Finding	Impact	Likelihood
MDM-FND-001	2 – Minor. The file left the managed apps but stayed encrypted and the receiving app could not open it. No confidential content was exposed. The organization loses control of where the copy sits. Scope: iOS BYOD only.	4 – Likely. The Share extension path is open to every iOS BYOD user at all times, with no barrier. Encryption is counted in Impact, not again here.
MDM-FND-002	3 – Moderate. Corporate files in OneDrive remain reachable on a corporate device that failed the compliance baseline. Scope: corporate iOS devices without the OneDrive app configuration.	3 – Possible. The device must first fall out of compliance, which MDM-TST-005 shows does occur. App protection on corporate devices was not tested, so it is not counted as a compensating control.
MDM-FND-003	3 – Moderate. The unreviewed account holds the broadest Intune access in the team. Misuse could weaken security settings across corporate devices, as in MDM-RSK-005. Scope: one account.	2 – Unlikely. The access was approved by the CISO and matches its approved scope (MDM-TST-003, steps 2 and 6). Harm requires that access to become excessive and then be misused before the next review.
MDM-FND-004	3 – Moderate. A stale baseline would let outdated corporate devices count as compliant and reach confidential documents, as in MDM-RSK-003. Scope: all corporate devices.	2 – Unlikely. Automated enforcement and the threshold change process passed (MDM-TST-005, steps 3, 4, 6 and 9), and the later two monthly reviews took place. Harm requires the baseline to fall behind in the missed month and a vulnerable device to be compromised.
MDM-FND-005	3 – Moderate. A person who finds a lost device inside the window	2 – Unlikely. Harm requires the device to be lost and woken by someone else

Finding	Impact	Likelihood
	can open it without a PIN and reach confidential documents, as in MDM-RSK-001. Scope: corporate Android devices only.	inside a short window after screen-off. Strong PINs, the five-minute lock and power-button lock all passed (MDM-TST-006, steps 4–7 and 9). Only a 15-second wake was tested, so the full window length is unknown.
MDM-FND-006	3 – Moderate. If a revocation silently failed, a former contractor could keep viewing or editing confidential team documents, as in MDM-RSK-007. Scope: contractor departures.	2 – Unlikely. All three revocations were completed on time (MDM-TST-007, step 4), and a disabled account lost access in 3 minutes (step 8). Harm requires a revocation to fail and the failure to go unnoticed, which is what verification and escalation should catch.
MDM-FND-007	3 – Moderate. If the wipe never completed, confidential data stays on a lost device, as in MDM-RSK-001. Scope: one lost device.	2 – Unlikely. The wipe was issued on the day of the report (MDM-TST-008, step 5), and wipe capability works on both platforms (steps 8–14). Harm requires the wipe to stay incomplete and the device passcode to be bypassed.
MDM-FND-008	2 – Minor. Activation records hold limited employee data: identity, notice version, acknowledgment time and approvals. Keeping them without limit widens what could be seen if access were misused, as in MDM-RSK-006. Scope: all BYOD users.	2 – Unlikely. Repository access is limited to authorized roles (MDM-TST-009, step 7). Harm requires that restriction to fail or be misused.
MDM-FND-009	3 – Moderate. If a capability stopped working, no owner or review would detect it. The worst case is data left on a lost device, as in MDM-RSK-001, together with a gap against NCA ECC 2-6-3-3. Scope: four requirement areas.	2 – Unlikely. Three of the four areas worked when tested (MDM-TST-001, 005 and 008 to 010). Harm requires a capability to degrade and the change to go unnoticed. Encryption in transit is unverified and is not counted here (Section 4.3).

MDM-FND-007 and MDM-FND-008 have no linked risk in MDM-D04 and no control in MDM-D05 (known gap 1). Each is rated against the closest risk with a matching scenario, which also

sets its ceiling: MDM-RSK-001 for FND-007 and MDM-RSK-006 for FND-008. The IT Operations Manager owns both until a control and owner are defined (Section 4.2).

No rating exceeds the ceiling set by its linked or closest risk. If evidence shows the FND-001 copy can be read outside managed apps, its Impact is re-rated to 3.

For MDM-FND-003, the CISO owns the control and also performs the missed review. Closure is therefore validated by Internal Audit, not by the CISO.

4. Gap Analysis

4.1 Tested Findings

Each row traces one tested finding from what was observed to the risk it leaves open. Current State is taken from the MDM-D10 test steps. Required is taken from MDM-D05, MDM-D07 or MDM-D08.

Finding	Current State	Required	Gap	Resulting Risk
MDM-FND-001	On iOS BYOD, the Share extension moves corporate files to unmanaged apps. The files stay encrypted. Other transfer paths are blocked (MDM-TST-001, step 14).	Corporate files remain in approved apps and storage. Transfers to unapproved apps are restricted (MDM-D07 Section 4.4; MDM-CTL-002).	The App Protection setting cannot block this path on unenrolled iOS devices. No alternative control is defined.	MDM-RSK-002: encrypted copies leave organizational control. Medium (8).
MDM-FND-002	A noncompliant corporate iPhone reaches OneDrive through the app protection grant. The OneDrive app configuration does not exist (MDM-TST-002, steps 11–12; MDM-EVD-007).	Noncompliant corporate devices are blocked from corporate services (MDM-D08 A-01; MDM-CTL-002).	The required app configuration was not deployed, so the compliance requirement can be bypassed in OneDrive.	MDM-RSK-002: corporate files reachable on a device that failed the baseline. Medium (9).
MDM-FND-003	The IT Operations Manager's access has no recorded CISO review. Team access reviews are complete	The CISO reviews the manager's access at least every three	The review was not performed or not recorded.	MDM-RSK-005: the broadest administrative account runs without

Finding	Current State	Required	Gap	Resulting Risk
	(MDM-TST-003, step 9; MDM-EVD-030).	months, with the reviewer and decision recorded (MDM-CTL-005; MDM-D07 Section 5.4).		independent review. Medium (6).
MDM-FND-004	Two monthly baseline reviews exist. The first month is missing. Automated enforcement works (MDM-TST-005, step 5; MDM-EVD-014).	One baseline review each month (MDM-CTL-003; MDM-D07 Sections 3.3–3.8).	One monthly review was not performed.	MDM-RSK-003: a stale baseline could let outdated devices count as compliant. Medium (6).
MDM-FND-005	Corporate Android devices unlock without a PIN 15 seconds after automatic screen-off. No approved immediate-lock configuration exists (MDM-TST-006, steps 3 and 8; MDM-EVD-002).	Authentication is required immediately after the device locks (MDM-D07 Section 3.1; MDM-CTL-001).	The standard sets the requirement but defines no Android configuration to meet it.	MDM-RSK-001: a lost device can be opened inside the grace window. Medium (6).
MDM-FND-006	One of three contractor departures was verified by account status only, and was not escalated (MDM-TST-007, steps 5–6; MDM-EVD-046, 047).	Effective blocking is verified for each departure. Account status alone is not accepted. Incomplete actions are escalated to the IT Operations Manager (MDM-D07 Sections 5.7–5.8; MDM-CTL-	Verification and escalation were not performed as required.	MDM-RSK-007: a failed revocation could go unnoticed. Medium (6).

Finding	Current State	Required	Gap	Resulting Risk
		007).		
MDM-FND-007	The wipe of a lost device was issued on the day of the report, but completion was not confirmed. No owner or follow-up date was recorded (MDM-TST-008, steps 6–7; MDM-EVD-060).	An unconfirmed wipe stays open with an owner and a follow-up date (MDM-D07 Section 5.9).	Confirmation and follow-up were not performed. The requirement has no control in MDM-D05.	Closest risk MDM-RSK-001: data may remain on a lost device. Medium (6).
MDM-FND-008	Activation records are complete and access is restricted, but no retention period is set (MDM-TST-009, step 8; MDM-EVD-064).	The retention period is confirmed before operational use (MDM-D07 Section 4.17).	BYOD activation went live before the retention period was confirmed. The requirement has no control in MDM-D05.	Closest risk MDM-RSK-006: employee data kept without limit. Low (4).

4.2 Confirmed Design Gaps

MDM-FND-009 records one root cause: MDM-D05 was not updated when MDM-D07 added requirements traced only to MDM-D06. These requirements have no control, no Control Owner and no risk in MDM-D04. One finding covers all four areas because they share that cause.

Area	Current State	Required	Gap	Resulting Risk
Encryption	Encryption at rest works on corporate devices and in BYOD apps (MDM-TST-001, step 16; MDM-TST-005, step 7). Encryption in transit is unverified (Section 4.3).	MDM-D07 encryption requirements, including Section 5.1 for data in transit.	No control in MDM-D05, no owner and no linked risk.	Loss of encryption could go undetected.
Data removal	Selective and full wipe work on both platforms (MDM-TST-008).	MDM-D07 Sections 4.14, 4.15 and 5.9.	No control in MDM-D05, no owner and no	Data may remain on lost or

Area	Current State	Required	Gap	Resulting Risk
	Confirmation of a lost-device wipe was not followed up (MDM-FND-007).	NCA ECC 2-6-3-3.	linked risk. The ECC requirement is met technically but has no assigned accountability.	departed devices (closest: MDM-RSK-001, MDM-RSK-007).
BYOD notice	The notice, activation gate and records work (MDM-TST-009). No retention period is set (MDM-FND-008).	MDM-D07 Section 4.17.	No control in MDM-D05, no owner and no linked risk.	Employee data handled without a defined owner (closest: MDM-RSK-006).
Browser access	Mobile browser access is blocked, and approved apps still work (MDM-TST-010, Effective).	MDM-D06 browser prohibition; MDM-D08 Section 3.3 (MDM-CAP-003).	No control in MDM-D05 and no linked risk. The block runs as a Conditional Access policy without a control record.	Changes to the block could go unreviewed.

The technical capabilities work in the simulation. The gap is governance: no one is accountable for keeping them working, and no risk tracks them.

4.3 Assurance Gaps

These items were not tested, and their evidence in MDM-D09 was Partial or Not Provided. Their effectiveness is unknown, so they are not rated. The linked risk level is shown for context only.

Item	Evidence Status	Why Not Rated	Linked Risk (context only)	Next Step	Owner
MDM-CTL-004 Access policy change management	MDM-EVD-023 Not Provided	Not in the test sample, and no evidence to review.	MDM-RSK-004, Medium (6)	Provide MDM-EVD-023 and test the control in the next cycle.	IT Operations Manager
Corporate	MDM-	The network path	None in	Provide MDM-	IT

Item	Evidence Status	Why Not Rated	Linked Risk (context only)	Next Step	Owner
data protection in transit (MDM-D07 Section 5.1)	EVD-057 Not Provided	was not reviewed. A device-side test cannot show proxy or TLS inspection.	MDM-D04 (part of MDM-FND-009)	EVD-057 and review the network path.	Operations Manager
Enterprise user MFA (MDM-D08 Section 4.5, assumption A-06)	MDM-EVD-069 Partial	The IAM owner did not confirm MFA coverage. The design depends on it but does not control it.	Enterprise dependency, no risk in MDM-D04	Obtain written coverage confirmation from the IAM owner. If coverage is incomplete, raise a finding.	CISO, with the IAM owner

Items deferred in MDM-D10 Section 5 with Accepted evidence are not listed here. They are out of the test sample, not evidence gaps, and move to the next test cycle: MDM-CTL-006, MDM-CTL-008, MDM-D07 Sections 4.6 to 4.13 and 4.16, and Section 5.2 (priority).

5. Recommendations

Each recommendation answers one finding or gap. Design findings need a design change. Operating findings need the control performed as written, with evidence. Due dates follow Section 2.4 and run from the date the owner agrees the finding. Every success indicator is checked by retest in MDM-D12.

5.1 Findings

Rec	Finding	Action	Owner	Due	Success Indicator
MDM-REC-001	MDM-FND-001 (Medium, 8)	Record the iOS Share extension path as a platform constraint in MDM-D07 Section 4.4. State that encryption is the protection that still applies. Submit the remaining exposure to the Business Owner to accept it or to require a different iOS BYOD access model.	IT Operations Manager; decision by the Business Owner	90 days	The constraint is documented, and the Business Owner's decision is recorded in MDM-D12. A retest confirms that shared files still cannot be opened outside managed apps.

Rec	Finding	Action	Owner	Due	Success Indicator
MDM-REC-002	MDM-FND-002 (Medium, 9)	Deploy the OneDrive app configuration required by MDM-D08 to corporate iOS devices and provide MDM-EVD-007. Check the other five approved apps for the same bypass.	IT Operations Manager	90 days	A noncompliant corporate iPhone is blocked in OneDrive and in the other approved apps (MDM-TST-002, steps 11–12 repeated).
MDM-REC-003	MDM-FND-003 (Medium, 6)	Perform and record the CISO review of the IT Operations Manager's access. Add the manager's access as a separate line in the quarterly review record.	CISO	90 days	The next two quarterly reviews show a recorded CISO decision for the manager's access. Internal Audit validates closure.
MDM-REC-004	MDM-FND-004 (Medium, 6)	Perform the current monthly baseline review. Schedule each review as a recurring task with a named backup reviewer.	IT Operations Manager	90 days	Three consecutive monthly reviews are recorded in MDM-EVD-014.
MDM-REC-005	MDM-FND-005 (Medium, 6)	Define and approve an immediate-lock configuration for each approved Android model and record it in MDM-EVD-002. Measure the unlock window after screen-off. If a model cannot enforce immediate lock, record it as a constraint and set the shortest supported value.	IT Operations Manager	90 days	MDM-EVD-002 lists a configuration per model. A retest shows a PIN is required on wake after screen-off, with the window measured.
MDM-REC-006	MDM-FND-006 (Medium, 6)	Confirm that access is blocked for the departure verified by account status only. Add sign-in failure evidence as a required	IT Operations Manager	90 days	Every contractor departure in the next 90 days has effective-block evidence. Any

Rec	Finding	Action	Owner	Due	Success Indicator
		field in the offboarding record.			incomplete action is escalated as MDM-D07 Section 5.8 requires.
MDM-REC-007	MDM-FND-007 (Medium, 6)	Confirm the wipe status of the lost device now. If it is still unconfirmed, keep it open with an owner and a follow-up date. Add confirmation, owner and follow-up date as required fields in the loss record.	IT Operations Manager (interim)	90 days	The lost-device record shows confirmation or active tracking. Every new loss record has the three fields completed.
MDM-REC-008	MDM-FND-008 (Low, 4)	Set a retention period for BYOD activation records with the data owner and legal or privacy input. Configure it in the repository and remove records past the period.	IT Operations Manager (interim)	180 days	The retention period is approved and configured, with evidence added to MDM-EVD-064.
MDM-REC-009	MDM-FND-009 (Medium, 6)	In the next revision of MDM-D05, add controls for encryption, data removal, the BYOD notice and browser access. Assign a Control Owner to each and link each to a risk in MDM-D04, new or existing. Map data removal to NCA ECC 2-6-3-3 in the crosswalk.	CISO; GRC Analyst prepares the draft	90 days	Each of the four areas has a control ID, an owner and a linked risk in MDM-D05. The next test plan includes them. Owners named in MDM-REC-007 and 008 move to the new control owners.

5.2 Assurance Gaps

Rec	Gap	Action	Owner	Due	Success Indicator
MDM-	MDM-CTL-	Provide MDM-EVD-	IT	90 days	MDM-EVD-023 is

Rec	Gap	Action	Owner	Due	Success Indicator
REC-010	004 (MDM-EVD-023 Not Provided)	023 and include MDM-CTL-004 in the next test sample.	Operations Manager		Accepted in MDM-D09, and the control has a test result.
MDM-REC-011	Encryption in transit (MDM-EVD-057 Not Provided)	Provide MDM-EVD-057 and review the network path for proxy or TLS inspection.	IT Operations Manager	90 days	MDM-EVD-057 is Accepted, and the review result is recorded.
MDM-REC-012	Enterprise user MFA, A-06 (MDM-EVD-069 Partial)	Obtain written confirmation of MFA coverage from the IAM owner.	CISO, with the IAM owner	90 days	Written confirmation is filed in MDM-EVD-069. If coverage is incomplete, a finding is raised.

Assurance gaps have no severity. They take the 90-day timeline so they are resolved before the next test cycle.

5.3 Priority

Work starts with the highest scores: MDM-REC-002 (9), then MDM-REC-001 (8). The six Medium findings scored 6 follow, then MDM-REC-008 (Low). MDM-REC-009 runs alongside the others because it fixes the root cause behind MDM-FND-007 and 008.

6. Items for Risk Owner Decision

Four items need a decision that only the Risk Owner can make. The Control Owner supplies the facts and the options. The decision and its date are recorded in MDM-D12. No finding has an Impact score of 5, so no item needs mandatory management review under rule R5.

Item	Risk	Risk Owner	Facts	Options	GRC View
D-01: Access window after loss of compliance (L-02)	MDM-RSK-003, Medium (9)	Business Owner	An open session kept access for 6 hours 10 minutes after the device became noncompliant, until token renewal (MDM-TST-005, step 17). This is within the 28-hour bound in MDM-D08 Section 4.2. After an account was disabled,	1. Accept the window up to the 28-hour bound. 2. Ask IT Operations to assess options to shorten it,	The window is within the designed bound, so it is not a finding. Its length differs sharply from account revocation. Option 2 is

Item	Risk	Risk Owner	Facts	Options	GRC View
			access ended in 3 minutes (MDM-TST-007, step 8).	then decide.	advised before accepting, so the decision rests on known alternatives.
D-02: iOS Share extension exposure (MDM-FND-001, MDM-REC-001)	MDM-RSK-002, High (12)	Business Owner	Encrypted corporate files can be moved to unmanaged apps on iOS BYOD. The receiving app could not open them (MDM-TST-001, step 14). App Protection cannot block this path on unenrolled devices (MDM-D07 Section 4.4).	1. Accept the exposure, with encryption as the protection that applies. 2. Require a different access model for iOS BYOD.	Option 1 is reasonable while files stay unreadable. If evidence shows a copy can be read outside managed apps, the finding is re-rated and the decision is revisited.
D-03: Android immediate lock, if a model cannot enforce it (MDM-FND-005, MDM-REC-005)	MDM-RSK-001, Medium (9)	Business Owner	Corporate Android devices unlocked without a PIN 15 seconds after screen-off (MDM-TST-006, step 8). The full window is not yet measured.	Decided only if MDM-REC-005 finds a model that cannot enforce immediate lock: 1. Accept the measured window for that model. 2. Remove the model from the approved	No decision is needed until the window is measured.

Item	Risk	Risk Owner	Facts	Options	GRC View
				list.	
D-04: BYOD without MDM enrollment, against SAMA CSF 3.3.10 consideration 4(e)	MDM-RSK-002, High (12)	Business Owner; the CISO advises	Consideration 4(e) expects the BYOD standard to cover MDM, access controls on the device and the business container, and encryption on the personal device for transmission and storage. Personal devices are not enrolled by design (MDM-D07 Section 4.4). Container access controls and encryption at rest are applied and tested (MDM-TST-001, steps 15–16). Encryption in transit is unverified (MDM-REC-011). MDM-D05 maps MDM-CTL-002 to considerations 4(c) and 4(d) only.	1. Accept the deviation, with app-level controls as the alternative, and record the rationale in the MDM-D05 crosswalk. 2. Require MDM enrollment for BYOD, with the privacy impact that brings.	Option 1 is defensible because the container controls serve the objective of protecting data in transmission and storage. It should be accepted only after MDM-REC-011 confirms encryption in transit. The deviation must be documented, not left implicit.

The Current Residual Risk field in MDM-D04 is not changed here. It is updated in MDM-D12 from the MDM-D10 results and these decisions.

7. Assumptions and Limitations

7.1 Assumptions

ID	Assumption
AS-01	The MDM-D10 results reflect how the controls operate across the period, not only on the test date.
AS-02	The MDM-D04 Impact and Likelihood scales apply to findings as well as to risks.
AS-03	Where a finding has no linked risk, the closest MDM-D04 risk with a matching

ID	Assumption
	scenario is a fair basis for its rating and ceiling.
AS-04	Owners agree each finding promptly, so due dates start soon after this register is issued.

7.2 Limitations

ID	Limitation
LM-01	No tenant was configured. All findings, ratings and dates are simulated.
LM-02	Ratings rely on MDM-D04 scales, which do not cover regulatory impact. Regulatory exposure, such as under NCA ECC, is noted but not scored.
LM-03	Likelihood is judged from a small sample. Most populations were below the sampling threshold and were tested in full.
LM-04	Assurance Gaps are not rated, so the register may understate exposure in those areas until they are tested.
LM-05	Some values are not yet measured: the Android unlock window (MDM-FND-005) and whether shared iOS files can be read outside managed apps (MDM-FND-001). Ratings may change after retest.
LM-06	Items deferred in MDM-D10 Section 5 were not assessed and are not reflected in this register.

8. Sources

Platform behavior is cited through the project documents that reviewed it, mainly MDM-D07 and MDM-D08. The only new external page is SAMA CSF 3.3.10, reviewed on 7 November 2026.

Source	Used In
MDM-D04 Risk Assessment Methodology and Risk Register	2.3, 3, 4, 5, 6
MDM-D05 Control Requirements and Framework Crosswalk	3, 4, 5
MDM-D06 Mobile Device and BYOD Policy	4.2
MDM-D07 MDM Security Standard	3, 4, 5, 6
MDM-D08 Conditional Access Control Design	4, 5, 6
MDM-D09 Evidence Request List and Evidence Index	4, 5
MDM-D10 Control Testing Workbook	1, 3, 4, 5, 6

Source	Used In
NCA Essential Cybersecurity Controls (ECC-2:2024) - https://cdn.nca.gov.sa/api/files/public/upload/86e09090-44e4-481f-bc28-355673607654_ECC--2024-EN.pdf	3.1, 4.2, 5
SAMA Cyber Security Framework, 3.3.10 Bring Your Own Device (BYOD) - https://rulebook.sama.gov.sa/en/node/3943	6

Risk Treatment and Retesting Record

MDM-D12

1. Purpose and Scope

This document records the Risk Owner decisions on the items raised in MDM-D11. It updates the current residual risk for each risk in MDM-D04 and sets how and when each recommendation is retested.

It covers the four decisions in MDM-D11 Section 6 (D-01 to D-04), the eight risks MDM-RSK-001 to MDM-RSK-008, and the twelve recommendations MDM-REC-001 to MDM-REC-012.

Residual risk is assessed and justified here. In MDM-D04, only the Current Residual Risk and Target Residual Risk fields are updated, with the value and a reference to this document. The MDM-D04 method and other fields do not change.

Risk Owners decide treatment and accept residual risk. GRC records the decisions and the facts behind them, and plans the retests. Closure of MDM-FND-003 is verified by Internal Audit, not the CISO.

MDM-CTL-006, MDM-CTL-008 and the MDM-D07 requirements outside the MDM-D10 sample are not covered. They belong to the next testing cycle.

No tenant was configured. All decisions, dates, residual ratings and retest results are simulated.

2. Method

2.1 Residual Risk Rules

Current residual risk uses the MDM-D04 scales and score bands. Each finding in MDM-D11 is already rated on the risk it leaves open, so its score is used as the residual measure.

Rule	Description
RR1 – Credit	Only tested evidence reduces risk. A path counts as treated when a key step that covers it passed in MDM-D10, even if the test as a whole is Not Effective. Paths that failed or were not tested get no credit. Planned controls do not reduce risk, as in MDM-D04.
RR2 – Score	Current residual is the highest score among open findings linked to or rated against the risk. It cannot exceed the inherent score.
RR3 – Untested	A risk whose controls were not tested stays Not assessed. A finding rated against it does not make it assessed.
RR4 – Acceptance	Accepting a risk does not lower its score. It changes the treatment status only.
RR5 – Provisional	A residual that relies on an untested item from MDM-D11

Rule	Description
	Section 4.3 is marked provisional until the related recommendation is retested.
RR6 – Target	Target residual is the expected score once the open recommendations close. The Risk Owner approves it, and it holds only after a passed retest.

RR2 assumes the other tested controls work and that separate findings do not add up. Where findings on the same risk would raise the likelihood of one scenario together, the residual is raised and the reason is written in Section 4, as in MDM-D11 rule R6.

2.2 Treatment Options

Option	Meaning
Mitigate	Apply or fix controls through the MDM-D11 recommendations.
Accept	Keep the risk at its current level, with a recorded rationale and a review trigger.
Avoid	Stop the activity that creates the risk, such as removing a device model from the approved list.
Transfer	Share the risk with a third party. Not used in this case study.

Each decision records the option, the Risk Owner, the date, any condition and what would reopen it. Decisions are shown with the inherent risk level, not the residual.

2.3 Retest Rules

Rule	Description
Trigger	The Control Owner reports the recommendation complete.
Timing	Retest is done before the finding's due date. Due dates run from the date the Control Owner agreed the finding (MDM-D11 Section 2.4).
Tester	The GRC Analyst retests. The Control Owner does not retest their own control. MDM-FND-003 is retested by Internal Audit.
Evidence	Evidence meets the MDM-D09 standards and is indexed there.
Pass	The success indicator in the recommendation is met. The finding closes and the residual is updated in Section 4.
Fail	The finding stays open and is re-rated with the MDM-D11 rules. The due date does not change. An overdue finding is reported to the Risk Owner.

3. Risk Owner Decisions

The Business Owner decided the four items in MDM-D11 Section 6 on 16 November 2026. Two are accepted, one with a condition still open. One awaits an assessment and one is not yet needed. Risk levels are inherent, as in Section 2.2.

Item	Risk	Decision	Treatment	Condition	Reopens When
D-01: Access window after loss of compliance (L-02)	MDM-RSK-003, Medium (9)	Option 2. IT Operations assesses ways to shorten the window before the Business Owner decides.	Mitigate, decision pending	Until the decision, the window stays within the 28-hour bound in MDM-D08 Section 4.2.	The IT Operations assessment is received. The Business Owner then accepts the window or approves a change.
D-02: iOS Share extension exposure (MDM-FND-001, MDM-REC-001)	MDM-RSK-002, High (12)	Option 1. The exposure is accepted, with encryption as the protection that applies.	Accept	Shared files cannot be opened outside managed apps, confirmed by the MDM-REC-001 retest.	A copy is shown to be readable outside managed apps, or the MDM-REC-001 retest fails (Section 6).
D-03: Android immediate lock (MDM-FND-005, MDM-REC-005)	MDM-RSK-001, Medium (9)	Not decided. No decision is needed until MDM-REC-005 measures the window.	Mitigate through MDM-REC-005	None	MDM-REC-005 finds a model that cannot enforce immediate lock. The Business Owner then accepts that model's measured window or removes the model.
D-04: BYOD without MDM enrollment, against SAMA CSF	MDM-RSK-002, High (12)	Option 1, conditional. The deviation is accepted, with app-level controls as the	Accept, not yet effective	Takes effect when MDM-REC-011 confirms encryption in transit. The	The MDM-REC-011 review fails. The decision then returns to the Business Owner.

Item	Risk	Decision	Treatment	Condition	Reopens When
3.3.10 consideration 4(e)		alternative. The CISO advised in favour.		rationale is added to the MDM-D05 crosswalk in its next revision, with MDM-REC-009.	

MDM-RSK-002 carries two accepted items and one finding under remediation (MDM-FND-002). Its treatment is mixed: Accept for D-02 and D-04, Mitigate for MDM-REC-002.

4. Residual Risk Update

Five of the eight risks were assessed, and all five now sit at Medium. The two High risks, MDM-RSK-002 and MDM-RSK-005, fall to Medium (9) and Medium (6). The three risks scored 6 stay Not assessed because their controls were not tested.

Risk	Inherent	Tests	Open Findings	Current Residual	Target Residual	Treatment
MDM-RSK-002	**High (12)**	MDM-TST-001, 002	MDM-FND-001 (8), MDM-FND-002 (9)	**Medium (9), provisional**	**Medium (8)**	Mitigate and Accept (D-02, D-04)
MDM-RSK-005	**High (12)**	MDM-TST-003, 004	MDM-FND-003 (6)	**Medium (6)**	**Low (3)**	Mitigate
MDM-RSK-001	**Medium (9)**	MDM-TST-006, 008	MDM-FND-005, 007, 009 (6 each)	**Medium (6)**	**Low (3)**	Mitigate (D-03 pending)
MDM-RSK-003	**Medium (9)**	MDM-TST-005	MDM-FND-004 (6)	**Medium (6)**	**Medium (6) until D-01 is decided**	Mitigate (D-01 pending)
MDM-RSK-007	**Medium (9)**	MDM-TST-007	MDM-FND-006 (6)	**Medium (6)**	**Low (3)**	Mitigate
MDM-RSK-004	**Medium (6)**	None	None	**Not assessed**	**Not set**	Test MDM-CTL-004 (MDM-REC-010)

Risk	Inherent	Tests	Open Findings	Current Residual	Target Residual	Treatment
MDM-RSK-006	Medium (6)	None for MDM-CTL-006	MDM-FND-008 (4), rated against it	Not assessed	Not set	Next test cycle
MDM-RSK-008	Medium (6)	None	None	Not assessed	Not set	Next test cycle

Notes on the ratings

- MDM-CTL-002 is rated Not Implemented in MDM-D13 because both of its tests were Not Effective. The fall of MDM-RSK-002 from High (12) to Medium (9) is credited to the transfer paths that passed (MDM-TST-001, key steps 5, 6, 8 and 10–13), not to the control as a whole (RR1). The two paths that failed are scored as MDM-FND-001 and MDM-FND-002.
- MDM-RSK-002 takes the higher of its two findings (RR2). The two findings affect different devices through different paths, so together they do not raise the likelihood of one scenario. The rating is provisional until MDM-REC-011 confirms encryption in transit (RR5). App-level protections in MDM-D07 Sections 4.6–4.13 and 4.16 were not tested, so the rating covers the tested paths only.
- MDM-RSK-002 cannot go below Medium (8) while D-02 stands. The accepted Share extension exposure keeps the MDM-FND-001 score after MDM-REC-002 closes.
- MDM-RSK-005 covers the tested scope only. Permission and scope behavior in MDM-D07 Section 5.2 was not tested and is a priority for the next cycle.
- MDM-RSK-001 relies on the MDM-REC-005 measurement. If D-03 accepts a measured window for a model, the target is reset with that window.
- MDM-RSK-003 keeps a Medium target while the D-01 window is undecided. Once D-01 is decided, the target is reset.
- The Low targets keep inherent Impact and set Likelihood to 1 – Rare, on the basis that every tested control works and every finding is closed. Each Risk Owner approved the targets on 16 November 2026. They hold only after a passed retest (RR6).

MDM-D04 Current Residual Risk and Target Residual Risk fields were updated with these values and a reference to this section. Earlier values (Not assessed) are kept here for traceability.

5. Retesting Plan

All twelve recommendations are planned for retest. Eleven are due by 14 February 2027 and one by 15 May 2027. The Control Owners agreed the findings on 16 November 2026, and the due dates follow MDM-D11 Section 2.4. No retest has been performed yet.

Rec	Item	Retest Method	Tester	Retest By
MDM-REC-001	MDM-FND-001	Repeat MDM-TST-001 step 14 and confirm the shared file	GRC Analyst	14 February

Rec	Item	Retest Method	Tester	Retest By
		cannot be opened outside managed apps. Confirm the constraint is recorded in MDM-D07 Section 4.4.		2027
MDM-REC-002	MDM-FND-002	Repeat MDM-TST-002 steps 11–12 with a noncompliant corporate iPhone in OneDrive and the other five approved apps. Inspect MDM-EVD-007.	GRC Analyst	14 February 2027
MDM-REC-003	MDM-FND-003	Inspect the quarterly review record for a CISO decision on the IT Operations Manager's access.	Internal Audit	14 February 2027 for the first review; closure after the second
MDM-REC-004	MDM-FND-004	Inspect MDM-EVD-014 for three consecutive monthly reviews, the recurring task and the named backup reviewer.	GRC Analyst	14 February 2027
MDM-REC-005	MDM-FND-005	Inspect MDM-EVD-002 for a configuration per approved Android model. Repeat MDM-TST-006 step 8 on each model and measure the unlock window.	GRC Analyst	14 February 2027
MDM-REC-006	MDM-FND-006	Inspect every contractor departure in the period for sign-in failure evidence, and any incomplete action for escalation under MDM-D07 Section 5.8.	GRC Analyst	14 February 2027
MDM-REC-007	MDM-FND-007	Inspect the lost-device record for wipe confirmation or active tracking. Inspect every new loss record for confirmation, owner	GRC Analyst	14 February 2027

Rec	Item	Retest Method	Tester	Retest By
		and follow-up date.		
MDM-REC-008	MDM-FND-008	Inspect the approved retention period and its repository setting. Check that no activation record past the period remains.	GRC Analyst	15 May 2027
MDM-REC-009	MDM-FND-009	Inspect the revised MDM-D05 for the four controls, each with an ID, owner and linked risk, the NCA ECC 2-6-3-3 mapping and the D-04 rationale.	Internal Audit	14 February 2027
MDM-REC-010	MDM-CTL-004	Confirm MDM-EVD-023 is Accepted in MDM-D09, then test MDM-CTL-004 with a new procedure in MDM-D10.	GRC Analyst	14 February 2027
MDM-REC-011	Encryption in transit	Confirm MDM-EVD-057 is Accepted and the network path review is recorded.	GRC Analyst	14 February 2027
MDM-REC-012	A-06, enterprise user MFA	Confirm the IAM owner's written confirmation is filed in MDM-EVD-069. Raise a finding if coverage is incomplete.	GRC Analyst	14 February 2027

Notes on the plan

- Internal Audit retests MDM-REC-009 because the GRC Analyst prepares the MDM-D05 draft. GRC does not verify its own work.
- MDM-REC-003, 004 and 006 have success indicators that run over time. The retest checks what exists by the due date. MDM-REC-003 closes only after the second quarterly review is recorded.
- The MDM-REC-005 result decides D-03 and may trigger a re-rating of MDM-FND-005 (Section 6).
- The MDM-REC-011 result decides whether D-04 takes effect and whether the MDM-RSK-002 rating stays provisional.
- MDM-REC-010 brings MDM-RSK-004 into assessment. Its residual is rated in Section 4 once the test is done.

6. Re-rating Triggers

Six events reopen a rating or a decision. When one occurs, the finding is re-rated with the MDM-D11 rules, Section 4 is updated, and the Risk Owner is informed. A new due date applies

only when the severity rises. It runs from the date the Control Owner agrees the re-rated finding, and it can only be earlier than the current one.

Trigger	Affects	Action
A shared copy can be read outside managed apps (MDM-REC-001 retest or other evidence).	MDM-FND-001, D-02, MDM-RSK-002	Impact rises to 3. MDM-FND-001 becomes 3 × 4 = 12, High, at the MDM-RSK-002 ceiling. D-02 returns to the Business Owner. MDM-RSK-002 current residual becomes High (12).
The Android unlock window exceeds one minute on any approved model (MDM-REC-005).	MDM-FND-005, D-03, MDM-RSK-001	MDM-FND-005 Likelihood is re-rated. D-03 goes to the Business Owner for that model.
Encryption in transit is not confirmed, or the network path review finds an issue (MDM-REC-011).	D-04, MDM-RSK-002	D-04 does not take effect and returns to the Business Owner. A finding is raised and rated against MDM-RSK-002.
Enterprise user MFA coverage is incomplete (MDM-REC-012).	Assumption A-06	A finding is raised and rated with the MDM-D11 rules.
The Business Owner decides D-01.	MDM-RSK-003	The target residual is reset from the decision.
A retest fails (Section 2.3).	The related finding and risk	The finding stays open and is re-rated. The due date does not change.

Assessing an untested risk is not a re-rating. MDM-RSK-004, 006 and 008 are rated in Section 4 when their controls are first tested.

7. Assumptions and Limitations

7.1 Assumptions

ID	Assumption
AS-01	A finding score in MDM-D11 is a fair measure of the risk it leaves open, so it can stand as the residual score (RR2).
AS-02	Controls tested effective in MDM-D10 keep operating until the retest.
AS-03	Separate findings on one risk affect different paths and do not add up, unless Section 4 says otherwise.
AS-04	Risk Owners act on the decisions in Section 3 and the triggers in Section 6

ID	Assumption
	when they occur.

7.2 Limitations

ID	Limitation
LM-01	No tenant was configured. All decisions, dates, residual ratings and retest plans are simulated.
LM-02	Residual ratings cover the tested scope only. App-level protections in MDM-D07 Sections 4.6–4.13 and 4.16, and permission behavior in Section 5.2, were not tested.
LM-03	MDM-RSK-004, 006 and 008 are not assessed. The overall residual picture is incomplete until they are tested.
LM-04	Target residuals are expectations, not results. They hold only after a passed retest.
LM-05	The MDM-RSK-002 rating is provisional until MDM-REC-011 is retested.
LM-06	No retest has been performed. This record will be updated with results by 15 May 2027.

GRC Workspace and Readiness Dashboard

MDM-D13

1. Purpose and Scope

This document shows where the MDM case study stands, and how its records link together. It adds no new risk ratings or Risk Owner decisions. Its only new judgements are the control readiness ratings that MDM-D10 assigns to this document, and the overall readiness status. Both follow fixed rules in Section 3. Every figure in it comes from MDM-D04 and MDM-D09 to MDM-D12, with a reference to the section it came from.

It has two parts. The workspace part sets out the registers, how their IDs link, and who updates each one. The dashboard part defines the readiness measures and reports them as at 16 November 2026, the date of the Risk Owner decisions in MDM-D12.

The dashboard is a reporting view, not a source. Where it differs from a source document, the source is correct and the dashboard is fixed.

MDM-D13 feeds MDM-D14. The overall readiness status in Section 4 is the starting point for the executive report.

MDM-CTL-006, MDM-CTL-008 and the MDM-D07 requirements outside the MDM-D10 sample were not tested, as stated in MDM-D12. The dashboard shows them as coverage gaps so they are not read as passed.

No tenant was configured and no dashboard tool was built. The dashboard is a document view, and all values are simulated.

Structure

Section	Content	Main Sources
1. Purpose and Scope	Purpose, scope and structure of this document	None
2. Workspace Structure	Registers and ID scheme, the traceability chain from asset to decision, and update rules	MDM-D03 to MDM-D12
3. Readiness Measures	Each measure with its calculation, source and thresholds, and the rules for control readiness and the overall readiness status	MDM-D04, MDM-D09 to MDM-D12
4. Readiness Snapshot	The overall status as at 16 November 2026, the measures, control readiness, open decisions, milestones and items for attention	MDM-D09 to MDM-D12
5. Reporting and Escalation	Who receives the dashboard, how often, and what is escalated	MDM-D02, MDM-D12 Section 6
6. Assumptions and	What the dashboard assumes and what it	None

Section	Content	Main Sources
Limitations	cannot show	

2. Workspace Structure

The workspace is ten registers linked by ID. Any item can be traced from the asset at risk to the decision taken on it, and back.

2.1 Registers and IDs

Register	ID Format	Held In	Prepared By	Approved or Decided By
Assets	MDM-AST-001	MDM-D03	GRC Analyst	CISO
Risks	MDM-RSK-001	MDM-D04; residual fields updated from MDM-D12	GRC Analyst	CISO; Risk Owner for treatment and targets
Controls	MDM-CTL-001	MDM-D05	GRC Analyst	CISO
Standard requirements	MDM-STD-001	MDM-D07	GRC Analyst	CISO
Conditional Access policies	MDM-CAP-001	MDM-D08	GRC Analyst	CISO
Evidence	MDM-EVD-001	MDM-D09	IT Operations Team, or the enterprise IAM team for the items listed in MDM-D09 Section 2.2	GRC Analyst rates each item Accepted, Partial or Not Provided
Tests	MDM-TST-001	MDM-D10	GRC Analyst	CISO
Findings	MDM-FND-001	MDM-D11	GRC Analyst	Control Owner agrees the finding
Recommendations	MDM-REC-001	MDM-D11; retest plan in MDM-D12 Section 5	Owner named in each recommendation	Closed by a passed retest (GRC Analyst or Internal Audit)
Risk Owner	D-nn	Raised in MDM-	GRC Analyst	Business Owner

Register	ID Format	Held In	Prepared By	Approved or Decided By
decisions		D11 Section 6; recorded in MDM-D12 Section 3		

Preparer and approver follow the MDM-D02 RACI: the GRC Analyst is Responsible and the CISO Accountable for scope, risks, control requirements and testing. Simulated evidence files carry their own reference, such as SIM-EVD-001, inside their MDM-EVD record.

Assumption and limitation IDs (A-, L-, AS-, LM-) are local to the document that holds them. They are always cited with that document, for example MDM-D08 A-06.

2.2 Traceability Chain

Each link in the chain is held in one place. The dashboard reads the links from there and keeps no copy of its own.

Link	Recorded In
Asset → Risk	MDM-D04, Related Assets field of each risk
Risk → Control	MDM-D05, each control entry
Control → Evidence	MDM-D09 Section 3, evidence requests by control
Evidence → Test	MDM-D09 Section 4, D10 Test column of the evidence index
Test → Finding	MDM-D11 Section 3, Test, Control and Risk columns of the register
Finding → Recommendation	MDM-D11 Section 5, Finding column
Recommendation → Decision, Residual and Retest	MDM-D12 Sections 3 to 5

Broken links are reported, not filled in. MDM-FND-007, 008 and 009 have no control in MDM-D05 and no risk in MDM-D04, so each is rated against the closest risk. MDM-TST-008 to 010 test MDM-D07 requirements that have no risk in MDM-D04. Section 3 measures these breaks as chain completeness.

2.3 Worked Example

One full chain, for the iOS Share extension finding.

Step	Item	What the Record Shows
Asset	MDM-AST-006	Personal iOS/iPadOS devices used for work
Risk	MDM-RSK-002	Corporate data leakage to personal apps or accounts. Inherent High (12). Risk Owner: Business Owner
Control	MDM-CTL-002	Its requirements sit in MDM-D07 Sections 4.2–4.5 (MDM-STD-010 to 013)
Evidence	MDM-EVD-005	iOS app protection policy export, rated Accepted
Test	MDM-TST-001	BYOD data transfer restrictions
Finding	MDM-FND-001	iOS Share extension moves corporate files outside managed apps. Design, Medium (8)
Recommendation	MDM-REC-001	Record the platform constraint in MDM-D07 Section 4.4 and submit the remaining exposure to the Business Owner. Owner: IT Operations Manager
Decision	D-02	Accepted on 16 November 2026, on condition that shared files cannot be opened outside managed apps
Residual and Retest	MDM-RSK-002	Current Medium (9), provisional. Target Medium (8). MDM-REC-001 retest by 14 February 2027

2.4 Update Rules

Rule	Description
UR1 – Source first	A value changes in its source register first. MDM-D13 is then updated from the source, never the other way round.
UR2 – Dated snapshot	Every snapshot shows its as-at date. A new snapshot replaces the old one in Section 4, and the old one stays in the version history.
UR3 – Refresh	The snapshot is refreshed on the cadence in Section 5, and after any event in MDM-D12 Section 6.
UR4 – Approval	The GRC Analyst prepares each snapshot and the CISO approves it before it is shared, as MDM-D02 sets for reporting readiness conclusions.

Rule	Description
UR5 – Independence	Where GRC prepared the item itself, such as MDM-REC-009, the dashboard shows the Internal Audit result, not a GRC status.
UR6 – Simulation	Every snapshot is labelled simulated while no tenant exists.

3. Readiness Measures

Readiness is judged on nine measures in two groups. Coverage measures show how much of the scope has been assessed. Outcome measures show how well the assessed scope works. A Red outcome measure makes the case Not Ready. A coverage measure below Green stops it from being Ready.

3.1 Coverage Measures

ID	Measure	Calculation	Source	Green	Amber	Red
RM-01	Risk assessment coverage	Risks with a current residual ÷ risks in MDM-D04	MDM-D12 Section 4	100%	75–99%	Below 75%
RM-02	Control test coverage	MDM-D05 controls tested in MDM-D10 ÷ controls in MDM-D05	MDM-D10 Sections 3.1 and 5	100%	75–99%	Below 75%
RM-03	Requirement test coverage	MDM-D07 requirements covered by an MDM-D10 test ÷ requirements in MDM-D07	MDM-D10 Sections 3.1 and 5	100%	75–99%	Below 75%
RM-04	Evidence acceptance	Evidence items rated Accepted ÷ evidence items requested	MDM-D09 Section 4	95% or more	80–94%	Below 80%
RM-05	Chain completeness	Findings linked to both a control in MDM-D05 and a risk in MDM-D04 ÷ findings	MDM-D11 Section 3	100%	80–99%	Below 80%
RM-06	Open Risk Owner decisions	Decisions not yet made or not yet in effect	MDM-D12 Section 3	None open	Open, each tied to a dated retest or assessmen	Open with no date

ID	Measure	Calculation	Source	Green	Amber	Red
					t	

3.2 Outcome Measures

ID	Measure	Calculation	Source	Green	Amber	Red
RM-07	Control effectiveness	Tests rated Effective ÷ tests performed. A test counts as Effective once every recommendation linked to it passes retest	MDM-D10 Section 3.3; MDM-D12 Section 5	90% or more	70–89%	Below 70%
RM-08	Residual risk profile	Assessed risks with a current residual of High	MDM-D12 Section 4	None, and none provisional	None, but at least one provisional	One or more
RM-09	Remediation timeliness	Recommendations past their due date and not closed	MDM-D11 Section 5; MDM-D12 Section 5	None overdue	None overdue, but one or more due within 30 days and not yet reported complete	One or more overdue

3.3 Overall Readiness Status

The status is set by the first rule that applies.

Order	Status	Rule
1	**Not Ready**	Any outcome measure (RM-07 to RM-09) is Red.
2	**Ready**	Every measure is Green.
3	**Ready with Conditions**	All other cases. The conditions are the measures below Green, listed in Section 4.

The status describes the tested scope only. The coverage measures show what lies outside it, so a reader cannot take an untested area as passed.

A measure that relies on a provisional value, such as the MDM-RSK-002 residual, is marked provisional. So is the overall status, if it would change when that value changes.

Coverage reaches Green only at 100%, because an untested area cannot be called ready. Amber at 75% marks a scope that is mostly tested, with the rest planned for the next cycle. The 90% effectiveness line allows one test in a sample of ten to fall short.

3.4 Control Readiness Rating

MDM-D10 assigns the control rating to this document. Each control in MDM-D05 is rated from its MDM-D10 test results.

Rating	Rule
Implemented	Every test of the control is Effective, or has become Effective after a passed retest (RM-07).
Partial	The control's tests give mixed results, or a test is Partially Effective.
Not Implemented	Every test of the control is Not Effective.
Not rated	The control was not tested. It counts against RM-02 instead.

The rating shows how the control performed when tested, not whether a configuration exists. Tests of MDM-D07 requirements with no control in MDM-D05 (MDM-TST-008 to 010) are not rated here. They count in RM-05 and RM-07.

4. Readiness Snapshot

As at 16 November 2026, the case is Not Ready. Two of ten tests were effective, so the tested controls cannot yet be relied on. No assessed risk sits at High and no recommendation is overdue. All values are simulated.

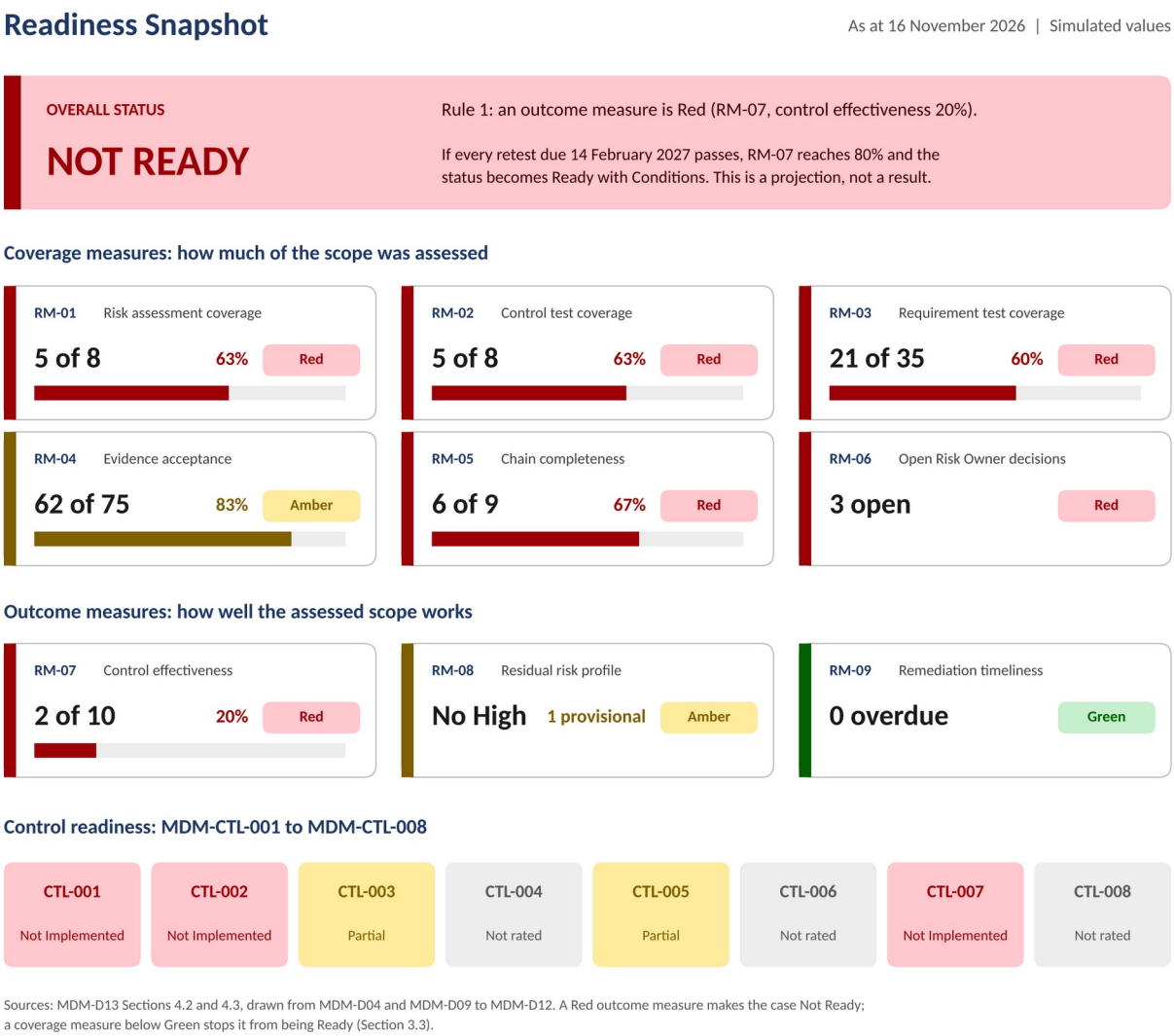


Figure 2. Readiness snapshot as at 16 November 2026. Values come from Sections 4.2 and 4.3. All values are simulated.

4.1 Overall Status

The status is Not Ready under rule 1 in Section 3.3, because RM-07 is Red. It is not provisional: a change in the MDM-RSK-002 residual would not change it.

If every retest due by 14 February 2027 passes, MDM-TST-001, 002, 005, 006, 007 and 008 count as Effective. RM-07 would then reach 8 of 10 (80%, Amber), and the status would become Ready with Conditions. This is a projection, not a result.

Ready needs every coverage measure at 100%. That depends on the next test cycle, which has no date yet (Section 4.5).

4.2 Measures

ID	Measure	Value	Status	Basis
RM-01	Risk assessment coverage	5 of 8 (63%)	Red	MDM-RSK-004, 006 and 008 not assessed
RM-02	Control test coverage	5 of 8 (63%)	Red	MDM-CTL-004 not tested (MDM-EVD-023 Not Provided); MDM-CTL-006 and 008 left to the next cycle
RM-03	Requirement test coverage	21 of 35 (60%)	Red	14 untested: MDM-STD-009, 014 to 021, 024, 026, 027, 030 and 031
RM-04	Evidence acceptance	62 of 75 (83%)	Amber	9 Partial, 4 Not Provided
RM-05	Chain completeness	6 of 9 (67%)	Red	MDM-FND-007, 008 and 009 have no control in MDM-D05 or risk in MDM-D04
RM-06	Open Risk Owner decisions	3 open	Red	D-01 has no date. D-03 and D-04 are tied to retests due 14 February 2027
RM-07	Control effectiveness	2 of 10 (20%)	Red	Effective: MDM-TST-004 and 010
RM-08	Residual risk profile	No High; 1 provisional	Amber	MDM-RSK-002 at Medium (9), provisional until MDM-REC-011
RM-09	Remediation timeliness	None overdue	Green	Earliest due date 14 February 2027

MDM-STD-009 (MDM-D07 Section 4.1) is covered by no MDM-D10 test and is missing from the untested list in MDM-D10 Section 5. It is counted as untested here.

MDM-REC-010 brings MDM-CTL-004 and MDM-RSK-004 into testing. If it is done by 14 February 2027, RM-01 and RM-02 each reach 6 of 8 (75%, Amber).

4.3 Control Readiness

Control	Tests	Results	Rating
MDM-CTL-001	MDM-TST-006	Not Effective	Not Implemented
MDM-CTL-002	MDM-TST-001, 002	Not Effective; Not Effective	Not Implemented
MDM-CTL-003	MDM-TST-005	Partially Effective	Partial
MDM-CTL-004	None	Not tested; MDM-EVD-023	Not rated

Control	Tests	Results	Rating
		Not Provided	
MDM-CTL-005	MDM-TST-003, 004	Not Effective; Effective	Partial
MDM-CTL-006	None	Next test cycle	Not rated
MDM-CTL-007	MDM-TST-007	Not Effective	Not Implemented
MDM-CTL-008	None	Next test cycle	Not rated

No control is rated Implemented yet. Three are Not Implemented, two Partial and three not rated.

4.4 Open Decisions and Milestones

Date	Milestone	Effect on the Dashboard
14 February 2027	Retests of MDM-REC-001, 002, 004 to 007 and 009 to 012; first quarterly review under MDM-REC-003	If all pass, RM-07 reaches 80% and the status becomes Ready with Conditions. MDM-REC-005 settles D-03, MDM-REC-011 settles D-04, and MDM-REC-010 brings MDM-RSK-004 into assessment
15 May 2027	MDM-REC-008 retest	MDM-TST-009 counts as Effective
After the second quarterly review	MDM-REC-003 closure, validated by Internal Audit	MDM-TST-003 counts as Effective, and MDM-CTL-005 can reach Implemented
Not set	IT Operations assessment for D-01	A date moves RM-06 from Red to Amber
Not set	Next test cycle: MDM-CTL-006, MDM-CTL-008 and the untested MDM-D07 requirements, MDM-D07 Section 5.2 first	Needed for any coverage measure to reach Green

4.5 Items for Attention

These items come from building the dashboard. They are reported to the CISO under Section 5. The dashboard does not decide them.

Item	Why It Matters	Raised With
D-01 has no date for the IT Operations assessment	MDM-RSK-003 target stays open, and RM-06 stays Red	Business Owner, through the CISO
The next test cycle has no date	No coverage measure can reach Green, so the case cannot reach Ready	CISO
MDM-STD-009 is in no test and missing from MDM-D10 Section 5	An untested requirement was not reported as untested	GRC Analyst, for the next MDM-D10 revision

5. Reporting and Escalation

The dashboard is issued monthly to the people who own a decision or an action in it. A worse status is escalated within five working days, without waiting for the next issue.

5.1 Distribution and Cadence

A snapshot is issued on the 16th of each month, and once more within five working days after 14 February 2027 to report the retests. The GRC Analyst prepares it and the CISO approves it before it goes out (UR4).

Audience	Receives	Frequency	Purpose
CISO	Full Section 4	Monthly	Approves the snapshot and acts on the items for attention
Business Owner (Risk Owner)	Overall status, RM-06, RM-08 and the decisions due	Monthly	Tracks the open decisions and the residual risks they own
IT Operations Manager (Control Owner)	Control readiness, RM-09 and their own recommendations	Monthly	Tracks remediation against due dates
Internal Audit	Full Section 4	Quarterly	Independent view, and the status of MDM-REC-003 and MDM-REC-009, which it retests
Senior management	Overall status and summary, through MDM-D14	Quarterly	Readiness decision and support needed

Each snapshot states its as-at date, the simulated label, and what changed since the last one. Values are never shown without their status, so a reader does not have to judge a number alone.

5.2 Escalation

Condition	Escalated To	Within
The overall status gets worse	CISO and Business Owner	5 working days
An outcome measure (RM-07 to RM-09) turns Red	CISO	5 working days
A recommendation passes its due date	Risk Owner of the linked risk, as MDM-D12 Section 2.3 requires	5 working days
An event in MDM-D12 Section 6 occurs	Risk Owner, as MDM-D12 Section 6 requires. The dashboard is refreshed (UR3)	5 working days
An item for attention stays open past two monthly issues	CISO raises it with the Business Owner	At the third monthly issue

Escalation reports the condition and its source. The decision stays with the Risk Owner or the CISO, as set in MDM-D12.

The current items for attention (Section 4.5) are raised in the first issue. If D-01 or the next test cycle still has no date by the 16 January 2027 issue, the CISO raises it with the Business Owner.

6. Assumptions and Limitations

6.1 Assumptions

ID	Assumption
AS-01	MDM-D04 and MDM-D09 to MDM-D12 are current as at 16 November 2026. The dashboard holds no value they do not hold.
AS-02	The thresholds in Section 3 are set for this case study and its sample of ten tests. They are not taken from a standard.
AS-03	The retest dates in MDM-D12 Section 5 hold. The projections in Sections 4.1 and 4.4 assume every retest passes.
AS-04	The roles in Section 5 exist as described in MDM-D02 and MDM-D12, including the Business Owner and Internal Audit.

6.2 Limitations

ID	Limitation
LM-01	No tenant was configured and no dashboard tool was built. All values are

ID	Limitation
	simulated.
LM-02	The overall status covers the tested scope only. RM-01 to RM-03 show what lies outside it.
LM-03	The measures count items and do not weight them by risk. In RM-07, a test on a High risk counts the same as one on a Medium risk, so RM-07 is read with RM-08 and MDM-D12 Section 4.
LM-04	A control rating summarises its test results. The failed steps behind a Partial or Not Implemented rating are in MDM-D10 and MDM-D11.
LM-05	The counts in Section 4.2 were made by hand from MDM-D09 and MDM-D10. A change in either document requires a recount (UR1).
LM-06	Projections in Sections 4.1 and 4.4 are expectations, not results. They hold only after passed retests.

Executive Readiness Report

MDM-D14

1. Purpose and Scope

This report tells senior management where the MDM case stands as at 16 November 2026, and what it needs from them. It answers five questions: the overall risk level, the three main gaps, the immediate action, who owns it, and the decision required from management.

It adds no new ratings, estimates or decisions. Every figure comes from MDM-D12 or MDM-D13, with the section it came from in brackets. Where this report differs from a source, the source is correct.

Two results are reported separately because they answer different questions. The risk level is the current residual risk: how exposed the organization is now, within the tested scope. The readiness status shows whether the controls can be relied on yet. The two can differ, and in this case they do.

The report is issued to senior management quarterly, as set in MDM-D13 Section 5.1. The GRC Analyst prepares it and the CISO approves it before issue, as MDM-D02 sets for readiness conclusions.

No tenant was configured. All values, dates and decisions are simulated.

Structure

Section	Content	Main Sources
1. Purpose and Scope	Purpose, scope and structure of this report	None
2. Summary for Management	One answer to each of the five questions	MDM-D12, MDM-D13
3. Risk Level and Readiness Status	The current residual risk, the readiness status, and why they differ	MDM-D12 Section 4; MDM-D13 Sections 4.1–4.2
4. Top Three Gaps	The three gaps that most affect the risk level and the readiness status, and the risk each leaves open	MDM-D11 Sections 4–5; MDM-D12 Section 4; MDM-D13 Section 4.2
5. Immediate Action and Owners	What must start now, who owns it, and when it is checked	MDM-D11 Section 5; MDM-D12 Section 5
6. Decisions Required from Management	What only senior management can decide, and what happens without a decision	MDM-D12 Section 3; MDM-D13 Sections 4.5 and 5.2

Section	Content	Main Sources
7. Outlook	What the next retests can change, what they cannot, and what would raise the risk level	MDM-D12 Section 6; MDM-D13 Sections 4.1 and 4.4
8. Basis and Limitations	What this report relies on and what it cannot show	MDM-D12 Section 7; MDM-D13 Section 6

2. Summary for Management

As at 16 November 2026, the case is Not Ready, although no assessed risk is at High. Current exposure within the tested scope is Medium, but most tested controls do not yet work as designed, so they cannot be relied on. All values are simulated.

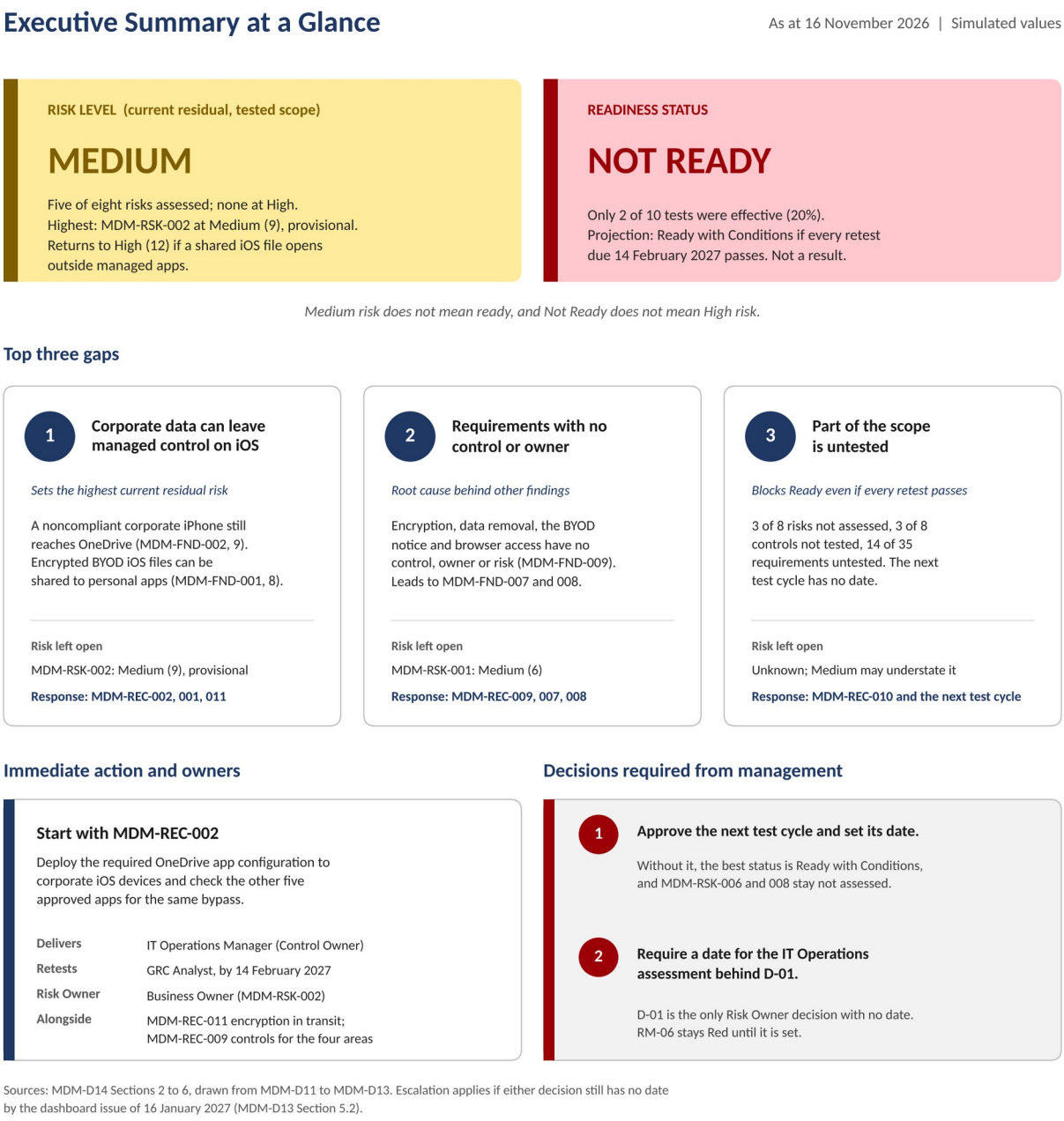


Figure 3. Executive summary at a glance. Each panel answers one of the five questions in the table below. All values are simulated.

Question	Answer	Source
1. What is the overall risk level?	Medium, within the tested scope. All five assessed risks sit at Medium. The highest is MDM-RSK-002, corporate data leakage, at Medium (9). It is provisional and returns to High	MDM-D12 Sections 4 and 6; MDM-D13 Sections 4.1–4.2

Question	Answer	Source
	(12) if a shared iOS file proves readable outside managed apps. Three of the eight risks are not assessed yet. Separately, the readiness status is Not Ready, because only 2 of 10 tests were effective (20%).	
2. What are the three main gaps?	(1) Corporate data on iOS can leave managed control: a noncompliant corporate iPhone still reaches OneDrive (MDM-FND-002, score 9), and iOS BYOD users can share encrypted files to personal apps (MDM-FND-001, score 8, accepted under D-02). (2) Encryption, data removal, the BYOD notice and browser access have no control, owner or risk (MDM-FND-009). This is the root cause behind the unconfirmed wipe of a lost device and the missing retention period. (3) Part of the scope is untested: 3 of 8 risks, 3 of 8 controls and 14 of 35 standard requirements, and the next test cycle has no date.	MDM-D12 Sections 3–4; MDM-D13 Sections 4.2 and 4.5
3. What must happen now?	Deploy the required OneDrive app configuration to corporate iOS devices, and check the other five approved apps for the same bypass (MDM-REC-002). It fixes the highest-scored finding and is first in the remediation priority. Alongside it, confirm encryption in transit (MDM-REC-011), which decides whether MDM-RSK-002 stays provisional and whether D-04 takes effect.	MDM-D11 Section 5; MDM-D12 Sections 3 and 5
4. Who is responsible?	The IT Operations Manager, as Control Owner, delivers both actions. The GRC Analyst retests them by 14 February 2027. The Business Owner owns MDM-RSK-002 as Risk Owner, and the CISO tracks progress in the monthly dashboard.	MDM-D12 Sections 3 and 5; MDM-D13 Section 5.1
5. What decision is required from management?	Approve the next test cycle and set its date. Without it, the case cannot reach Ready, even if every retest passes. Also require a date for the IT Operations assessment behind Risk Owner decision D-01, which has none.	MDM-D13 Sections 4.1, 4.4 and 4.5

Sections 3 to 6 give the basis for each answer. Section 7 shows what the retests due by 14 February 2027 can change.

3. Risk Level and Readiness Status

The risk level is Medium and the readiness status is Not Ready. Both hold at once, because they measure different things.

3.1 Risk Level

Five of the eight risks were assessed, and all five sit at Medium. The two risks that started at High, MDM-RSK-002 and MDM-RSK-005, fell to Medium. No assessed risk is at High (MDM-D12 Section 4).

Risk	Inherent	Current Residual	Target Residual
MDM-RSK-002 Corporate data leakage to personal apps or accounts	High (12)	Medium (9), provisional	Medium (8)
MDM-RSK-005 Unauthorized changes to central device security settings	High (12)	Medium (6)	Low (3)
MDM-RSK-001 Unauthorized access to data on a lost corporate device	Medium (9)	Medium (6)	Low (3)
MDM-RSK-003 Corporate data exposure through noncompliant devices	Medium (9)	Medium (6)	Medium (6) until D-01 is decided
MDM-RSK-007 Continued corporate access after contractor departure	Medium (9)	Medium (6)	Low (3)
MDM-RSK-004 Business disruption from incorrect access policy changes	Medium (6)	Not assessed	Not set
MDM-RSK-006 Inappropriate internal access to employee device reports	Medium (6)	Not assessed	Not set
MDM-RSK-008 Inaccurate device compliance reporting	Medium (6)	Not assessed	Not set

Source: MDM-D12 Section 4.

Current residual gives credit only to controls that worked when tested. Targets are what the Risk Owner expects once the open recommendations close, and they hold only after a passed retest (MDM-D12 Section 2.1).

MDM-RSK-002 is provisional until encryption in transit is confirmed (MDM-REC-011). It cannot fall below Medium (8) while the iOS Share exposure stays accepted under D-02 (MDM-D12 Section 4). Section 7 sets out what would return it to High.

Not assessed means the risk's controls were not tested. It does not mean the risk is low.

3.2 Readiness Status

The case is Not Ready because only 2 of 10 tests were effective (20%). Any Red outcome measure makes the case Not Ready (MDM-D13 Section 3.3, rule 1). The status is not provisional: a change in the MDM-RSK-002 rating would not change it (MDM-D13 Section 4.1).

Measure	Value	Status
Outcome: control effectiveness (RM-07)	2 of 10 tests effective (20%)	Red
Outcome: residual risk profile (RM-08)	No High; 1 provisional	Amber
Outcome: remediation timeliness (RM-09)	None overdue	Green
Coverage: risks assessed (RM-01)	5 of 8 (63%)	Red
Coverage: controls tested (RM-02)	5 of 8 (63%)	Red
Coverage: standard requirements tested (RM-03)	21 of 35 (60%)	Red
Coverage: evidence accepted (RM-04)	62 of 75 (83%)	Amber
Coverage: findings fully traced (RM-05)	6 of 9 (67%)	Red
Coverage: open Risk Owner decisions (RM-06)	3 open, 1 with no date	Red

Source: MDM-D13 Section 4.2.

No control is rated Implemented. Three are Not Implemented, two Partial and three not rated, because they were not tested (MDM-D13 Section 4.3).

3.3 Why the Two Differ

The risk level follows the findings that remain open. No finding scores above 9, so every assessed risk sits at Medium (MDM-D12 Section 4). The readiness status asks whether the controls work as designed. Eight of ten tests found that they do not yet, and each of the five controls tested fell short in at least one test (MDM-D13 Sections 4.2–4.3).

The findings are moderate one by one, but they are many and spread across the tested scope. Medium risk does not mean ready, and Not Ready does not mean High risk. Both results also cover the tested scope only: three risks are not assessed and three controls are not tested.

4. Top Three Gaps

The three gaps are corporate data leaving managed control on iOS, requirements with no control or owner, and scope that has not been tested. Together they set the risk level and keep the case from Ready.

Each gap meets one of three criteria. It sets the highest current residual risk, it is the root cause behind other findings, or it blocks Ready even if every retest passes. The criteria use the existing ratings and add no new ones.

4.1 Corporate Data Can Leave Managed Control on iOS

Field	Detail
Criterion	Sets the highest current residual risk
What happens now	A noncompliant corporate iPhone still reaches OneDrive, because the required OneDrive app configuration was not deployed (MDM-FND-002, score 9). On personal iOS devices, the Share extension moves encrypted corporate files to personal apps. The files could not be opened there (MDM-FND-001, score 8).
What is required	Noncompliant corporate devices are blocked from corporate services, and corporate files stay in approved apps (MDM-D07 Section 4.4; MDM-D08; MDM-CTL-002).
Risk left open	MDM-RSK-002, corporate data leakage, at Medium (9), provisional. The Share extension exposure was accepted under D-02, so the risk stays at Medium (8) or above.
Response	MDM-REC-002 deploys the configuration. MDM-REC-001 records the iOS constraint. MDM-REC-011 confirms encryption in transit. All are retested by 14 February 2027.

Sources: MDM-D11 Section 4.1; MDM-D12 Sections 3–5.

4.2 Requirements with No Control or Owner

Field	Detail
Criterion	Root cause behind other findings
What happens now	Encryption, data removal, the BYOD notice and browser access work in the simulation. However, MDM-D05 has no control, owner or risk for them, because it was not updated when MDM-D07 added them (MDM-FND-009). Two failures already follow from this: the wipe of a lost device was never confirmed (MDM-FND-007), and BYOD activation records have no

Field	Detail
	retention period (MDM-FND-008).
What is required	Each MDM-D07 requirement has a control, an owner and a linked risk. Data removal is mapped to NCA ECC 2-6-3-3.
Risk left open	No one is accountable for keeping these capabilities working, so a failure could go unnoticed. The worst case is corporate data left on a lost device, under MDM-RSK-001 at Medium (6).
Response	MDM-REC-009 adds the four controls to MDM-D05, owned by the CISO and retested by Internal Audit by 14 February 2027. MDM-REC-007 and 008 fix the two failures.

Sources: MDM-D11 Section 4.2; MDM-D12 Sections 4–5.

4.3 Part of the Scope Is Untested

Field	Detail
Criterion	Blocks Ready even if every retest passes
What happens now	3 of 8 risks are not assessed, 3 of 8 controls are not tested, and 14 of 35 standard requirements are untested. One of them, MDM-STD-009, was also missing from the untested list in MDM-D10. The next test cycle has no date.
What is required	Every coverage measure at 100% before the case can be called Ready (MDM-D13 Section 3.3).
Risk left open	Exposure in the untested areas is unknown, so the Medium risk level may understate it. If every retest passes, the best status is Ready with Conditions.
Response	MDM-REC-010 tests MDM-CTL-004 by 14 February 2027, which brings risks assessed and controls tested to 6 of 8 (75%). The rest needs the next test cycle, which is the decision in Section 6.

Sources: MDM-D13 Sections 4.1, 4.2 and 4.5.

4.4 Other Findings

MDM-FND-003 to 006 and the open MFA confirmation (MDM-REC-012) are not among the three. Each finding scores 6, and each item has an owner and a retest by 14 February 2027 (MDM-D12 Sections 4–5). MDM-FND-003 concerns the broadest administrative account, so Internal Audit, not the CISO, validates its closure.

5. Immediate Action and Owners

Remediation starts with MDM-REC-002, the OneDrive configuration for corporate iOS devices. The IT Operations Manager owns it, and the GRC Analyst retests it by 14 February 2027. Two actions run alongside it, because they decide how far the risk level can be trusted and fix the root cause.

5.1 Start Now

Order	Action	Why Now	Owner	Retest
1	MDM-REC-002: deploy the OneDrive app configuration to corporate iOS devices, and check the other five approved apps for the same bypass	Highest-scored finding (9) and first in the remediation priority	IT Operations Manager	GRC Analyst, by 14 February 2027. Passes when a noncompliant corporate iPhone is blocked in all six apps
2	MDM-REC-011: provide the missing evidence and review the network path for encryption in transit	Decides whether MDM-RSK-002 stays provisional and whether D-04 takes effect	IT Operations Manager	GRC Analyst, by 14 February 2027. Passes when the evidence is accepted and the review is recorded
3	MDM-REC-009: add controls for encryption, data removal, the BYOD notice and browser access to MDM-D05, each with an owner and a linked risk	Fixes the root cause behind MDM-FND-007 and 008; runs alongside the others	CISO; the GRC Analyst prepares the draft	Internal Audit, by 14 February 2027, because GRC prepares the draft

Sources: MDM-D11 Sections 5.1 and 5.3; MDM-D12 Section 5.

MDM-REC-007 also asks for the wipe status of the lost device to be confirmed now. It is a single check, so it does not wait for its place in the order.

The other recommendations follow the MDM-D11 priority: MDM-REC-001 (8), then the findings scored 6, then MDM-REC-008 (Low). All are retested by 14 February 2027, except MDM-REC-008 by 15 May 2027 (MDM-D12 Section 5).

5.2 Accountability

Role	Accountable For
IT Operations Manager (Control Owner)	Delivers nine of the twelve recommendations, and reports each one complete so it can be

Role	Accountable For
	retested
CISO	Owns MDM-REC-003, 009 and 012. Approves the monthly dashboard and this report, and raises open items with the Business Owner
Business Owner (Risk Owner)	Decides treatment and accepts residual risk, including D-01 to D-04
GRC Analyst	Retests the recommendations, except where GRC prepared the work. Prepares the dashboard and this report
Internal Audit	Retests MDM-REC-003 and 009, so no one checks their own work

Sources: MDM-D11 Section 5; MDM-D12 Sections 2.3, 3 and 5; MDM-D13 Section 5.

A recommendation that passes its due date is escalated to the Risk Owner within five working days (MDM-D13 Section 5.2). As at 16 November 2026, none is overdue.

6. Decisions Required from Management

Management is asked to approve the next test cycle and set its date, and to require a date for the IT Operations assessment behind D-01. Both items have no date at working level, and both are needed before the case can be called Ready.

6.1 Decisions Required

Decision	Why It Is Needed	If Not Decided
1. Approve the next test cycle and set its date. It covers MDM-CTL-006, MDM-CTL-008 and the untested MDM-D07 requirements, starting with Section 5.2 (permissions)	The case cannot reach Ready while any part of the scope is untested. The retests due by 14 February 2027 cannot close this gap	The best status the case can reach is Ready with Conditions. MDM-RSK-006 and 008 stay not assessed, so the risk level stays incomplete
2. Require a date for the IT Operations assessment behind D-01	D-01 is the only Risk Owner decision with no date. Until it is made, the MDM-RSK-003 target stays open	Open Risk Owner decisions (RM-06) stay Red. The access window after a device loses compliance stays undecided

Sources: MDM-D12 Sections 3–4; MDM-D13 Sections 3.3, 4.4 and 4.5.

If either item still has no date by the dashboard issue of 16 January 2027, the CISO raises it with the Business Owner (MDM-D13 Section 5.2). A decision from management now avoids waiting for that escalation.

6.2 Decisions Already Taken

The Business Owner, as Risk Owner, decided the four items raised in MDM-D11 on 16 November 2026. They are listed for information and need no further decision from management. No finding requires mandatory management review under the MDM-D11 rules.

Item	Decision	Status
D-01: access window after a device loses compliance (MDM-RSK-003)	IT Operations assesses ways to shorten the window before the Business Owner decides	Pending; no date for the assessment (decision 2 above)
D-02: iOS Share extension exposure (MDM-RSK-002)	Accepted, with encryption as the protection that applies	In effect, on condition that shared files cannot be opened outside managed apps
D-03: Android immediate lock (MDM-RSK-001)	No decision until MDM-REC-005 measures the unlock window	Not needed yet
D-04: BYOD without MDM enrollment, a deviation from SAMA CSF 3.3.10 consideration 4(e) (MDM-RSK-002)	Accepted on condition, with app-level controls as the alternative. The CISO advised in favour	Not yet in effect. It takes effect only when MDM-REC-011 confirms encryption in transit

Source: MDM-D12 Section 3.

Management should note D-04 in particular, because it accepts a deviation from a regulatory framework. If encryption in transit is not confirmed, it returns to the Business Owner (MDM-D12 Section 6).

7. Outlook

If every retest due by 14 February 2027 passes, the case is expected to reach Ready with Conditions. This is a projection, not a result. Ready also needs the next test cycle, and the risk level would stay Medium.

7.1 What the Retests Can Change

Date	What Is Checked	Expected Effect If It Passes
14 February 2027	Retests of MDM-REC-001, 002, 004 to 007 and 009 to 012, and the first quarterly review under MDM-REC-003	Control effectiveness reaches 8 of 10 (80%, Amber), and the status becomes Ready with Conditions. MDM-REC-010 brings risks assessed and controls tested to 6 of 8 (75%). D-03 and D-

Date	What Is Checked	Expected Effect If It Passes
		04 are settled
15 May 2027	Retest of MDM-REC-008	One more test counts as effective
After the second quarterly review	Closure of MDM-REC-003, validated by Internal Audit	MDM-CTL-005 can reach Implemented
Not set	IT Operations assessment for D-01	The MDM-RSK-003 target can be reset (decision 2 in Section 6)
Not set	Next test cycle	Needed for any coverage measure to reach 100%, and so for Ready (decision 1 in Section 6)

Sources: MDM-D13 Sections 4.1, 4.2 and 4.4.

Even if every retest passes, the risk level stays Medium. MDM-RSK-002 cannot fall below Medium (8) while D-02 stands, and the MDM-RSK-003 target is Medium (6) until D-01 is decided. MDM-RSK-001, 005 and 007 are expected to reach Low (3) (MDM-D12 Section 4).

7.2 What Would Raise the Risk Level

Five of the six re-rating triggers in MDM-D12 could raise a rating or reopen a decision. The sixth, the D-01 decision, only resets a target. The first event below would return the risk level to High.

Event	Effect
A shared iOS file is shown to be readable outside managed apps	MDM-FND-001 rises to High (12). MDM-RSK-002 returns to High (12), and D-02 returns to the Business Owner
Encryption in transit is not confirmed, or the network path review finds an issue	D-04 does not take effect and returns to the Business Owner. A finding is raised against MDM-RSK-002
The Android unlock window exceeds one minute on any approved model	MDM-FND-005 is re-rated, and D-03 goes to the Business Owner for that model
Enterprise user MFA coverage is incomplete	A finding is raised and rated
A retest fails	The finding stays open and is re-rated. Its due date does not change

Source: MDM-D12 Section 6.

Each event is reported to the Risk Owner within five working days. A worse overall status is escalated to the CISO and the Business Owner in the same time (MDM-D13 Section 5.2).

7.3 Next Report

The next report follows the retests due by 14 February 2027. It draws on the dashboard snapshot issued within five working days after that date (MDM-D13 Section 5.1). It will show the actual retest results in place of the projection above.

8. Basis and Limitations

This report rests on MDM-D11 to MDM-D13 as at 16 November 2026. It covers the tested scope only, and all values are simulated.

8.1 Basis

Source	Used For	Sections
MDM-D02 Stakeholder and RACI Matrix	Who prepares and approves readiness conclusions	1
MDM-D04 Risk Assessment Methodology and Risk Register	Risk titles	3.1
MDM-D11 Findings and Remediation Register	Findings, gaps, recommendations, owners and remediation priority	2, 4, 5
MDM-D12 Risk Treatment and Retesting Record	Residual risk, Risk Owner decisions, retest plan and re-rating triggers	2 to 7
MDM-D13 GRC Workspace and Readiness Dashboard	Readiness measures and status, control readiness, milestones, reporting and escalation	2, 3, 6, 7

8.2 Assumptions

ID	Assumption
AS-01	MDM-D11 to MDM-D13 are current as at 16 November 2026. This report holds no value they do not hold.
AS-02	The retest dates in MDM-D12 Section 5 hold. The projections in Section 7 assume every retest passes.
AS-03	The roles in Section 5.2 exist as described in MDM-D02 and MDM-D12, including the Business Owner and Internal Audit.

8.3 Limitations

ID	Limitation
LM-01	No tenant was configured. All values, dates and decisions are simulated.
LM-02	The risk level and the readiness status cover the tested scope only. Three risks are not assessed and three controls are not tested (Section 4.3).
LM-03	The MDM-RSK-002 rating is provisional until MDM-REC-011 is retested.
LM-04	Projections in Section 7 are expectations, not results. They hold only after passed retests.
LM-05	The risk scales do not score regulatory impact. Regulatory exposure, such as under NCA ECC or the D-04 deviation from SAMA CSF, is noted but not rated (MDM-D11 LM-02).
LM-06	This report summarises. The test steps and evidence behind each result are in MDM-D09 to MDM-D11.